MINI-PROJET 5DESI · DOSSIER D'ARCHITECTURE

MedX — Conception de la solution technique

La conception technique de MedX, une plateforme de téléconsultation, de dossier patient tenu à vie et de suivi des ordonnances. Chaque choix suit les priorités de MedX : les données de santé sont protégées au repos et en transit, le dossier ne peut pas être réécrit en silence, et les professionnels habilités accèdent en quelques secondes aux informations critiques en situation d'urgence.

1 **Architecture de haut niveau**

2 **Conception détaillée des composants**

3 **Modèle de données et stockage**

4 **Scalabilité et performances**

5 **Sécurité et conformité**

6 **Présentation (diapositives et notes)**

STYLE

8 microservices en zones de sécurité, pilotés par les événements, zéro confiance

ACCÈS D'URGENCE

Bris de glace, 99,99 %, synthèse critique p95 < 300 ms

CHIFFREMENT

TLS 1.3 / mTLS partout, clés par patient dans un KMS adossé à des HSM

CIBLE DE CHARGE

10 M de patients, 200 000 consultations/jour, 10 000 appels simultanés

Sommaire

0 Contexte et objectifs

1 Architecture de haut niveau

2 Conception des composants

- 2.1 Gestion des utilisateurs
- 2.2 Planification
- 2.3 Consultation
- 2.4 Dossier patient et accès d'urgence
- 2.5 Ordonnances
- 2.6 Interface pharmacie
- 2.7 Notification
- 2.8 Facturation et paiement
- 2.9 Composants de plateforme

3 Données et stockage

4 Scalabilité et performances

5 Sécurité et conformité

6 Décisions et compromis

7 Matrice de traçabilité

8 Feuille de route et risques

0. Contexte, hypothèses et objectifs

Fait partie du dossier de conception **MedX — Solution technique**. Commencer ici : ce document fixe le périmètre, les hypothèses et les chiffres sur lesquels reposent tous les autres documents.

#	Document	Livrable
0	Contexte, hypothèses et objectifs (ce document)	Socle
1	Architecture de haut niveau	Livrable 1
2	Conception détaillée des composants	Livrable 2
3	Modèle de données et stratégie de stockage	Livrable 3
4	Scalabilité et performances	Livrable 4
5	Sécurité et conformité	Livrable 5
6	Décisions d'architecture et compromis	Alignement sur les priorités
7	Matrice de traçabilité des exigences	Complétude
8	Feuille de route et risques	Alignement sur les priorités
—	Présentation	Livrable 6

0.1 MedX en un paragraphe

MedX est une plateforme de santé qui repose sur trois piliers : les **téléconsultations** (prendre rendez-vous, rencontrer un médecin en vidéo, échanger par chat et partager des documents), la **gestion des dossiers patients** (un dossier médical sécurisé, tenu tout au long de la vie et accessible au patient comme aux professionnels qui le soignent) et le **suivi des ordonnances** (le médecin émet une ordonnance électronique que la pharmacie reçoit, prépare et délivre, pendant que le patient suit chaque étape). Comme MedX traite des données de santé — la catégorie de données personnelles la plus sensible —, l'architecture est d'abord guidée par **la protection des données, l'intégrité des dossiers et la disponibilité en urgence**, puis par les parcours de soins, et enfin par les fonctions de support.

0.2 Acteurs

Acteur	Description	Canaux principaux	Actions typiques
Patient	Utilisateur adulte ; peut aussi agir comme **mandataire** (parent d'un mineur, aidant avec consentement)	Application mobile (iOS/Android), application web	Prendre rendez-vous, consulter, lire son dossier, suivre ses ordonnances, payer
Médecin / praticien	Professionnel de santé vérifié (numéro d'inscription contrôlé dans le répertoire national)	Portail web (poste de travail), application mobile	Gérer ses disponibilités, mener les consultations, rédiger ses notes, prescrire
Soignant d'urgence	Praticien titulaire du droit `acces_urgence` (urgences, garde, SAMU)	Portail web, application mobile	Accès « bris de glace » aux informations critiques d'un patient
Personnel de pharmacie	Pharmacien, préparateur, administrateur de pharmacie	Portail pharmacie, ou leur logiciel de gestion d'officine (LGO) via l'API partenaire	Recevoir les ordonnances, mettre à jour leur statut, répondre aux questions des patients

Acteur	Description	Canaux principaux	Actions typiques
Équipes MedX	Agent de support, agent de facturation, administrateur de plateforme, **délégué à la protection des données (DPO)**, auditeur	Console d'administration (accès zéro confiance + SSO + clé matérielle)	Support sans accès aux données cliniques, audits, revues des bris de glace
Systèmes externes	Agendas, prestataire de paiement, fournisseurs SMS/e-mail/push, logiciels de pharmacie, base médicaments, services nationaux de santé, fédération d'identité	API, webhooks	Intégration

0.3 Périmètre

Dans le périmètre — les huit composants métier de l'Annexe 1 et les capacités de plateforme dont ils ont besoin :

1. Gestion des utilisateurs (identité, authentification, autorisations, préférences)
2. Planification des téléconsultations (réservation, listes d'attente, demandes urgentes, agendas externes)
3. Consultation (salles virtuelles, vidéo/audio, chat, transfert de fichiers)
4. Gestion des dossiers patients (historique médical, notes, documents, **accès d'urgence**)
5. Gestion des ordonnances
6. Interface pharmacie
7. Notification
8. Facturation et paiement

Capacités de plateforme : passerelles API et temps réel, moteur de politiques d'accès, bus d'événements, stockage sécurisé de documents, piste d'audit, gestion des clés, observabilité, plateforme de données désidentifiées.

Hors périmètre de la v1 (restent compatibles avec la conception) : gestion de cabinet physique, imagerie médicale (visionneuses PACS/DICOM — seulement des documents déposés et des liens), traitement des remboursements par l'assurance maladie (tiers payant), aide au diagnostic par IA, dispositifs médicaux connectés. Ils figurent dans la feuille de route.

0.4 Les priorités de MedX et leur effet sur la conception

L'énoncé est explicite : *protéger les données en transit et au repos est primordial* et *les professionnels de santé doivent accéder rapidement aux informations du patient en cas d'urgence*. Chaque exigence de priorité haute devient donc un **principe d'architecture non négociable**, et pas seulement une fonctionnalité.

Priorité	Exigence	Devient…
Haute	H1 Confidentialité des données (chiffrement au repos et en transit)	TLS 1.3 / mTLS partout, AES-256 au repos partout, **chiffrement d'enveloppe par patient** des données cliniques (principe P1)
Haute	H2 Gestion des dossiers patients	Service Dossier patient dédié, fondé sur **FHIR**, versionné et audité (P3, P4)
Haute	H3 Accès d'urgence	Capacité de **bris de glace** sur un chemin de lecture isolé de niveau 0, avec revue a posteriori (P2)
Haute	H4 Authentification et autorisations	Fournisseur d'identité éprouvé (OIDC, MFA) + moteur de politiques **RBAC + ABAC**, zéro confiance entre services (P1)
Haute	H5 Intégrité des données et stockage sécurisé des fichiers	Historique en ajout seul, chaînage par hachage, sommes de contrôle, sauvegardes immuables, stockage de documents analysé et chiffré (P3)
Moyenne	M1–M5 Planification, consultations, ordonnances, masquage, agendas	Parcours de soins construits sur le socle de priorité haute

Priorité	Exigence	Devient…
Basse	B1–B6 Pharmacie, préférences, suivi des notifications, anonymisation, paiement, remboursements	Conçus dès maintenant, livrés en dernier, **achetés plutôt que développés** quand c'est possible (PSP, fournisseurs de messagerie)

0.5 Principes d'architecture

ID	Principe	Ce que cela signifie concrètement
P1	**Confidentialité et sécurité dès la conception et par défaut**	Tout chiffrer, moindre privilège, refus par défaut, minimisation des données (aucune donnée de santé dans les SMS, e-mails, agendas, journaux ou événements).
P2	**La sécurité du patient d'abord**	Le chemin d'accès d'urgence doit fonctionner quand tout le reste est dégradé : déploiement isolé, dépendances minimales, niveau de disponibilité le plus élevé.
P3	**L'intégrité avant le confort**	Les données cliniques ne sont jamais écrasées ni supprimées physiquement pendant leur durée de conservation : chaque modification est une nouvelle version, attribuée et infalsifiable.
P4	**Les standards plutôt que le sur-mesure**	HL7 FHIR R4 (+ International Patient Summary), OpenID Connect / OAuth 2.1, WebRTC, OpenAPI 3.1, CloudEvents. Interopérabilité, audits et recrutement facilités.
P5	**Couplage faible, responsabilités claires**	Un service = un contexte délimité = une base de données privée. Les services s'intègrent par des API versionnées et des événements métier.
P6	**Acheter le banal, construire le différenciant**	Réutiliser un fournisseur d'identité, un prestataire de paiement, des fournisseurs de messagerie, un SFU open source. Construire ce qui rend MedX unique : dossiers, accès d'urgence, parcours de soins.
P7	**Monter en charge horizontalement et automatiser**	Services sans état, mise à l'échelle automatique, infrastructure en tant que code, GitOps, aucune modification manuelle en production.
P8	**Observable et auditable par défaut**	Chaque requête est tracée, chaque accès à une donnée de santé est inscrit dans une piste d'audit immuable.

0.6 Hypothèses

ID	Hypothèse	Effet sur la conception
A1	MedX démarre dans l'**UE (d'abord en France)** ; les États-Unis sont un marché possible ensuite.	Le RGPD et la certification française **HDS** (hébergement de données de santé) sont obligatoires ; la conception est **compatible HIPAA** (BAA, audit, chiffrement) pour une future cellule américaine.
A2	Hébergement sur un **cloud public certifié HDS** (implémentation de référence : AWS région Paris, reprise à Francfort ; Azure, Google Cloud ou OVHcloud sont des options équivalentes).	Les services managés ne sont utilisés que s'ils font partie du périmètre certifié du fournisseur. Toutes les données de santé restent dans l'EEE.
A3	Les rôles juridiques (responsable de traitement / sous-traitant) entre MedX et les praticiens sont définis par le DPO.	La conception supporte les deux : contrôle d'accès par praticien, registre des consentements, audit complet.
A4	Les patients utilisent un smartphone ou un navigateur récent compatible WebRTC ; certains ont une mauvaise connexion.	Débit adaptatif, repli en audio seul, relais TURN, expérience pensée d'abord pour le mobile.
A5	Les pharmacies utilisent des logiciels hétérogènes, parfois sans API.	Portail web pour toutes + API partenaire à base d'adaptateurs pour les logiciels connectés.
A6	Les paiements passent par un **prestataire de services de paiement** (PSP) certifié PCI DSS niveau 1.	MedX ne stocke jamais de données de carte → périmètre PCI minimal (SAQ A).
A7	Les médecins utilisent des agendas Google Workspace, Microsoft 365 ou CalDAV.	Connecteurs pour ces trois familles, limités aux disponibilités (libre/occupé).
A8	L'intégration aux services nationaux (ordonnance numérique, identifiant national de santé, DMP) vient après la v1.	Dossiers et ordonnances sont modélisés en FHIR : ces intégrations seront des adaptateurs, pas des refontes.
A9	Les objectifs de croissance ci-dessous sont des chiffres de planification, revus chaque trimestre.	La capacité est conçue avec une marge ×2 et une trajectoire claire au-delà.

0.7 Objectifs de capacité

Chiffres utilisés pour le dimensionnement dans le document de scalabilité.

Indicateur	Année 1 (lancement)	Année 3 (cible)	Capacité de conception (année 3 × 2)
Patients inscrits	1 M	10 M	—
Professionnels de santé	5 000	50 000	—
Pharmacies connectées	2 000	15 000	—
Utilisateurs actifs par jour (jour de pointe)	100 000	1 M	2 M
Téléconsultations par jour	20 000	200 000	400 000
Sessions vidéo simultanées (heure de pointe)	1 000	10 000	20 000
Ordonnances par jour	12 000	120 000	240 000
Notifications par jour	200 000	2 M	4 M
Requêtes API par seconde (pointe)	500	5 000	10 000
Connexions WebSocket simultanées (pointe)	20 000	200 000	400 000
Documents médicaux (cumul)	10 To	150 To	—
Données cliniques structurées (entrepôt FHIR)	0,5 To	10 To	—
Événements d'audit par jour	2 M	20 M	40 M

Comment les chiffres de l'année 3 ont été obtenus : 50 000 professionnels × 4 téléconsultations par jour = 200 000 consultations ; 12 % d'entre elles à l'heure de pointe × 20 min de session en moyenne (salle d'attente comprise) ≈ 8 000 sessions simultanées, arrondies à 10 000 ; 60 % des consultations se terminent par une ordonnance ; environ 6 notifications par consultation, plus les échanges avec les pharmacies ≈ 2 M par jour ; environ 75 M d'appels API par jour avec un facteur de pointe de 5 ≈ 4 300 req/s, arrondies à 5 000.

0.8 Niveaux de service et criticité

Les services sont regroupés en **niveaux de criticité**. Le niveau fixe l'objectif de disponibilité, les objectifs de reprise et l'ordre dans lequel la capacité est protégée quand la plateforme est sous tension.

Niveau	Périmètre	Disponibilité	RPO (perte de données max.)	RTO (perte d'une région)	RTO (perte d'une zone)
Niveau 0 — vital	Accès d'urgence, authentification / validation des jetons, lecture des dossiers	**99,99 %**	0 dans la région (multi-AZ synchrone), ≤ 1 min entre régions	**≤ 15 min**	automatique, < 1 min
Niveau 1 — soins	Écriture des dossiers, consultation, planification, ordonnances, chat	99,95 %	0 dans la région, ≤ 1 min entre régions	≤ 1 h	automatique, < 2 min
Niveau 2 — support	Interface pharmacie, notification, facturation, analytique	99,9 %	≤ 5 min	≤ 4 h	automatique, < 5 min

Capacité	Niveau	Objectif de latence (p95)
Accès d'urgence — résumé critique	0	**< 300 ms** côté API, < 1 s à l'écran
Connexion / émission de jeton	0	< 300 ms (hors interaction MFA de l'utilisateur)
Lecture / écriture du dossier patient	1	< 300 ms / < 500 ms

Capacité	Niveau	Objectif de latence (p95)
Téléconsultation vidéo	1	connexion < 3 s ; < 100 ms d'aller-retour vers le nœud média le plus proche ; bouche-à-oreille < 400 ms
Distribution d'un message de chat	1	< 500 ms
Ordonnance signée → visible dans la boîte de la pharmacie	1	< 5 s
Recherche de créneau / réservation	1	< 300 ms / < 800 ms (hors 3-D Secure)
Envoi d'une notification (critique / standard)	2	< 10 s / < 60 s
Vérification de disponibilité en stock	2	< 1 s en cache, < 3 s en direct
Autorisation de paiement	2	< 2 s (hors 3-D Secure)

0.9 Glossaire

Terme	Signification
Donnée de santé	Toute information relative à la santé d'une personne identifiable (données « sensibles » au sens de l'article 9 du RGPD ; *PHI* en anglais).
HDS	Hébergeur de Données de Santé — certification française obligatoire pour héberger des données de santé.
FHIR	HL7 Fast Healthcare Interoperability Resources — le standard de modèle de données et d'API REST pour la santé.
IPS	International Patient Summary (guide d'implémentation HL7 FHIR) — résumé clinique minimal conçu pour les soins non programmés ; base du résumé d'urgence de MedX.
Bris de glace	Dérogation contrôlée qui donne un accès immédiat en urgence, avec justification et revue obligatoire (*break-glass*).
RBAC / ABAC	Contrôle d'accès fondé sur les rôles / sur les attributs.
PDP / PEP	Point de décision de politique (évalue les règles) / point d'application de la politique (applique la décision dans chaque service).
DEK / KEK	Clé de chiffrement des données / clé de chiffrement de clés (chiffrement d'enveloppe).
HSM / KMS	Module matériel de sécurité / service de gestion des clés.
SFU / TURN	Selective Forwarding Unit (routeur vidéo) / serveur relais utilisé quand aucun chemin direct n'est possible.
WORM	Write Once, Read Many — stockage non réinscriptible : impossible à modifier ou supprimer avant la fin de la rétention.
RPO / RTO	Perte de données maximale admissible / durée d'interruption maximale admissible.
SLO	Objectif de niveau de service.
INS / RPPS / FINESS	Identifiant national de santé / répertoire partagé des professionnels de santé / fichier national des établissements (dont les pharmacies).
PSP	Prestataire de services de paiement (par exemple Stripe, Adyen).
Outbox (patron)	Les événements sont écrits dans la même transaction que la modification métier, puis publiés — aucun événement perdu ni fantôme.
Langage du domaine	Suivant l'approche DDD, les noms métier (événements, tables, API) sont en français, langue du domaine ; les noms techniques standard (ressources FHIR, protocoles) restent inchangés.

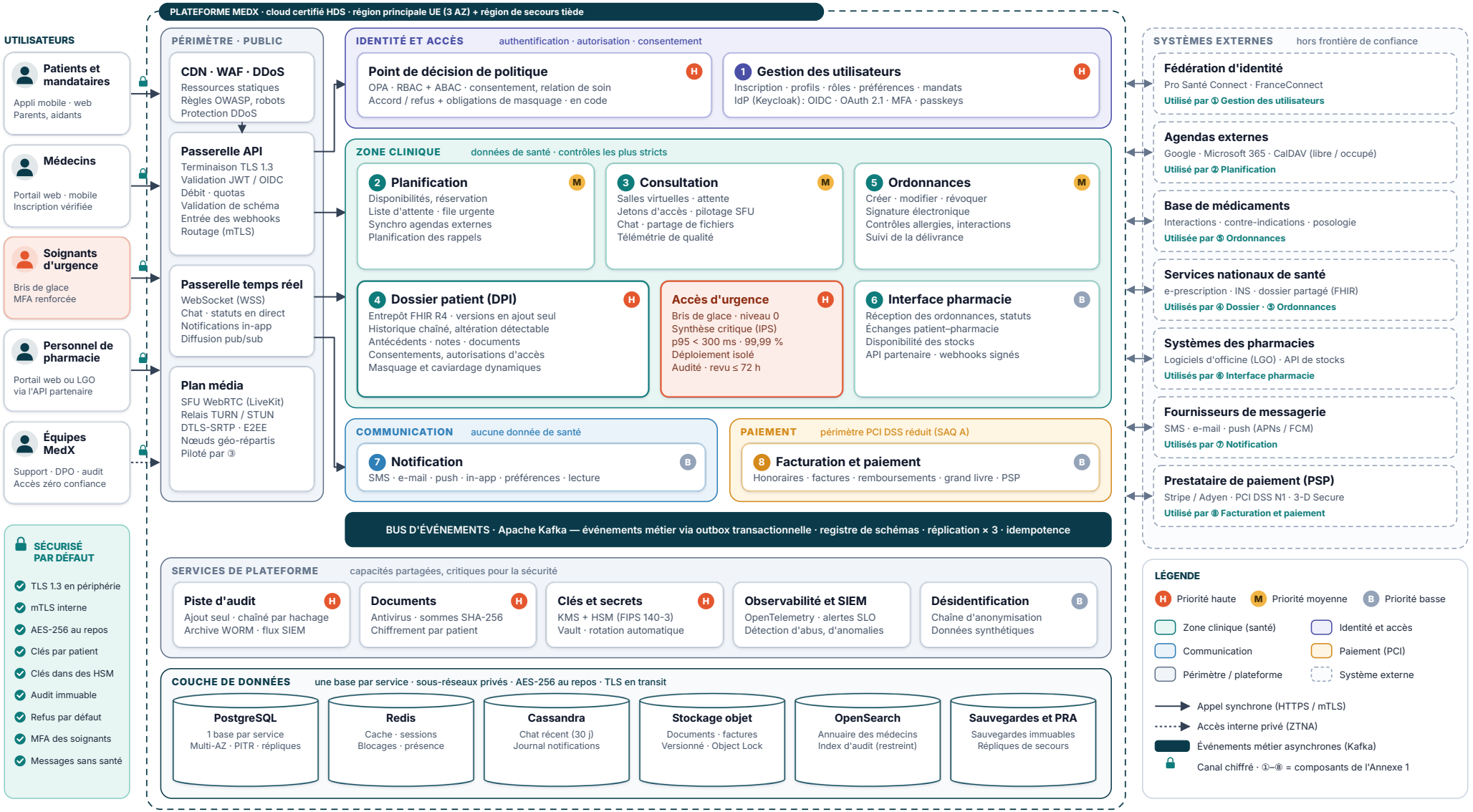
1. Architecture de haut niveau

Livrable 1. Représentation visuelle de la structure d'ensemble de MedX et de la logique qui la sous-tend. Les hypothèses et les objectifs viennent du document 0 — Contexte.

1.1 Vue d'ensemble de l'architecture

MedX — Architecture de haut niveau

Vue des conteneurs · microservices par contexte métier · pilotée par les événements · zéro confiance · chaque lien chiffré



Architecture de haut niveau de MedX

Source vectorielle : `diagrammes/medx-architecture-haut-niveau.svg`. Les numéros ①–⑧ sont les composants de l'Annexe 1; les pastilles H / M / B indiquent les priorités de MedX (Annexe 2 : haute, moyenne, basse).

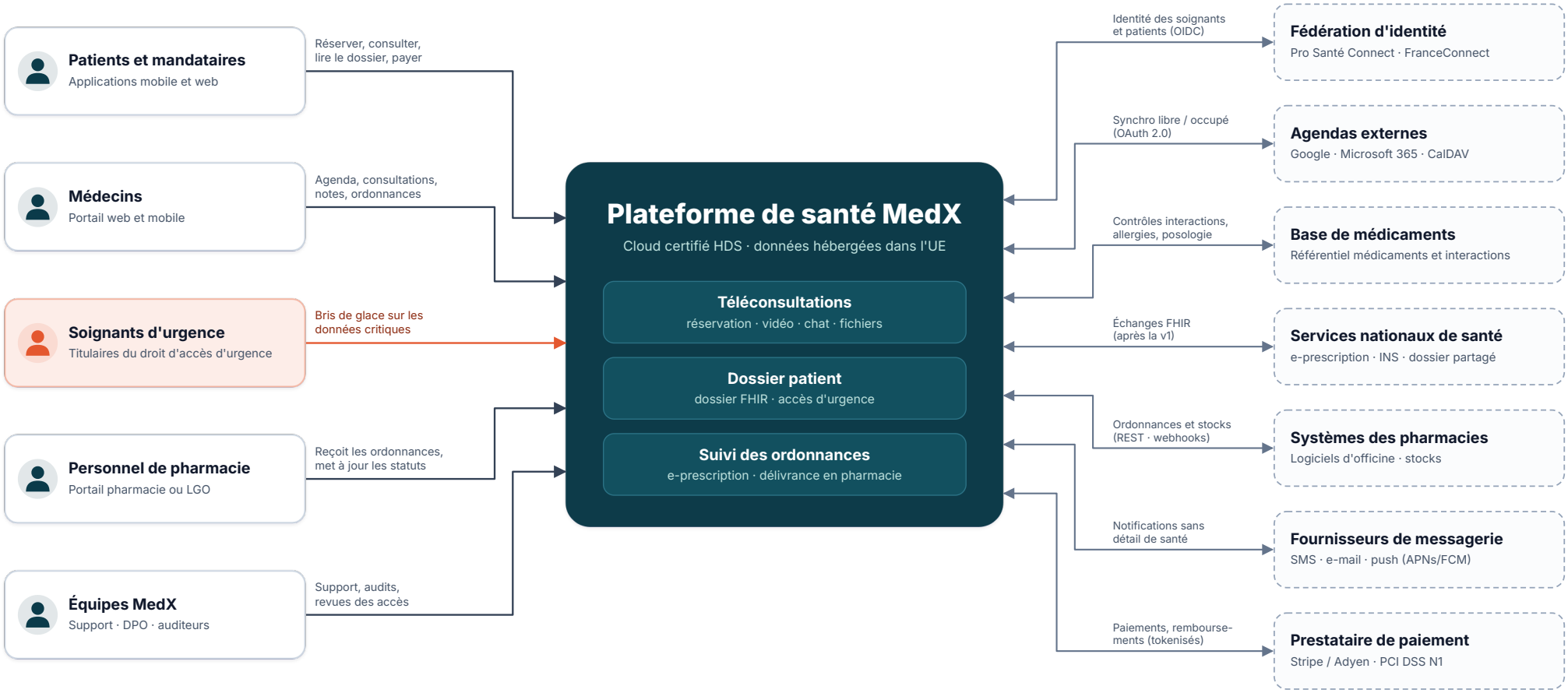
Sept idées à retenir

1. **Huit microservices métier, un par composant de l'Annexe 1**, regroupés en **zones de sécurité**. La *zone clinique* concentre les données de santé et reçoit les contrôles les plus stricts.
2. **Une seule porte d'entrée, durcie.** Seul le périmètre d'entrée (CDN/WAF, passerelle API, passerelle temps réel, plan média) est joignable depuis Internet ; tous les services et toutes les bases sont dans des sous-réseaux privés.
3. **L'identité est centralisée, l'application des règles est locale.** Un fournisseur d'identité éprouvé émet les jetons ; un moteur de politiques (OPA) tourne à côté de chaque service, si bien que chaque requête est autorisée en environ une milliseconde, sans aller-retour réseau.
4. **Les événements d'abord, le synchrone seulement quand un utilisateur attend.** Les changements d'état sont publiés comme événements métier sur Kafka via une outbox transactionnelle : les services restent découplés et les pannes restent contenues.
5. **Chaque service possède ses données** (une base par service). PostgreSQL est le choix par défaut ; des bases spécialisées ne sont utilisées que lorsqu'un besoin clair existe (Redis, Cassandra, stockage objet, OpenSearch).
6. **Les capacités critiques pour la sécurité sont construites une seule fois, comme services de plateforme** : piste d'audit, stockage sécurisé de documents, gestion des clés, observabilité et SIEM, plateforme de données désidentifiées.
7. **L'accès d'urgence est un chemin de niveau 0** : un déploiement isolé qui lit des résumés précalculés sur des répliques situées dans deux régions, et qui ne dépend de rien d'autre que du strict nécessaire.

1.2 Contexte du système (C4 niveau 1)

MedX — Contexte du système

C4 niveau 1 · qui utilise MedX, pour quoi faire, et sur quels systèmes externes la plateforme s'appuie



Cadres pleins : personnes · cadres pointillés : systèmes externes hors de la frontière de confiance de MedX · chaque connexion est chiffrée (TLS 1.3 / mTLS)

Contexte du système MedX

MedX sert cinq groupes de personnes et s'appuie sur sept familles de systèmes externes. Chaque système externe se trouve **hors de la frontière de confiance** : il ne reçoit que les données dont il a besoin (par exemple, les agendas reçoivent des plages occupées et un titre générique « Téléconsultation MedX » — jamais le nom d'un patient ni une spécialité), via des adaptateurs détenus par le service qui les consomme.

1.3 Style d'architecture et justification

Option	Points forts	Faiblesses pour MedX	Verdict
Monolithe	Simple à construire et à déployer	Un seul rayon d'impact pour les données de santé et les paiements ; vidéo, dossiers et facturation ne peuvent pas monter en charge séparément ; un bogue peut faire tomber l'accès d'urgence	Rejeté
Monolithe modulaire	Modules clairs, exploitation simple	Toujours un seul exécutable et une seule base : pas d'isolation du chemin de niveau 0, impossible de séparer les périmètres de conformité (santé, PCI)	Bonne option de démarrage, rejetée à l'échelle visée par MedX
Microservices par contexte délimité (8 services métier + plateforme)	Isolation des données sensibles et des pannes, montée en charge indépendante (vidéo ≠ dossiers ≠ facturation), cycles de mise en production indépendants, responsabilités claires	Complexité d'exploitation, cohérence des données distribuées	**Retenu** — complexité maîtrisée (voir ci-dessous)
Fonctions serverless partout	Aucun serveur à gérer, paiement à l'usage	Démarrages à froid sur le chemin d'urgence, sessions WebSocket/WebRTC longues difficiles, dépendance au fournisseur, périmètre HDS plus difficile à cerner	Utilisées seulement pour de petits traitements d'événements, si utile

Pourquoi ce style sert les priorités

- *Confidentialité des données (H1) et conformité* : les données de santé sont confinées à la zone clinique ; la facturation est dans une zone paiement séparée, ce qui garde son périmètre PCI minimal ; le service de notification ne stocke jamais de données de santé.
- *Accès d'urgence (H3)* : le chemin de bris de glace est déployé à part (cloisonnement) et ne peut pas être privé de ressources par un pic de réservations ou de trafic vidéo.
- *Scalabilité* : le plan média monte en charge selon la bande passante, le dossier patient selon le débit de lecture, les notifications selon la profondeur des files — chacun avec sa propre métrique de mise à l'échelle automatique.

Comment la complexité est maîtrisée

- Le nombre de services est volontairement **limité aux composants métier** (pas de « nano-services »).
- Un **modèle de service standard** (*golden path*) donne à chaque service le même squelette : contrat OpenAPI, point d'autorisation, outbox, sondes de santé, OpenTelemetry, en-têtes de sécurité, chaîne d'intégration continue.
- Un **maillage de services** (*service mesh*) fournit uniformément mTLS, nouvelles tentatives, délais d'expiration et disjoncteurs.
- Une **équipe plateforme** est responsable de Kubernetes, du bus d'événements, de l'observabilité et des briques de sécurité.

1.4 Couches et composants

Couche	Composants	Responsabilité
Canaux	Application mobile patient (iOS/Android), application web patient, portail web médecin, portail pharmacie, console d'administration	Interfaces utilisateur. Aucune logique métier, stockage local minimal des données de santé (chiffré, effacé à la déconnexion).
Périmètre d'entrée	CDN + WAF + protection DDoS · **passerelle API** · **passerelle temps réel** (WebSocket) · **plan média** (SFU WebRTC + TURN/STUN)	Point d'entrée unique : terminaison TLS, validation des jetons, limitation de débit, validation des requêtes, routage, réception des webhooks, diffusion temps réel, relais média.
Identité et accès	① **Gestion des utilisateurs** (+ fournisseur d'identité Keycloak) · **point de décision de politique** (OPA)	Qui vous êtes (authentification, MFA, fédération) et ce que vous pouvez faire (RBAC + ABAC, consentement, relation de soin, obligations de masquage).
Zone clinique	② Planification · ③ Consultation · ④ Dossier patient + **accès d'urgence** · ⑤ Ordonnances · ⑥ Interface pharmacie	Parcours de soins et données de santé.
Zone communication	⑦ Notification	Messages multicanaux sans détail médical, préférences, suivi de distribution et de lecture.
Zone paiement	⑧ Facturation et paiement	Honoraires, pré-autorisation puis encaissement, factures, remboursements, grand livre — les données de carte restent chez le PSP.
Colonne vertébrale événementielle	Apache Kafka + registre de schémas + relais d'outbox (CDC)	Intégration asynchrone, flux d'audit, projections.
Services de plateforme	Piste d'audit · stockage sécurisé de documents · clés et secrets (KMS/HSM, Vault) · observabilité et SIEM · plateforme de données désidentifiées	Capacités partagées et critiques pour la sécurité.
Couche de données	PostgreSQL (une base par service) · Redis · Cassandra · stockage objet · OpenSearch · coffre de sauvegardes	Persistance — voir le document 3.

Les responsabilités, API, événements et flux détaillés de chaque composant sont décrits dans le document 2 — Conception détaillée des composants.

1.5 Zones de sécurité et frontières de confiance

Zone	Contient	Données autorisées	Contrôles principaux
Périmètre d'entrée (public)	CDN/WAF, passerelles, nœuds média	Trafic chiffré en transit uniquement ; aucune base de données	Règles WAF, protection DDoS, TLS 1.3, validation des jetons, limites de débit
Identité et accès	Gestion des utilisateurs, fournisseur d'identité, PDP	Identité, secrets d'authentification (hachés), rôles, préférences	MFA, hachage des mots de passe, accès administrateur juste-à-temps, base séparée
Clinique (données de santé)	Planification, Consultation, Dossier patient, Accès d'urgence, Ordonnances, Interface pharmacie, stockage de documents	Données de santé, chiffrées par patient	Groupe de nœuds dédié, politiques réseau strictes, ABAC à chaque requête, chiffrement au niveau des champs, audit complet
Communication	Notification	Coordonnées, préférences, métadonnées des messages — **aucune donnée de santé**	Modèles relus pour exclure toute donnée de santé, contrats de sous-traitance avec les fournisseurs, consentements

Zone	Contient	Données autorisées	Contrôles principaux
Paiement	Facturation et paiement	Montants, factures, jetons PSP — **aucun numéro de carte, aucun diagnostic**	Espace de noms et politique réseau séparés, champs de paiement hébergés par le PSP, signatures des webhooks
Plateforme	Audit, KMS/Vault, observabilité, plateforme de données	Enregistrements d'audit (accès restreint), clés (jamais exportées), journaux expurgés des données de santé, jeux de données désidentifiés	Compte de sécurité séparé pour l'audit et les journaux, stockage WORM, séparation des tâches
Hors production	Développement, recette, démonstration	**Données synthétiques ou anonymisées uniquement**	Comptes séparés, aucun chemin réseau vers la production

Règles de circulation entre zones

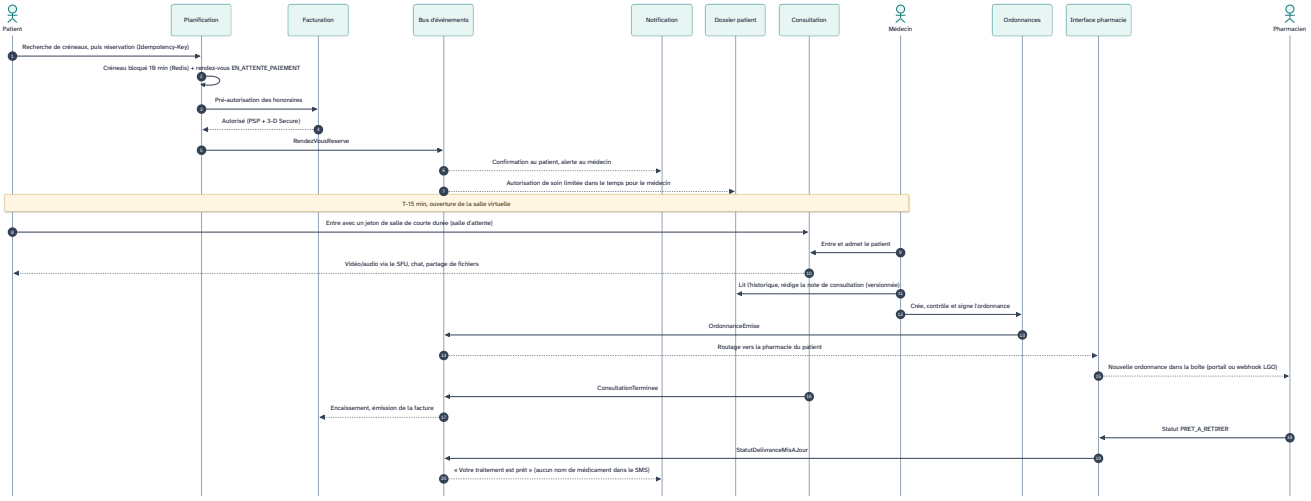
- Les données de santé ne quittent la zone clinique que (a) vers un utilisateur autorisé via la passerelle, (b) vers une pharmacie via l'Interface pharmacie, réduites à ce que la délivrance exige, ou (c) vers la plateforme de données désidentifiées **après** anonymisation.
- Les événements du bus transportent **des identifiants et des statuts, jamais de contenu clinique** (patron *claim-check* : le consommateur récupère le détail auprès du service propriétaire, avec sa propre autorisation).
- Rien dans la zone clinique n'accepte de connexion entrante depuis Internet, sauf via les passerelles.

1.6 Modes de communication

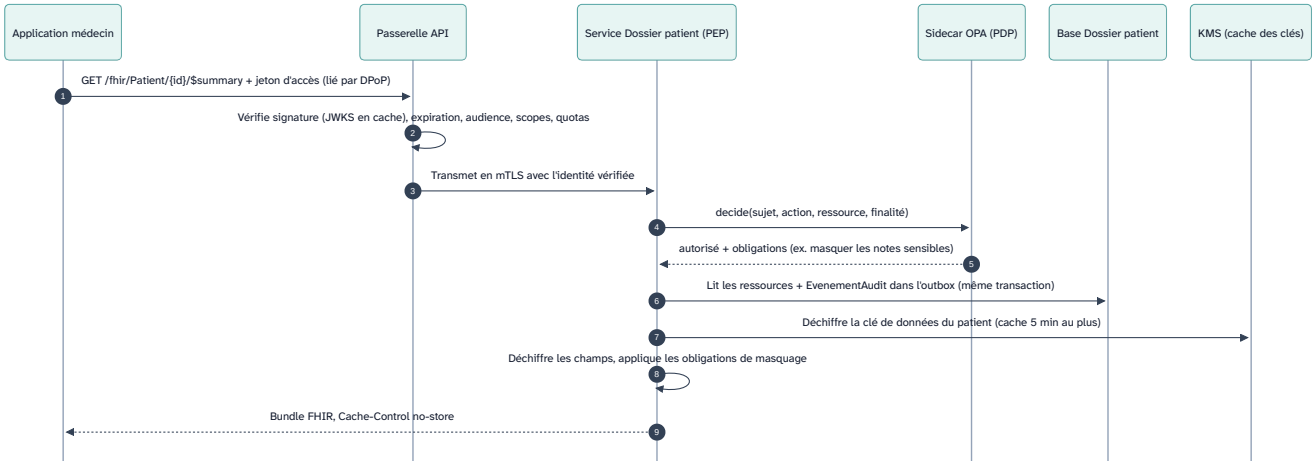
Mode	Utilisé pour	Protocole et format	Règles
Requête/réponse synchrone	Lectures et commandes des utilisateurs ; contrôles qui exigent une réponse immédiate (ex. contrôle des allergies pendant la prescription)	HTTPS/REST, JSON, OpenAPI 3.1 ; **FHIR R4 REST** pour les données cliniques ; appels internes en mTLS	Délai d'expiration sur chaque appel, nouvelles tentatives seulement pour les opérations idempotentes (avec gigue), disjoncteurs, **deux sauts synchrones au plus** par requête utilisateur, `Idempotency-Key` sur chaque création
Événements métier asynchrones	Propagation des changements d'état (réservation, ordonnance, paiement…), notifications, projections, audit	Topics Kafka, enveloppe CloudEvents, schémas versionnés (registre de schémas, rétrocompatibles)	Publiés via **l'outbox transactionnelle** (pas de double écriture) ; livraison au moins une fois + **consommateurs idempotents** ; ordre garanti par clé d'agrégat (ex. `idRendezVous`)
Poussée temps réel	Chat, statuts en direct (ordonnance, position dans la file), notifications dans l'application	WebSocket (WSS) via la passerelle temps réel, adossée à un pub/sub	Authentification à la connexion, canaux par utilisateur, ré-autorisation au renouvellement du jeton
Média	Vidéo et audio	WebRTC : DTLS-SRTP (+ chiffrement de bout en bout SFrame quand c'est possible), ICE/STUN/TURN	Le média ne traverse jamais les services métier ; salles et jetons contrôlés par le service Consultation
Intégration externe	Agendas, PSP, messagerie, logiciels de pharmacie, base médicaments, services nationaux	REST/FHIR en TLS ou mTLS, OAuth 2.0 ; webhooks entrants via la passerelle API	Un **adaptateur (couche anti-corruption)** par système externe, détenu par le service consommateur ; webhooks signés ; nouvelles tentatives avec temporisation ; files de lettres mortes

1.7 Flux de bout en bout clés

1.7.1 Le parcours de soin : réservation → consultation → ordonnance → pharmacie



1.7.2 Comment chaque requête sur des données de santé est autorisée



Deux propriétés comptent ici : **aucun accès sans enregistrement d'audit** (l'événement d'audit est écrit dans la même transaction que la lecture ou l'écriture), et **aucun aller-retour réseau pour la décision d'autorisation** (OPA tourne en *sidecar*, avec des politiques distribuées sous forme de paquets signés).

1.7.3 Accès d'urgence (bris de glace)

Accès d'urgence (bris de glace)

Exigence de priorité haute H3 · accès immédiat aux données critiques pour les professionnels habilités, avec une traçabilité complète a posteriori

1 Identifier le patient

Recherche exacte uniquement : INS / identifiant MedX, ou nom + date de naissance + sexe
Identité minimale pour confirmer le patient
Ni navigation, ni jokers

2 Déclarer l'urgence

Code motif (inconscient, pronostic vital engagé, consentement impossible…)
Justification en texte libre
Engagement de responsabilité « Je serai audité »

3 MFA renforcée

Passkey ou carte (e-CPS) dans les 15 dernières minutes
Le moteur de politiques vérifie le droit acces_urgence et l'opposition du patient

4 Autorisation limitée

4 heures · lecture seule
Ce patient uniquement
Autorisation + audit écrits dans la même transaction
Renouvelable avec un nouveau motif

5 Synthèse en < 1 s

Résumé patient (IPS) : allergies, problèmes actifs, traitements, groupe sanguin, implants, directives anticipées, contacts
Dossier complet : même accès

Soignant : ≈ 30 secondes de la recherche aux données (étapes humaines) · Système : p95 < 300 ms par appel d'API · Disponibilité 99,99 %

GARDE-FOUS — RESPONSABILITÉ A POSTERIORI (l'accès n'est jamais bloqué, il est toujours justifié)

Audit immuable

AuditEvent, finalité = traitement d'urgence, conservé dans la piste WORM

Alerte en temps réel

Le DPO est alerté via le SIEM dès le début de l'accès

Patient informé

Avis in-app + e-mail sous 24 h : qui, quand, ce qui a été consulté

Revue obligatoire

DPO + responsable médical revoient chaque cas sous 72 h

Détection des abus

L'analyse comportementale repère les anomalies ; sanctions et suspension

RÉSILIENCE — POURQUOI LE CHEMIN DE NIVEAU 0 FONCTIONNE QUAND D'AUTRES SERVICES SONT DÉGRADÉS

Déploiement isolé

cloisonné, capacité réservée

Synthèse pré-calculée

projection, sans jointure

Répliques multi-AZ

+ région de secours active

Jetons validés en local

clés de l'IdP en cache

Décisions locales

sidecar OPA, paquets en cache

Audit via l'outbox

sans dépendre de la chaîne d'audit

Qui peut briser la glace ?

Praticiens vérifiés titulaires du droit acces_urgence (médecine d'urgence, gardes, SAMU), accordé par le responsable médical de MedX et revu chaque trimestre. Les patients peuvent s'y opposer lorsque la loi le permet.

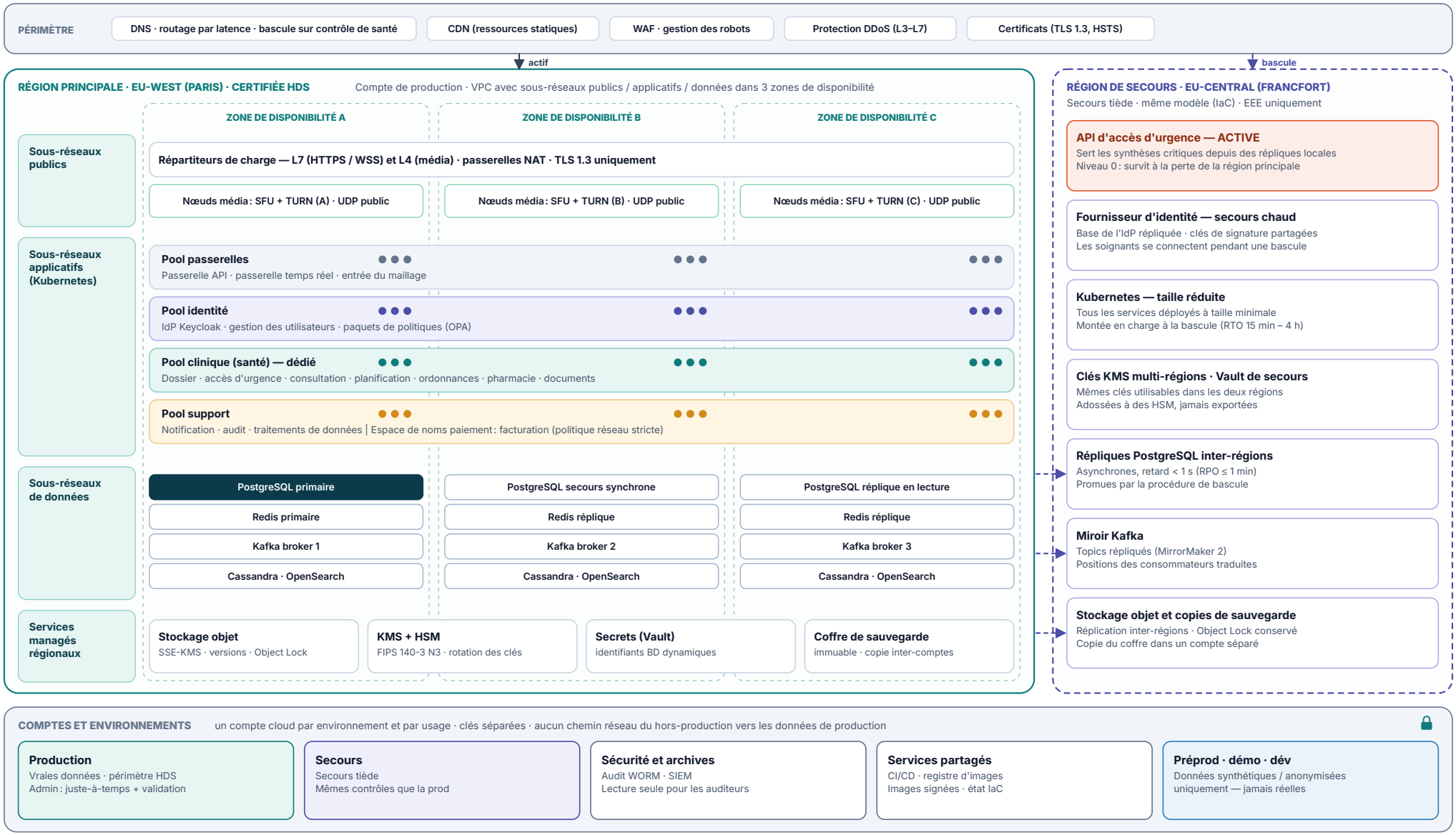
Flux d'accès d'urgence

La conception détaillée (droit d'accès, modèle d'autorisation, contenu du résumé critique, processus de revue) est dans le document 2.4 — Dossier patient et accès d'urgence.

1.8 Vue de déploiement

MedX — Déploiement et zones de sécurité

Implémentation de référence sur un cloud public certifié HDS · région principale multi-AZ · région de secours tiède · comptes isolés



Vue de déploiement MedX

- **Région principale** en France (certifiée HDS), répartie sur **trois zones de disponibilité**. Chaque couche est redondée entre zones : répartiteurs de charge, groupes de nœuds Kubernetes, base principale + **réplique synchrone**
    - réplique de lecture, répliques Redis, trois brokers Kafka, nœuds Cassandra et OpenSearch.
- Les **groupes de nœuds Kubernetes** suivent les zones de sécurité : passerelles, identité, **clinique (nœuds dédiés)** et support, plus un **espace de noms paiement** isolé par politique réseau. Les nœuds média sont dans des sous-réseaux publics car WebRTC a besoin de ports UDP publics ; ils ne détiennent aucune donnée.
- La **région de reprise** (deuxième région européenne, EEE uniquement) est un **secours tiède** construit à partir du même code d'infrastructure : répliques de bases (retard < 1 s), miroir Kafka, stockage objet répliqué, clés KMS multirégions. **L'API d'accès d'urgence et le fournisseur d'identité sont actifs dans les deux régions** : le chemin de niveau 0 survit à la perte de la région principale.
- **Un compte cloud par environnement et par usage** : production, reprise, sécurité et archives de journaux (audit WORM, SIEM), services partagés (CI/CD, images signées), hors production (données synthétiques uniquement).

1.9 Pile technologique (implémentation de référence)

La conception est indépendante du fournisseur cloud ; les choix ci-dessous constituent l'implémentation de référence utilisée pour le dimensionnement et le chiffrage.

Sujet	Choix de référence	Pourquoi	Alternatives
Hébergement	Cloud public certifié HDS — principal à Paris, reprise à Francfort	Périmètre certifié, services managés, résidence des données dans l'UE	Azure France, Google Cloud Paris, OVHcloud
Calcul	Kubernetes managé + maillage de services Istio	Mise à l'échelle standard, mTLS uniforme, politiques de trafic	Linkerd ; Nomad
Services métier	Java/Kotlin sur un JDK LTS récent, Spring Boot	Écosystème mature, bibliothèques santé solides (HAPI FHIR), vivier de recrutement	Go, .NET
Données cliniques	Serveur **HAPI FHIR** sur PostgreSQL	Open source, validation FHIR R4, versionnage, recherche	Services FHIR managés (Azure Health Data Services, Google Cloud Healthcare API, AWS HealthLake)
Identité	**Keycloak** (OIDC, MFA, WebAuthn/passkeys, fédération d'identité)	Auto-hébergeable dans le périmètre HDS, fondé sur les standards, pas de coût par utilisateur	Fournisseurs d'identité commerciaux si leur hébergement est conforme HDS
Autorisations	**Open Policy Agent** (politiques en tant que code, sidecar)	Décisions locales à faible latence, politiques testables et versionnées	AWS Cedar, OpenFGA
Vidéo	SFU **LiveKit** (open source) + serveurs TURN	Auto-hébergement dans l'UE, simulcast, chiffrement de bout en bout, mise à l'échelle horizontale	Jitsi, mediasoup ; CPaaS (Vonage, Daily) si le délai de mise sur le marché prime
Événements	**Apache Kafka** (managé) + registre de schémas + relais d'outbox Debezium	Journal durable et rejouable, ordre par clé, débit élevé	RabbitMQ, NATS JetStream, Pulsar
Bases de données	PostgreSQL (managé, multi-AZ), Redis/Valkey, Cassandra, OpenSearch, stockage objet compatible S3	Chacune justifiée composant par composant — voir le document 3	—
Clés et secrets	KMS cloud adossé à des HSM (FIPS 140-3) + HashiCorp Vault	Clés protégées matériellement, rotation, secrets dynamiques	Gestionnaire de secrets natif du cloud
Observabilité	OpenTelemetry → Prometheus / Grafana / Loki / Tempo ; SIEM	Standards ouverts, un identifiant de corrélation de bout en bout	Datadog, Elastic (selon l'hébergement)

Sujet	Choix de référence	Pourquoi	Alternatives
Livraison	Chaînes CI, Argo CD (GitOps), Terraform, signature des images (cosign), analyse (Trivy)	Chaque modification est revue, reproductible et traçable	Flux, Pulumi
Interfaces	React + TypeScript (web), React Native (mobile)	Compétences et composants partagés entre applications patient, médecin et pharmacie	Swift/Kotlin natifs

1.10 Comment l'architecture sert les priorités de MedX

Priorité	Réponse de l'architecture	Détails
H1 Confidentialité des données	TLS 1.3 / mTLS sur chaque saut ; chiffrement AES-256 du stockage + chiffrement d'enveloppe par patient ; données de santé confinées à la zone clinique	§5.5–5.6
H2 Dossiers patients	Service Dossier patient dédié fondé sur FHIR, historique en ajout seul, registre des consentements, audit complet	§2.4
H3 Accès d'urgence	Bris de glace sur un chemin de niveau 0 isolé et présent dans deux régions ; revue a posteriori	§2.4
H4 Authentification / autorisations	Keycloak (OIDC, MFA, passkeys) + OPA (RBAC + ABAC) évalué à côté de chaque service	§2.1
H5 Intégrité des données et fichiers sécurisés	Bases ACID, versionnage, chaînes de hachage, sommes de contrôle, Object Lock, sauvegardes immuables, stockage de documents analysé et chiffré	§3.8
Moyenne M1–M5	Services Planification, Consultation, Ordonnances ; obligations de masquage dans le PDP ; adaptateurs d'agendas	§2.2, §2.3, §2.5
Basse B1–B6	Services Pharmacie, Notification, Facturation ; chaîne d'anonymisation — conçus maintenant, livrés en dernier	§8 Feuille de route

La correspondance exigence par exigence figure dans la matrice de traçabilité.

2. Conception détaillée des composants

Livrable 2. Fonctionnalités, interfaces et interactions de chaque composant de MedX. Vue d'ensemble de l'architecture : document 1 — Architecture de haut niveau.

Mode de lecture

Chacun des huit composants métier de l'Annexe 1 a son propre document, avec la même structure : **mission et priorité → responsabilités (reliées à l'Annexe 1) → conception interne → flux clés → API → événements → données détenues → sécurité → scalabilité et résilience → décisions de conception et compromis.**

#	Composant	Priorité (Annexe 2)	Zone	Niveau	Document
①	Gestion des utilisateurs (identité et accès)	**Haute** (H4) · Basse (B2 préférences)	Identité et accès	0	01-gestion-utilisateurs.md
②	Planification des téléconsultations	Moyenne (M1, M5)	Clinique	1	02-planification.md
③	Consultation (vidéo, chat, fichiers)	Moyenne (M2)	Clinique + plan média	1	03-consultation.md
④	Dossier patient + accès d'urgence	**Haute** (H2, H3, H5) · Moyenne (M4)	Clinique	0 / 1	04-dossier-patient.md
⑤	Gestion des ordonnances	Moyenne (M3)	Clinique	1	05-ordonnances.md
⑥	Interface pharmacie	Basse (B1)	Clinique (données minimisées)	2	06-interface-pharmacie.md
⑦	Notification	Basse (B2, B3)	Communication	2	07-notification.md
⑧	Facturation et paiement	Basse (B5, B6)	Paiement	2	08-facturation-paiement.md
—	Composants de plateforme (passerelles, moteur de politiques, bus d'événements, stockage de documents, audit, clés, observabilité, plateforme de données)	**Haute** (H1, H4, H5) · Basse (B4)	Périmètre d'entrée / plateforme	0–2	09-composants-plateforme.md

Modèle de service commun

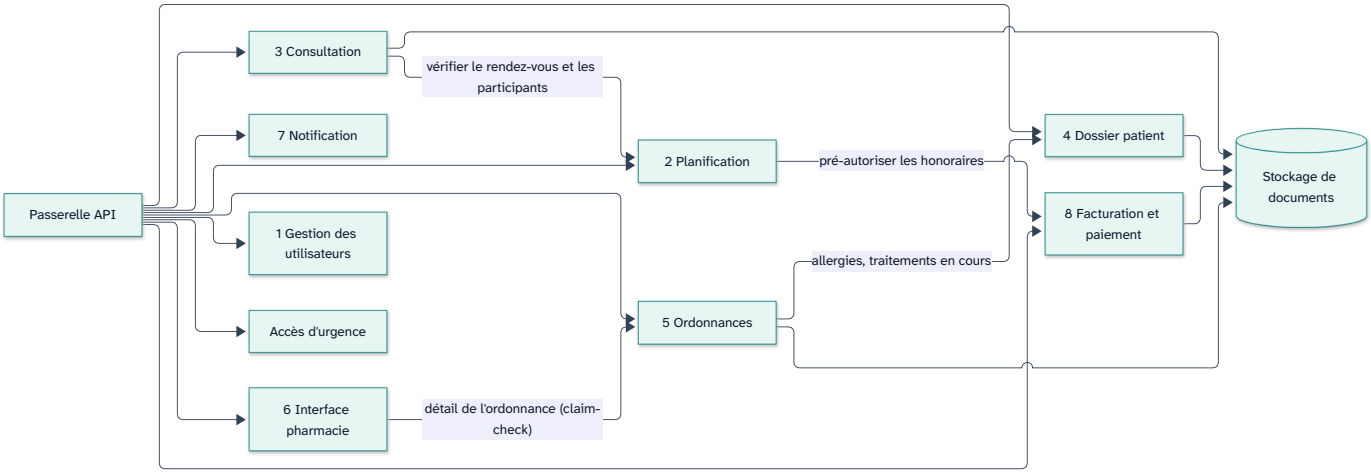
Chaque service est généré à partir du même **modèle standard** (*golden path*) : la sécurité et l'exploitabilité ne dépendent donc pas de la mémoire de chaque équipe.

Sujet	Règle appliquée à chaque service
Contrat d'API	OpenAPI 3.1 (CapabilityStatement FHIR pour le service Dossier patient), version dans l'URI (`/v1`), ajouts seulement au sein d'une version, pagination par curseur, erreurs au format `application/problem+json` (RFC 9457), `Idempotency-Key` obligatoire sur chaque `POST` qui crée quelque chose.
Authentification	Jeton JWT revalidé dans le service (défense en profondeur, même derrière la passerelle) ; identité de service à service via le mTLS du maillage (identités SPIFFE).
Autorisation	Un point d'application de la politique (PEP) dans le service interroge le sidecar OPA local avec `sujet · action · ressource · finalité` ; refus par défaut ; obligations (masquage) appliquées avant que la réponse ne sorte.
Données	Base/schéma et identifiants privés (délivrés par Vault, durée de vie 1 h) ; migrations relues (Flyway) ; identifiants **UUIDv7** (ordonnés dans le temps, jamais d'entiers séquentiels exposés aux clients) ; table `outbox` pour les événements.
Événements	Enveloppe CloudEvents, schéma dans le registre, publication via le relais d'outbox ; consommateurs idempotents (table des événements traités), topic de lettres mortes après 5 tentatives.

Sujet	Règle appliquée à chaque service
Résilience	≥ 3 répliques réparties sur 3 AZ (niveaux `0` et `1`), sondes de disponibilité et de vie, arrêt propre, budgets d'interruption de pods, délais d'expiration + nouvelles tentatives avec gigue + disjoncteurs (maillage), cloisonnement des chemins critiques.
Observabilité	Traces OpenTelemetry (`traceparent` W3C propagé aussi dans les en-têtes Kafka), métriques RED, journaux JSON structurés **sans donnée de santé** (champs en liste blanche, identifiants tokenisés), tableau de bord et alertes SLO.
Livraison	CI : tests unitaires, de contrat (pilotés par le consommateur) et d'intégration, SAST, analyse des dépendances et des conteneurs, images signées ; CD : GitOps, déploiement canari via le maillage avec retour arrière automatique.

Dépendances synchrones

Les appels synchrones sont limités aux cas où un utilisateur attend une réponse. Le graphe est acyclique et ne dépasse jamais deux sauts ; tout le reste passe par des événements.



Appelant → appelé	Pourquoi en synchrone	Gestion des pannes
Planification → Facturation	Le patient attend la confirmation de réservation, qui dépend de l'autorisation de paiement	Délai de 5 s, créneau bloqué 10 min pour permettre au patient de réessayer ; aucune nouvelle tentative sans clé d'idempotence
Consultation → Planification	Les jetons de salle ne sont délivrés qu'aux participants du rendez-vous, dans sa fenêtre horaire	Réplique locale des rendez-vous du jour (construite à partir des événements) utilisée si la Planification est indisponible
Ordonnances → Dossier patient	Les contrôles d'allergies et d'interactions ont besoin des listes à jour d'allergies et de traitements	En cas d'échec, le médecin voit « contrôle de sécurité indisponible » et doit le reconnaître explicitement avant de signer
Interface pharmacie → Ordonnances	Les pharmacies ne récupèrent le détail de l'ordonnance qu'à l'ouverture (les événements ne portent que des identifiants)	Nouvelles tentatives avec temporisation ; le portail affiche l'ordonnance « en chargement »
Services → stockage de documents	Dépôt / téléchargement de fichiers	Dépôts reprenables ; téléchargements réessayés

Catalogue des événements

Nommage des topics : `<domaine>.<agrégat>.v<majeure>`. Clé de partition = identifiant de l'agrégat (préserve l'ordre par agrégat). Les événements portent **des identifiants, des statuts et des horodatages — jamais de contenu clinique** ; les consommateurs récupèrent le détail auprès du service propriétaire, sous leur propre autorisation (*claim-check*).

Topic	Événements	Producteur	Principaux consommateurs
`identite.utilisateur.v1`	UtilisateurInscrit, ProfilMisAJour, PraticienVerifie, PraticienSuspendu, UtilisateurDesactive, RoleAttribue, DelegationAccordee/Revoquee	① Gestion des utilisateurs	② (activer/geler les agendas), ④ (créer le dossier et les clés, révoquer les autorisations), ⑦, ⑧
`identite.preferences.v1`	PreferencesMisesAJour	①	⑦
`planification.rendez-vous.v1`	RendezVousReserve, RendezVousDeplace, RendezVousAnnule, PatientAbsent, RappelRendezVousDu, CreneauProposeListeAttente, DemandeUrgenteCreee/Attribuee	②	③ (préparer les salles), ④ (autorisations de soin), ⑦, ⑧ (annulation / remboursement)
`consultation.seance.v1`	ConsultationOuverte, ConsultationDemarree, ConsultationTerminee, ConsultationEchouee, TranscriptionChatPrete	③	② (terminé / absent), ④ (rencontre, archivage de la transcription), ⑧ (encaissement ou remboursement), ⑦
`dossier.patient.v1`	DossierMisAJour, DocumentAjoute, ResultatPublie, ConsentementModifie	④	projections de ④ (résumé critique, chronologie), ⑦ (« nouveau document disponible »)
`dossier.urgence.v1`	BrisDeGlaceAccorde, RevueBrisDeGlaceAttendue, BrisDeGlaceRevu	④	Audit/SIEM (alerte en temps réel), ⑦ (délégué à la protection des données, information du patient)
`ordonnance.v1`	OrdonnanceEmise, OrdonnanceModifiee, OrdonnanceRevoquee, OrdonnanceExpiree, PharmacieAttribuee, StatutDelivranceModifie	⑤	⑥, ④ (liste des traitements), ⑦, ⑧ (commandes de médicaments)
`pharmacie.delivrance.v1`	ReceptionAccusee, StatutDelivranceMisAJour, DelivranceImpossible, MessagePharmaciePublie	⑥	⑤ (statut de référence), ⑦
`notification.distribution.v1`	NotificationEnvoyee, NotificationDistribuee, NotificationLue, NotificationEchouee, CoordonneeInvalide	⑦	① (coordonnée invalide), analytique
`facturation.paiement.v1`	PaiementAutorise, PaiementEchoue, PaiementEncaisse, PaiementAnnule, RemboursementEffectue, RemboursementEchoue, FactureEmise	⑧	② (saga de réservation), ⑦ (reçus), ⑥ (commandes payées)
`audit.evenements.v1`	EvenementAudit (un par accès ou modification d'une donnée personnelle)	chaque service, via son outbox	Piste d'audit, SIEM

Exemple d'événement (ni nom de médicament ni diagnostic — seulement ce dont un consommateur a besoin pour décider s'il doit récupérer davantage d'informations) :

```
{
  "specversion": "1.0",
  "id": "01929e8c-6f1a-7c2b-9d3e-5a4b3c2d1e0f",
  "source": "medx/service-ordonnances",
  "type": "medx.ordonnance.emise.v1",
  "subject": "ordonnance/01929e8c-51aa-7d10-8f00-1b2c3d4e5f60",
  "time": "2026-03-02T10:15:30Z",
  "datacontenttype": "application/json",
  "traceparent": "00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01",
  "data": {
    "idOrdonnance": "01929e8c-51aa-7d10-8f00-1b2c3d4e5f60",
    "version": 1,
    "idPatient": "01927f3a-0c55-7e21-a9f4-6d7e8f9a0b1c",
    "idPrescripteur": "01920b11-7a2e-7c3d-8e4f-5a6b7c8d9e0f",
    "idPharmacie": "01925d22-3b4c-7d5e-8f6a-7b8c9d0e1f2a",
    "valableJusquAu": "2026-06-02"
  }
}
```


Synthèse des interactions

Composant	Appelle (synchrone)	Publie	Consomme
① Gestion des utilisateurs	Fournisseur d'identité (intégré), fédération d'identité	`identite.*`	`notification.distribution.v1` (coordonnées invalides)
② Planification	Facturation, fournisseurs d'agendas	`planification.rendez-vous.v1`	`identite.utilisateur.v1`, `consultation.seance.v1`, `facturation.paiement.v1`
③ Consultation	Planification, stockage de documents, API du SFU	`consultation.seance.v1`	`planification.rendez-vous.v1`
④ Dossier patient	Stockage de documents, KMS	`dossier.*`	`identite.utilisateur.v1`, `planification.rendez-vous.v1`, `consultation.seance.v1`, `ordonnance.v1`
⑤ Ordonnances	Dossier patient, base médicaments, stockage de documents, signature HSM	`ordonnance.v1`	`pharmacie.delivrance.v1`, `identite.utilisateur.v1`
⑥ Interface pharmacie	Ordonnances, logiciels de pharmacie	`pharmacie.delivrance.v1`	`ordonnance.v1`
⑦ Notification	Fournisseurs de messagerie	`notification.distribution.v1`	presque tous les topics
⑧ Facturation et paiement	PSP, stockage de documents	`facturation.paiement.v1`	`planification.rendez-vous.v1`, `consultation.seance.v1`, `ordonnance.v1`

2.1 ① Service de gestion des utilisateurs — identité et accès

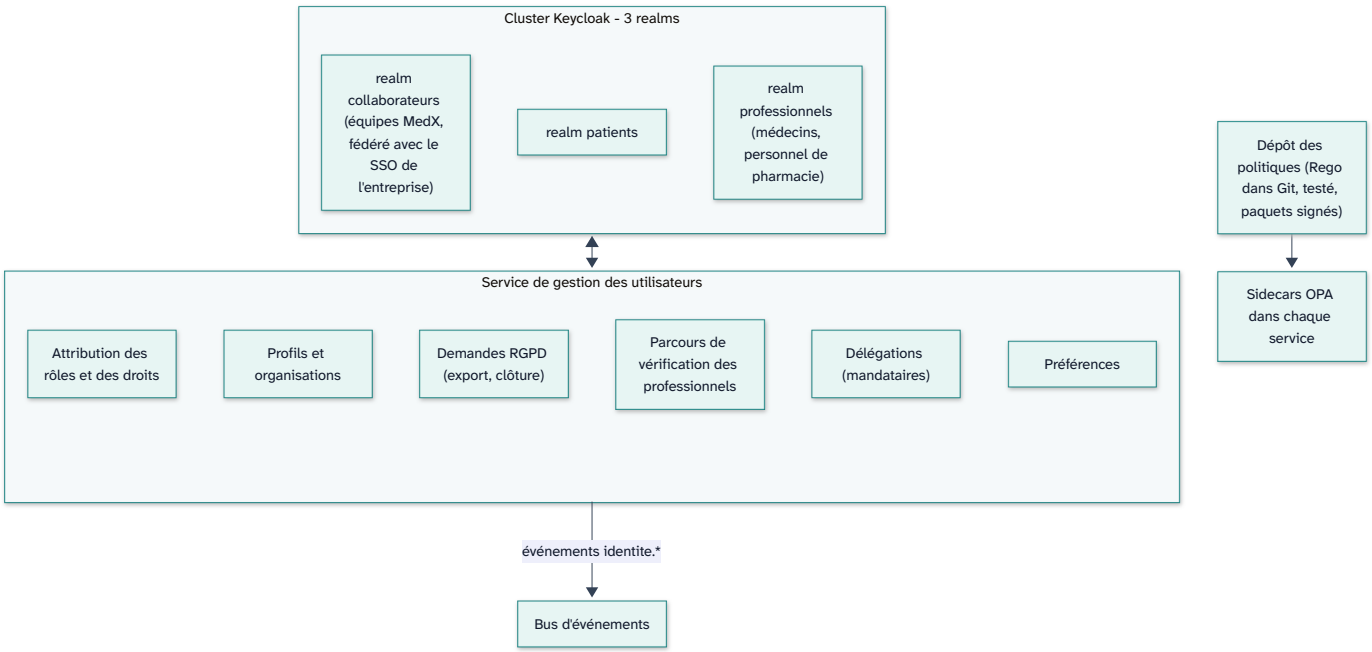
Priorité	Zone	Criticité	Détient
Haute — H4 authentification et autorisations · Basse — B2 préférences des utilisateurs	Identité et accès	Niveau 0 (connexion, validation des jetons)	Identités, profils, rôles, organisations, délégations, préférences

Mission — savoir qui est chaque utilisateur, le prouver de manière forte, et donner à tous les autres services une base fiable pour décider de ce que cet utilisateur a le droit de faire.

Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Gérer les inscriptions et les mises à jour de profil	Les **patients** s'inscrivent eux-mêmes (vérification de l'e-mail et du téléphone). L'accès à leur dossier médical exige une identité vérifiée (FranceConnect ou contrôle de pièce d'identité). Les **médecins** suivent un parcours d'intégration professionnel : numéro vérifié dans le répertoire national (RPPS / Annuaire Santé), pièce d'identité, validation manuelle. Les **pharmacies** s'inscrivent comme organisations (numéro FINESS vérifié) ; l'administrateur de la pharmacie invite son personnel.
Authentifier les utilisateurs	Fournisseur d'identité **Keycloak** : OpenID Connect Authorization Code + PKCE, **MFA obligatoire pour tous les professionnels** (passkeys/WebAuthn, TOTP, ou carte professionnelle via Pro Santé Connect), MFA selon le risque pour les patients, authentification renforcée pour les actions sensibles.
Autoriser l'accès selon les rôles	Rôles **RBAC** grossiers portés par les jetons + décisions **ABAC** fines prises par le moteur de politiques (OPA) à côté de chaque service : relation de soin, consentement, finalité, sensibilité de la donnée, organisation.
Stocker et gérer les préférences	API de préférences (langue, fuseau horaire, accessibilité, canaux de notification par catégorie, heures de silence, plafonds de fréquence). Chaque modification est publiée (`PreferencesMisesAJour`) : le service de notification l'applique sans devoir rappeler ce service.

Conception interne



- **Trois *realms*** (espaces d'identité Keycloak) isolent des populations aux risques différents : les règles « patients » privilégient la facilité d'usage (passkeys, biométrie sur mobile), les règles « professionnels » sont strictes (MFA systématique, déconnexion après 15 minutes d'inactivité, session de 12 heures au plus), et les identités des collaborateurs viennent de l'annuaire de l'entreprise, avec des clés de sécurité matérielles.
- **Les politiques sont du code** : fichiers Rego dans Git, testés unitairement en CI (`opa test`), empaquetés en **paquets signés** que les sidecars OPA récupèrent. Une modification de politique est relue comme n'importe quel code et reste entièrement traçable.
- Le service conserve les **attributs** (rôles, appartenance à une organisation, droits comme `acces_urgence`) et les expose dans les jetons ; les faits qui changent à chaque requête (autorisations de soin, consentements) sont lus par le service appelant et transmis à OPA en entrée.

Rôles et permissions (couche RBAC)

Capacité	Patient	Mandataire	Médecin	Médecin + `acces_urgence`	Pharmacien / préparateur	Agent de support	DPO	Admin plateforme
Gérer son profil et ses préférences	✅	✅ (délégué)	✅	✅	✅	—	—	—
Prendre / annuler des consultations	les siennes	celles de la personne représentée	—	—	—	assistance, sans donnée de santé	—	—
Gérer ses disponibilités et son agenda	—	—	le sien	le sien	—	—	—	—
Lire un dossier médical	le sien (selon les règles de publication)	périmètre délégué	**avec autorisation de soin**	+ **bris de glace**	❌	❌	métadonnées d'audit seulement	❌
Rédiger des notes cliniques	déposer ses propres documents	—	avec autorisation de soin	note d'urgence	❌	❌	❌	❌
Créer / modifier / révoquer des ordonnances	—	—	pour ses patients	—	❌	❌	❌	❌
Consulter des ordonnances	les siennes	celles de la personne représentée	celles qu'il a émises	via bris de glace	**uniquement celles attribuées à sa pharmacie** (minimisées)	❌	❌	❌
Mettre à jour le statut de délivrance	—	—	—	—	✅	❌	❌	❌
Effectuer des remboursements	demander	demander	—	—	—	≤ seuil (double validation au-delà)	—	❌
Consulter la piste d'audit	l'historique des accès à son dossier	—	—	—	—	❌	✅	❌

Capacité	Patient	Mandataire	Médecin	Médecin + `acces_urgence`	Pharmacien / préparateur	Agent de support	DPO	Admin plateforme
Exploiter l'infrastructure	—	—	—	—	—	—	—	juste-à-temps, limité dans le temps, **sans donnée de santé**

Couche ABAC (politique illustrative)

Le RBAC répond à « un médecin peut-il lire des dossiers ? » ; l'ABAC répond à « **ce** médecin peut-il lire le dossier de **ce** patient **maintenant**, pour **cette** finalité ? ».

```
package medx.dossier

import rego.v1

default allow := false

# Médecin traitant : vérifié, authentifié par MFA, titulaire d'une autorisation de soin non
expirée pour ce patient
allow if {
    input.sujet.role == "medecin"
    input.sujet.verifie
    input.sujet.niveau_authentification >= 2
    input.faits.autorisation_soin.expire_le > input.maintenant
    not sensible_sans_consentement
}

# Bris de glace : lecture seule, limité dans le temps, jamais si le patient s'y est légalement
opposé
allow if {
    "acces_urgence" in input.sujet.droits
    input.finalite == "ETREAT"
    input.action == "lire"
    input.faits.autorisation_urgence.expire_le > input.maintenant
    not input.faits.opposition_bris_de_glace
}

sensible_sans_consentement if {
    input.ressource.label_securite == "restreint"
    not input.faits.consentement_explicite
}

# Obligations renvoyées avec la décision et appliquées par le service avant de répondre
obligations contains {"masquer": "notes-psychotherapie"} if input.finalite == "ETREAT"
```

Parcours d'authentification

Public	Parcours	Facteurs	Session et jetons
Application mobile patient	OIDC Authorization Code + PKCE via le navigateur du système	Mot de passe ou passkey ; second facteur selon le risque (nouvel appareil, téléchargement du dossier) ; déverrouillage biométrique du jeton de rafraîchissement stocké	Jeton d'accès de 10 min, **lié par DPoP** (RFC 9449) ; jeton de rafraîchissement renouvelé à chaque usage, fenêtre glissante de 30 jours, lié à l'appareil
Application web patient	Idem, client confidentiel via un petit backend dédié (*BFF*) qui conserve les jetons côté serveur	Idem	Cookies HttpOnly, Secure, SameSite ; aucun jeton dans le stockage du navigateur
Portails médecin / pharmacie	OIDC Authorization Code + PKCE	**MFA obligatoire** : passkey/WebAuthn, TOTP ou carte professionnelle (e-CPS via Pro Santé Connect) ; OTP par SMS interdit (risque de détournement de SIM)	Jeton d'accès de 5 min, déconnexion après 15 min d'inactivité, 12 h au plus ; authentification renforcée (`max_age` / `acr`) avant de signer une ordonnance ou de briser la glace
Logiciels de pharmacie (LGO)	OAuth 2.0 *client credentials*	**Certificat client mTLS**, jetons liés au certificat (RFC 8705)	Jeton de 5 min, scopes et limites de débit par pharmacie
Collaborateurs MedX	SSO avec l'annuaire de l'entreprise	Clé matérielle FIDO2	Rôles à privilèges uniquement via une élévation juste-à-temps (approbation, durée limitée, session enregistrée)

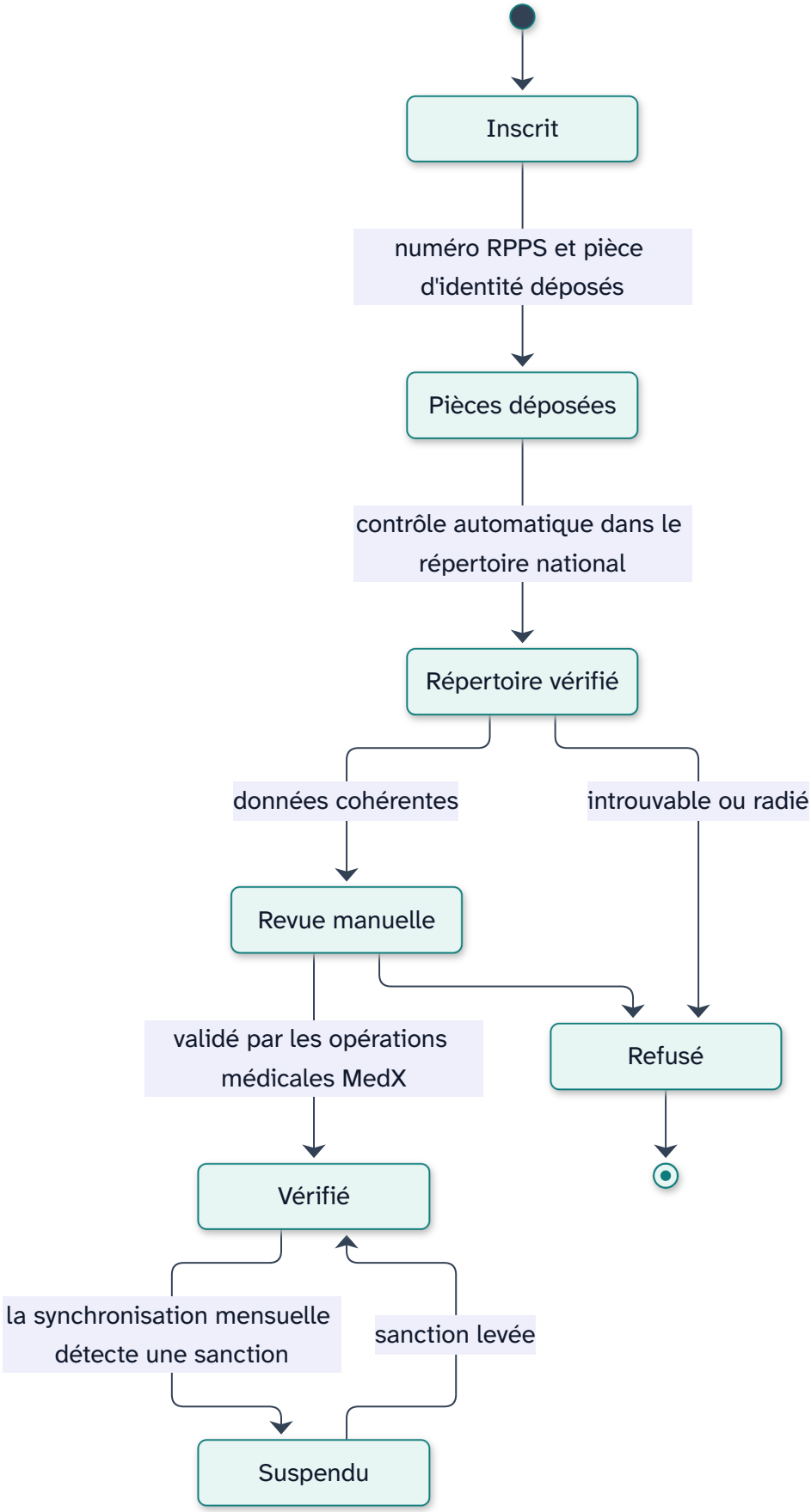
Contenu des jetons — les jetons d'accès sont des JWT signés en ES256 (clés renouvelées, publiées sur le point JWKS) qui contiennent un identifiant de sujet opaque (UUID), le realm, les rôles, l'organisation, les droits, le niveau d'authentification (`acr` / `amr`) et l'audience. Ils **ne contiennent jamais de donnée personnelle** (ni nom, ni e-mail, ni date de naissance).

Révocation — la déconnexion, la réinitialisation du mot de passe et la suspension d'un compte révoquent immédiatement toute la famille de jetons de rafraîchissement ; la courte durée de vie des jetons d'accès borne l'exposition restante, et une liste de refus dans Redis (vérifiée par la passerelle) coupe les comptes suspendus en quelques secondes.

Protection des comptes — mots de passe hachés avec Argon2id (PBKDF2-SHA512 en mode FIPS), 12 caractères minimum, vérification contre les mots de passe compromis, pas de renouvellement périodique forcé (NIST SP 800-63B) ; limitation progressive du débit et verrouillage ; détection des robots à l'inscription et à la connexion ; alerte lors d'une connexion depuis un nouvel appareil ; récupération de compte qui ne dégrade jamais le niveau d'assurance (un professionnel qui perd un facteur repasse par la vérification d'identité).

Flux clés

Intégration d'un professionnel



Accès par mandataire (délégation) — un parent est rattaché à un mineur après vérification des justificatifs (le lien expire à la majorité ; les soins que le mineur a demandé de garder confidentiels sont masqués au parent par la politique) ; un patient adulte peut déléguer des droits précis (prendre rendez-vous, voir ses ordonnances, voir son dossier) à un aidant, et les retirer à tout moment.

API (sélection)

Méthode	Point d'accès	Rôle
`POST`	`/v1/utilisateurs`	Inscription d'un patient
`POST`	`/v1/inscriptions-praticiens`	Démarrer l'intégration d'un professionnel
`GET` / `PATCH`	`/v1/utilisateurs/moi`	Lire / modifier son profil
`GET` / `PUT`	`/v1/utilisateurs/moi/preferences`	Lire / remplacer ses préférences (versionnées, `If-Match`)
`POST` / `DELETE`	`/v1/utilisateurs/moi/delegations`	Accorder / retirer un accès de mandataire
`POST`	`/v1/organisations/{idOrganisation}/membres`	L'administrateur de la pharmacie invite son personnel
`POST`	`/v1/admin/inscriptions-praticiens/{id}/decision`	Valider / refuser (console d'administration, double validation)
`POST`	`/v1/utilisateurs/moi/demandes-rgpd`	Demande d'accès ou de portabilité, clôture du compte
—	`/realms/{realm}/protocol/openid-connect/*`	Points d'accès OIDC standard (authorize, token, JWKS, logout)

Données détenues

PostgreSQL (base `gestion_utilisateurs`) + la base PostgreSQL propre à Keycloak — détail au §3.4. Les coordonnées (téléphone, adresse, identifiant national) sont chiffrées au niveau du champ ; l'e-mail est stocké chiffré **avec un index aveugle** (HMAC à clé) : on peut encore retrouver un compte par e-mail pour la connexion sans que l'adresse soit lisible.

Scalabilité et résilience

- La **validation** des jetons est locale partout (passerelle et services gardent le JWKS en cache) : le fournisseur d'identité ne traite que les connexions et les renouvellements, environ 3 M par jour en année 3, soit environ 35/s en moyenne et 300/s en pointe — modeste, mais le hachage des mots de passe consomme beaucoup de CPU : les points de connexion sont donc limités en débit et les nœuds Keycloak dimensionnés sur ce coût.
- Keycloak tourne en cluster de 3 nœuds ou plus répartis sur les AZ, avec un cache de sessions distribué, **actif dans les deux régions** (niveau 0) : les soignants peuvent encore se connecter pendant une bascule régionale.
- Le service de gestion des utilisateurs est lui-même sans état et monte en charge horizontalement ; les lectures de profil sont mises en cache 60 s.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
Réutiliser un fournisseur d'identité éprouvé (Keycloak)	Développer l'authentification en interne	C'est dans l'authentification que le code maison échoue de la manière la plus dangereuse ; Keycloak apporte OIDC, MFA, WebAuthn, fédération et audits. Coût : exploiter et maintenir à jour un cluster avec état.
JWT de courte durée validés localement	Jetons opaques + introspection à chaque appel	Retire le fournisseur d'identité du chemin critique (latence, résilience du chemin d'urgence). Coût : la révocation n'est pas instantanée → durées de 5 à 10 min + liste de refus pour les événements à risque.
RBAC + ABAC avec OPA	RBAC seul	Le RBAC seul ne sait exprimer ni la relation de soin, ni le consentement, ni le bris de glace. OPA garde des politiques testables et versionnées.

Décision	Alternative	Pourquoi ce choix
Un realm par population	Un seul realm	Niveaux d'assurance et règles de session différents ; une erreur de configuration côté patients ne peut pas affaiblir les comptes professionnels.

2.2 ② Service de planification des téléconsultations

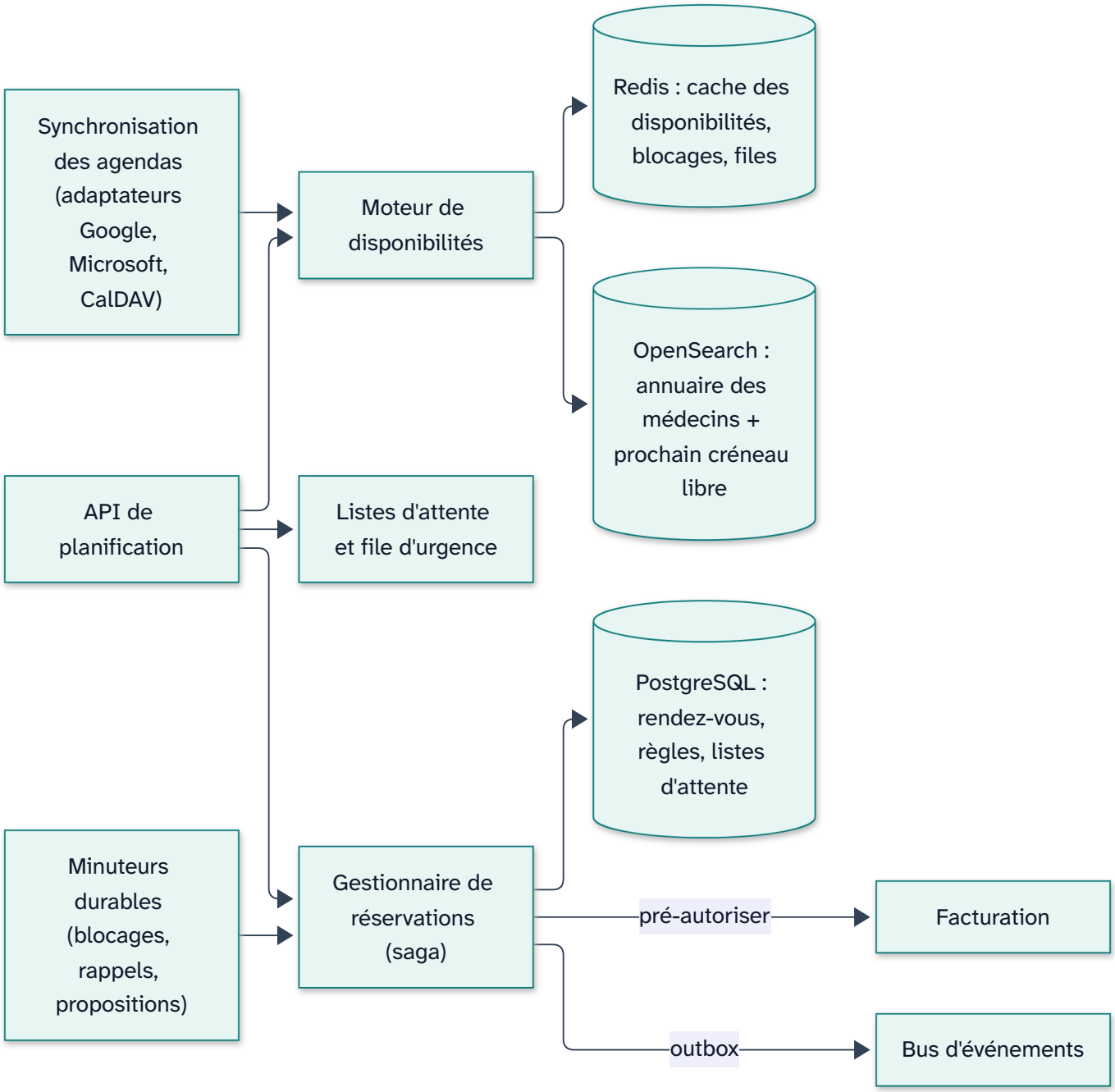
Priorité	Zone	Criticité	Détient
Moyenne — M1 planification · M5 agendas externes	Clinique (un rendez-vous chez un spécialiste est une donnée de santé)	Niveau 1	Règles de disponibilité, rendez-vous, listes d'attente, demandes urgentes, connexions aux agendas

Mission — permettre au patient de trouver et de réserver la bonne consultation en quelques gestes, ne jamais réserver deux fois le même créneau d'un médecin, tenir les médecins informés en temps réel et offrir une voie plus rapide aux cas urgents.

Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Réserver, déplacer, annuler des consultations	Recherche de créneaux → **blocage** court → confirmation avec pré-autorisation du paiement (saga avec la Facturation). Un déplacement transfère le même rendez-vous vers un nouveau créneau bloqué ; une annulation applique les règles d'annulation (gratuite jusqu'à 24 h avant).
Prévenir les médecins des nouvelles réservations ou des changements	Événements `RendezVousReserve / RendezVousDeplace / RendezVousAnnule` → Notification (push/e-mail selon les préférences) **et** mise à jour en direct de l'agenda du médecin via la passerelle temps réel.
S'intégrer aux agendas des médecins	Connecteurs Google Agenda, Microsoft 365 (Graph) et CalDAV : les plages occupées externes bloquent les créneaux MedX ; les rendez-vous MedX sont réinscrits dans l'agenda **sans aucune donnée patient**.
Listes d'attente et priorité pour les cas urgents	Liste d'attente par médecin ou par spécialité avec proposition automatique quand un créneau se libère ; questionnaire de triage → niveau d'urgence ; **file d'urgence à la demande** servie par des médecins de garde ; capacité réservée à l'urgence.

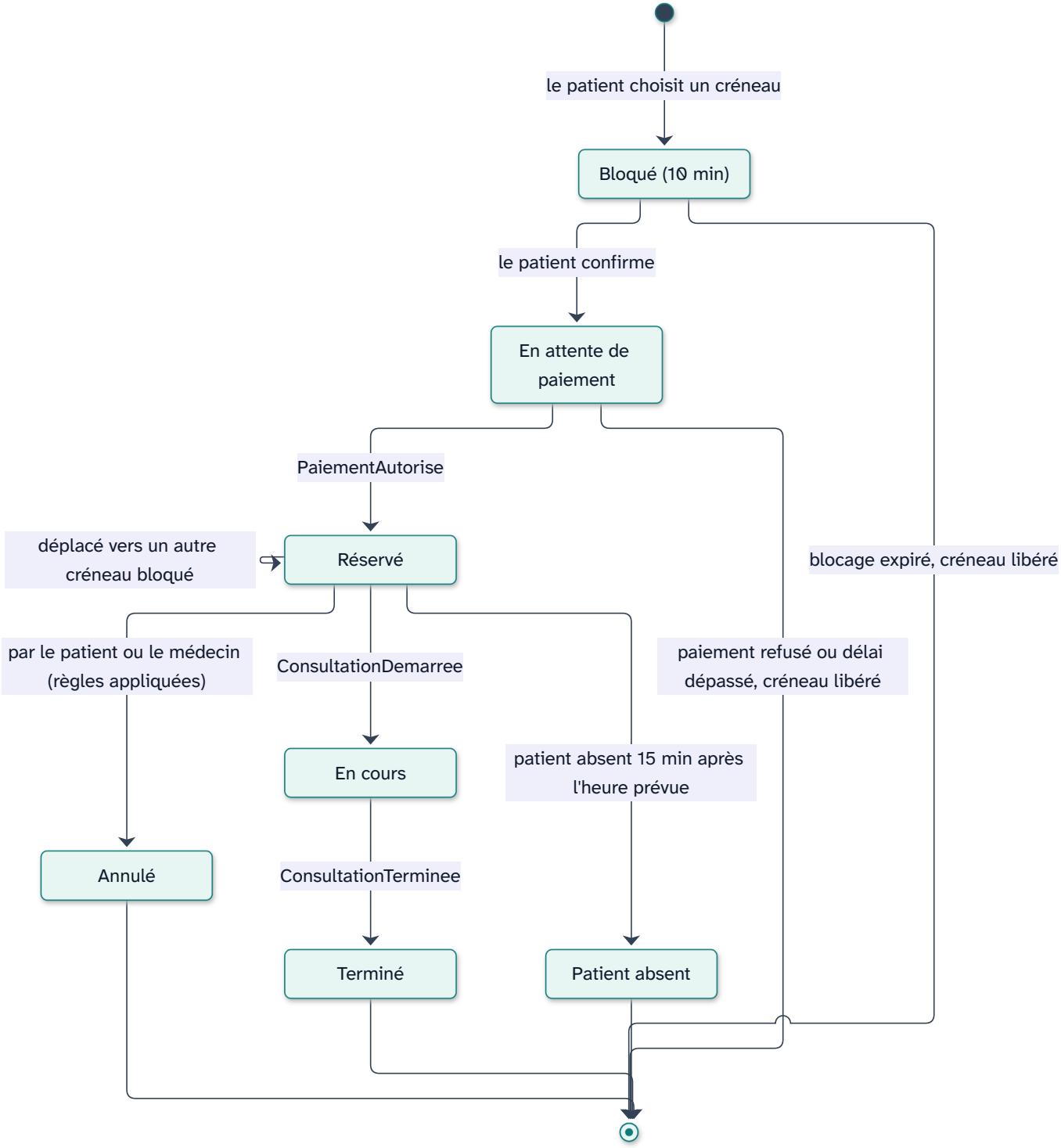
Conception interne



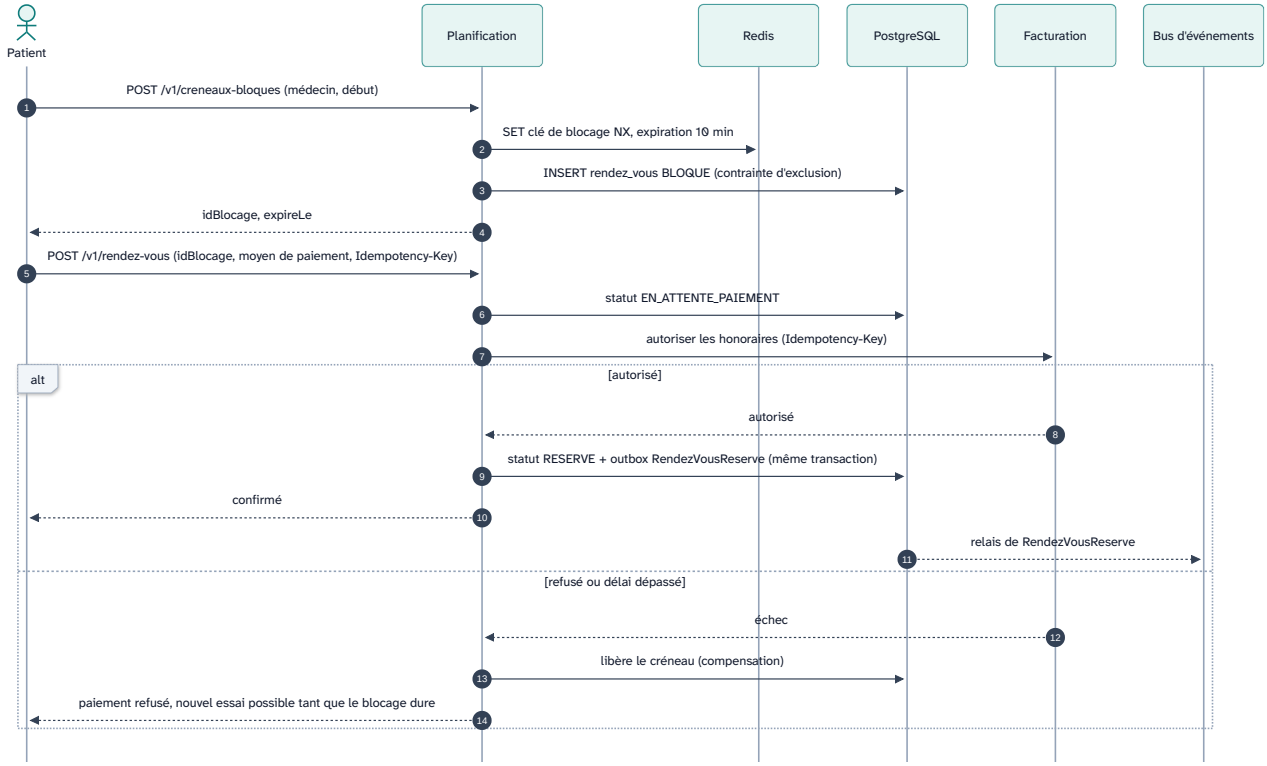
Module	Rôle
Moteur de disponibilités	Calcule les créneaux libres = règles récurrentes (RRULE, par type de consultation) – exceptions (congés) – plages occupées externes – créneaux réservés ou bloqués – capacité réservée à l'urgence. Précalcule les 60 prochains jours de chaque médecin dans Redis ; recalcule de façon incrémentale à chaque événement pertinent.
Gestionnaire de réservations	Blocages, confirmations, déplacements, annulations ; orchestre la saga de paiement ; porte la machine à états du rendez-vous.
Listes d'attente et file d'urgence	Files de priorité, propositions de créneaux avec blocage exclusif limité dans le temps, attribution des demandes urgentes aux médecins de garde.
Synchronisation des agendas	Connexions OAuth, webhooks de notifications poussées, synchronisation incrémentale, écriture des événements sortants, renouvellement des abonnements, rapprochement nocturne.
Minuteurs durables	Planificateur adossé à la base (survit aux redémarrages) pour l'expiration des blocages, les rappels (J-1, H-1, 10 min avant) et l'expiration des propositions de liste d'attente.

Module	Rôle
Projection annuaire	Profils de médecins dénormalisés (spécialité, langues, tarifs, prochain créneau libre) dans OpenSearch pour une recherche rapide.

Cycle de vie d'un rendez-vous



Saga de réservation et prévention des doubles réservations



Deux garde-fous indépendants empêchent les doubles réservations :

1. **Chemin rapide** — un blocage atomique dans Redis (`SET … NX PX 600000`) rejette les tentatives concurrentes sur le même créneau en moins d'une milliseconde.
2. **Source de vérité** — une **contrainte d'exclusion** PostgreSQL rend physiquement impossible le chevauchement de deux rendez-vous actifs d'un même médecin, même si Redis est indisponible ou si un bogue contourne le blocage :

```
CREATE EXTENSION IF NOT EXISTS btree_gist;

ALTER TABLE rendez_vous
  ADD CONSTRAINT rendez_vous_sans_chevauchement
  EXCLUDE USING gist (
    id_praticien WITH =,
    tstzrange(debut, fin, '[)') WITH &&
  )
  WHERE (statut IN ('BLOQUE', 'EN_ATTENTE_PAIEMENT', 'RESERVE', 'EN_COURS'));
```

Liste d'attente et cas urgents

- **Liste d'attente** — un patient peut attendre un créneau plus tôt avec un médecin donné ou avec n'importe quel médecin d'une spécialité. Quand un créneau se libère, il est proposé au meilleur candidat, classé **par niveau d'urgence puis par ancienneté d'attente**, avec un blocage exclusif de 15 minutes ; s'il refuse ou ne répond pas, le candidat suivant le reçoit.
- **Triage** — un court questionnaire validé médicalement (à base de règles, prudent) classe la demande : `URGENCE_VITALE` (signes d'alerte → **la réservation s'arrête et l'application affiche le 15 / 112**), `URGENT`

(le jour même), `PROCHE` (sous 48 h), `ROUTINE`. La téléconsultation ne doit jamais retarder une prise en charge en urgence.

- **File d'urgence à la demande** — les demandes `URGENT` entrent dans une file servie par les médecins de garde (appariés selon la spécialité, la langue, l'autorisation d'exercice). Un médecin a 2 minutes pour accepter avant que la demande ne passe au suivant ; un tableau de supervision suit l'objectif de temps d'attente (< 30 min) et déclenche une escalade.
- **Capacité réservée** — les médecins peuvent réserver une part de leurs créneaux aux cas urgents ; les créneaux réservés non utilisés sont ouverts à tous 2 heures avant.

Intégration des agendas externes

Aspect	Conception
Fournisseurs	Google Agenda (API), Microsoft Graph (Outlook / Microsoft 365), CalDAV (Apple iCloud et autres)
Consentement et scopes	Le médecin se connecte via OAuth 2.0 avec des **scopes minimaux** : lecture des plages libre/occupé, écriture limitée aux événements MedX (un agenda « MedX » dédié quand le fournisseur le permet). CalDAV utilise un mot de passe d'application stocké dans Vault.
Entrant (plages occupées)	Notifications poussées du fournisseur (canaux *watch* Google, abonnements Graph) → webhook via la passerelle → lecture incrémentale (jeton de synchronisation / lien delta) → mise à jour de `plage_occupee_externe` → disponibilités recalculées en quelques secondes. Interrogation de secours toutes les 10 min ; rapprochement complet chaque nuit ; renouvellement automatique des abonnements qui expirent.
Sortant (réservations MedX)	Chaque réservation crée un événement intitulé **« Téléconsultation MedX »** avec un lien vers le portail — **ni nom de patient, ni motif, ni spécialité**. Les déplacements et annulations le mettent à jour ou le suppriment (correspondance `id_rendez_vous ↔ id_evenement_externe`, idempotente).
Minimisation des données	Seuls le début et la fin des plages occupées sont stockés — jamais les titres, participants ou descriptions des événements privés du médecin.
Conflits	Les rendez-vous MedX font foi. Si le médecin ajoute un événement privé qui chevauche une réservation MedX, MedX l'alerte ; il n'annule jamais un patient automatiquement.
Pannes	Gestion des limites de débit par fournisseur avec temporisation exponentielle et disjoncteur ; si un fournisseur est indisponible, les dernières plages occupées connues sont utilisées et le médecin voit un bandeau « synchronisation de l'agenda retardée ».
Secrets	Jetons de rafraîchissement OAuth chiffrés avec Vault Transit, révoqués quand le médecin se déconnecte.

API (sélection)

Méthode	Point d'accès	Rôle
`GET`	`/v1/praticiens?specialite=&langue=&date=`	Recherche dans l'annuaire (OpenSearch)
`GET`	`/v1/praticiens/{id}/creneaux?du=&au=&type=`	Créneaux libres (cache Redis)
`POST`	`/v1/creneaux-bloques`	Bloquer un créneau pendant 10 min
`POST`	`/v1/rendez-vous`	Confirmer la réservation (`Idempotency-Key` , `idBlocage` , moyen de paiement)
`POST`	`/v1/rendez-vous/{id}/deplacement`	Déplacer vers un autre créneau bloqué
`POST`	`/v1/rendez-vous/{id}/annulation`	Annuler avec un motif (règles → remboursement ou annulation de l'autorisation)
`POST`	`/v1/listes-attente/inscriptions`	S'inscrire sur une liste d'attente
`POST`	`/v1/demandes-urgentes`	Réponses de triage → file d'urgence ou conseil d'appeler le 15
`PUT`	`/v1/praticiens/moi/regles-disponibilite`	Disponibilités récurrentes du médecin

Méthode	Point d'accès	Rôle
`POST`	`/v1/praticiens/moi/connexions-agenda`	Démarrer la connexion OAuth à un agenda externe
`POST`	`/v1/webhooks/agendas/{fournisseur}`	Notifications poussées des fournisseurs (jetons de canal vérifiés)

Événements

- **Publie** `planification.rendez-vous.v1` : RendezVousReserve, RendezVousDeplace, RendezVousAnnule, PatientAbsent, RappelRendezVousDu, CreneauProposeListeAttente, DemandeUrgenteCreee, DemandeUrgenteAttribuee.
- **Consomme** `facturation.paiement.v1` (PaiementAutorise / PaiementEchoue), `consultation.seance.v1` (ConsultationDemarree / ConsultationTerminee → statut), `identite.utilisateur.v1` (PraticienVerifie active l'agenda ; PraticienSuspendu le gèle et déclenche la reprogrammation des patients).

Données détenues

PostgreSQL : `regle_disponibilite`, `exception_disponibilite`, `rendez_vous` (+ `historique_rendez_vous` en ajout seul), `inscription_liste_attente`, `demande_urgente`, `connexion_agenda`, `plage_occupee_externe`, `minuteur`, `outbox`. Redis : blocages, disponibilités par médecin et par jour, files d'attente. OpenSearch : annuaire des médecins (données de profil public uniquement). Détail au §3.4.

Sécurité et confidentialité

- Les patients ne voient que leurs rendez-vous ; les médecins, seulement leur agenda ; les agents de support voient des données masquées.
- Le motif du rendez-vous et les réponses de triage sont des données de santé : chiffrés au niveau du champ, visibles seulement par le patient et le médecin réservé.
- La recherche dans l'annuaire est publique (profils seulement) et protégée contre l'aspiration de données par limitation de débit et détection des robots.

Scalabilité et résilience

- **Les lectures dominent** (recherche et disponibilités) : elles sont servies par OpenSearch et le cache Redis des disponibilités, si bien que la navigation ne sollicite pas la base ; les entrées de cache sont recalculées sur événement, pas à la lecture.
- **Les écritures restent modestes** (200 000 réservations par jour en année 3 ≈ 2 à 3/s, pointes ≈ 30/s) et la concurrence reste locale à un médecin.
- Les pointes (lundi de 8 h à 10 h, épidémies) sont absorbées par la mise à l'échelle automatique sur le débit de requêtes ; si le prestataire de paiement ralentit, le blocage garde le créneau pour le patient.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
Disponibilités précalculées	Calcul à chaque requête	Recherche rapide et prévisible même en pointe. Coût : logique d'invalidation, fraîcheur bornée (quelques secondes).

Décision	Alternative	Pourquoi ce choix
Blocage Redis **et** contrainte d'exclusion en base	L'un des deux seulement	Redis apporte la vitesse ; la contrainte apporte la garantie. Ceinture et bretelles pour un problème que les utilisateurs remarquent immédiatement.
Pré-autorisation du paiement à la réservation, encaissement après la consultation	Paiement à la fin	Moins de rendez-vous non honorés et d'impayés ; le patient ne paie qu'une consultation qui a eu lieu. Coût : les autorisations expirent au bout d'environ 7 jours → pour les rendez-vous lointains, la carte est enregistrée (authentification forte) et l'autorisation demandée 24 h avant.
Plages libre/occupé uniquement, aucune donnée de santé dans les agendas externes	Synchronisation complète dans les deux sens	Les agendas externes sont hors de la frontière de confiance de MedX et hors périmètre HDS.

2.3 ③ Service de consultation — vidéo, audio, chat et fichiers

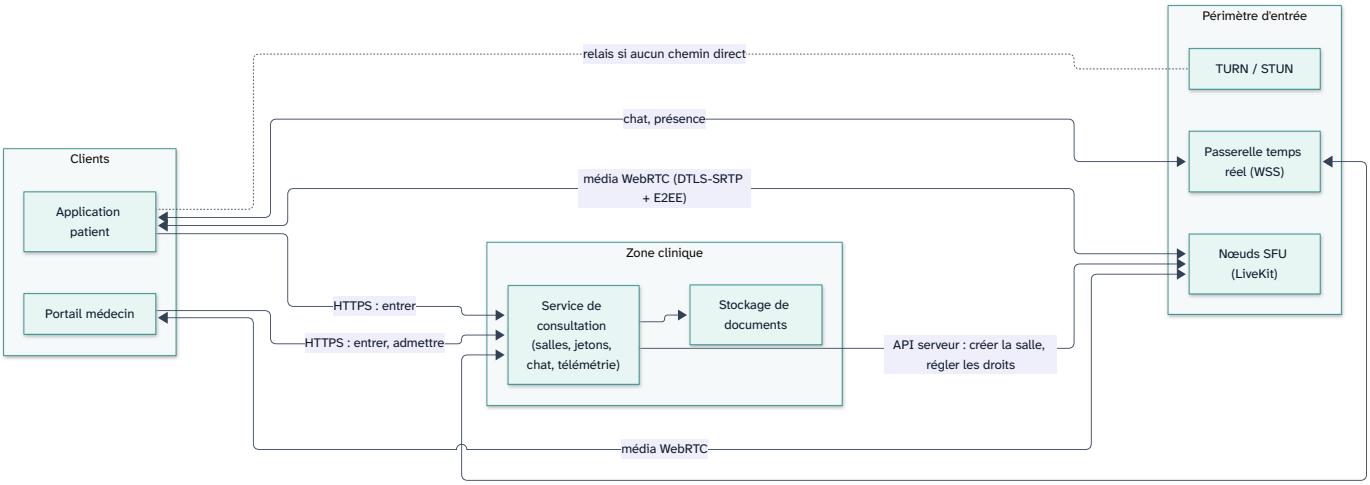
Priorité	Zone	Criticité	Détient
Moyenne — M2 services de consultation	Plan de contrôle dans la zone clinique · plan média dans le périmètre d'entrée	Niveau 1	Salles virtuelles, participants, événements de séance, historique récent du chat, télémétrie de qualité d'appel

Mission — offrir au patient et au médecin une salle virtuelle fiable et confidentielle : une bonne vidéo même sur un mauvais réseau, un chat qui ne perd jamais de message, et un moyen sûr d'échanger des documents médicaux.

Responsabilités

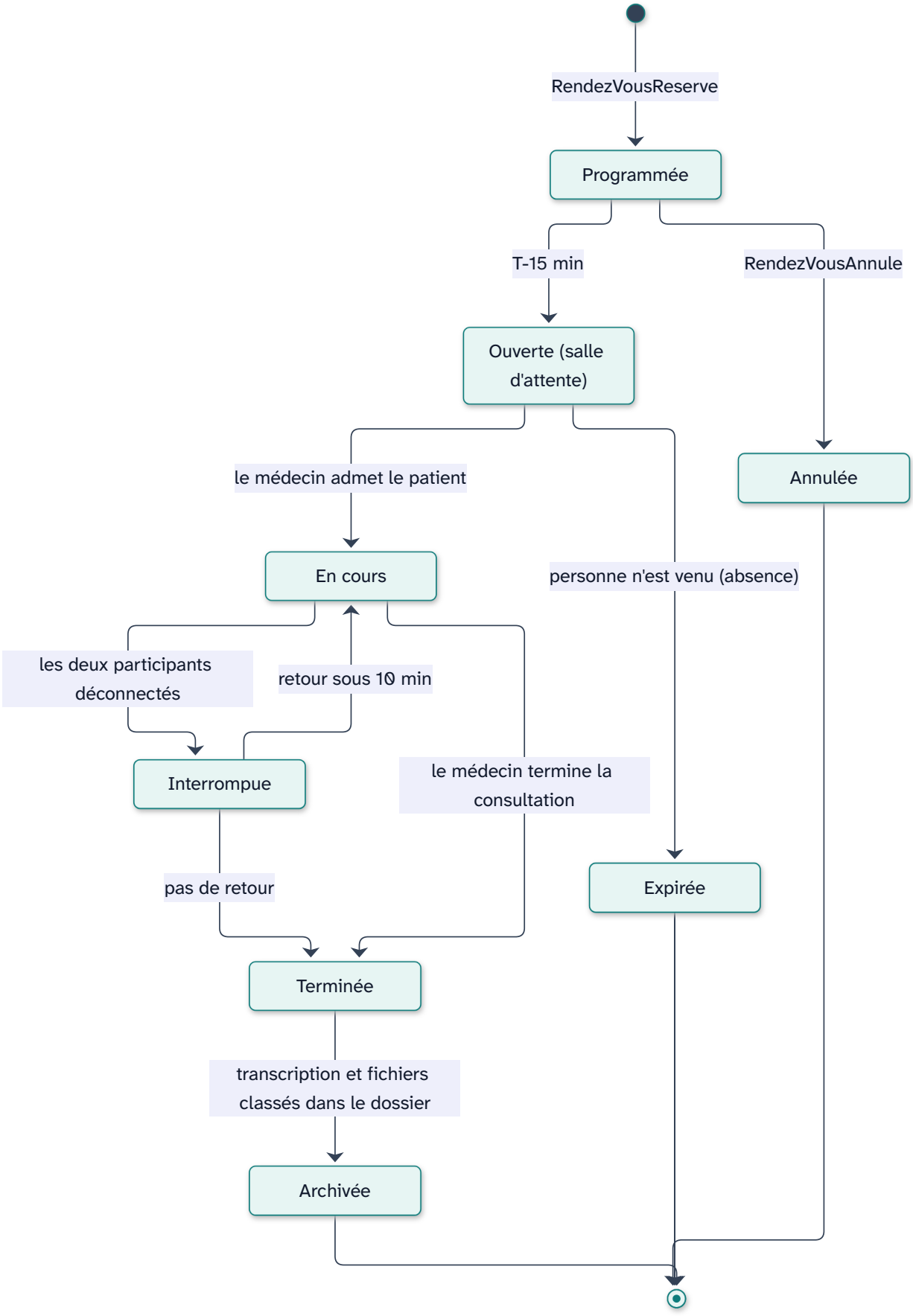
Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Créer des salles virtuelles	Une salle par rendez-vous, préparée dès la réservation et ouverte 15 min avant ; **salle d'attente** jusqu'à ce que le médecin admette le patient ; identifiants de salle de 128 bits, impossibles à deviner.
Gérer les flux vidéo et audio	**WebRTC** via un **SFU** auto-hébergé (LiveKit) avec relais TURN/STUN ; simulcast et débit adaptatif ; repli automatique en audio seul ; reconnexion par redémarrage ICE.
Permettre le chat pendant la consultation	Chat via la passerelle temps réel (WSS), persistant et ordonné par salle, avec accusés de réception et de lecture ; transcription archivée dans le dossier patient à la fin.
Permettre le transfert de documents médicaux	Dépôts via le **stockage sécurisé de documents** (quarantaine, antivirus, contrôle de type, chiffrement) ; fichiers partagés dans le chat ; le médecin peut les classer dans le dossier.

Plan de contrôle et plan média

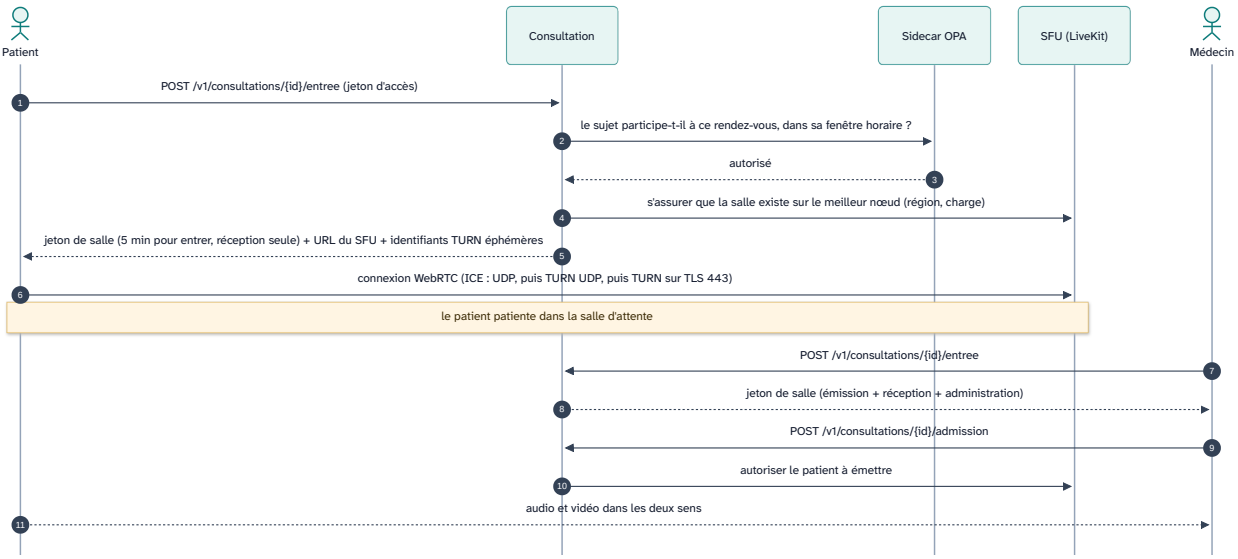


- Le **plan de contrôle** (service de consultation) décide *qui* peut entrer dans *quelle* salle et *quand* ; il ne touche jamais au média.
- Le **plan média** (SFU + TURN) ne fait que relayer des paquets chiffrés ; il ne stocke rien et ne conserve aucune donnée de santé. Les nœuds média sont dans des sous-réseaux publics car WebRTC a besoin de ports UDP publics.

Cycle de vie de la salle



Rejoindre une consultation



Les jetons sont **de courte durée, limités à une salle et à un participant** ; dans le SFU, l'identité du participant est un pseudonyme, jamais le nom du patient. Des participants supplémentaires (interprète, aidant) ne peuvent être invités qu'avec le consentement du patient et reçoivent leur propre jeton limité.

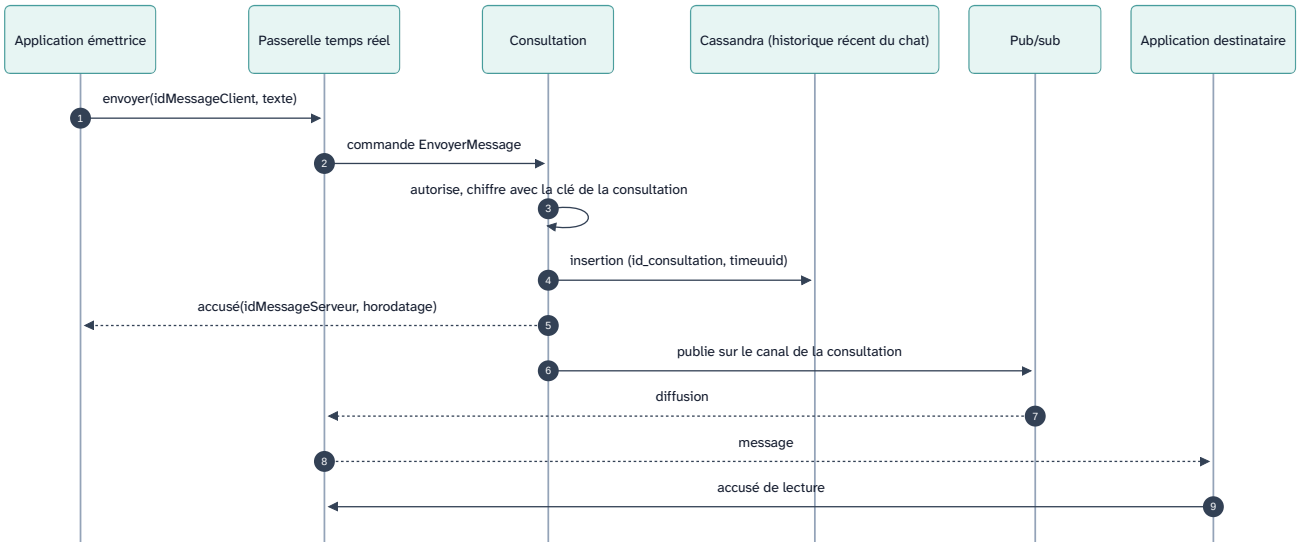
Qualité média sur des réseaux réels

Technique	Effet
Simulcast (3 couches) + dynacast	Chaque destinataire reçoit la couche que sa bande passante permet ; les couches inutilisées sont suspendues pour économiser la voie montante.
Audio Opus avec correction d'erreurs intégrée et DTX	La parole reste intelligible jusqu'à environ 20 % de pertes de paquets ; l'audio est prioritaire sur la vidéo.
Contrôle de congestion (*transport-wide CC*)	Le débit s'adapte en continu ; sous environ 150 kbit/s, l'appel bascule automatiquement en **audio seul**.
TURN sur TLS, port 443	Fonctionne sur les réseaux restrictifs d'hôpitaux et d'entreprises.
Redémarrage ICE + reconnexion	Passer du Wi-Fi à la 4G ne met pas fin à la consultation.
Test avant l'appel	Caméra, micro et bande passante vérifiés avant l'entrée en salle d'attente.
Télémétrie de qualité	Statistiques WebRTC (aller-retour, gigue, pertes, gels d'image) relevées toutes les 10 s — ni média, ni donnée de santé — qui alimentent tableaux de bord et alertes par région et par nœud TURN.

Confidentialité des flux média

- **Le chiffrement de saut en saut est obligatoire** : WebRTC utilise toujours DTLS-SRTP.
- Le **chiffrement de bout en bout (E2EE)** par *insertable streams* (SFrame) est **activé par défaut pour les consultations en tête-à-tête** quand les deux appareils le permettent : les clés sont négociées entre les appareils des participants et jamais stockées par MedX, si bien que ni MedX ni l'opérateur du SFU ne peuvent déchiffrer l'audio ou la vidéo.
- **Aucun enregistrement** des consultations (confidentialité dès la conception). Si un enregistrement était un jour introduit (par exemple pour la formation), il exigerait un consentement explicite, désactiverait l'E2EE pour cette séance et serait conservé comme un document du dossier.

Chat



- **Effet « exactement une fois »** : livraison au moins une fois + déduplication sur `idMessageClient` ; ordre fixé par le time-UUID du serveur.
- **Conservation** : l'historique récent garde les messages 30 jours (TTL) pour le confort ; à la fin de la consultation, la transcription complète est **archivée dans le dossier patient** (`TranscriptionChatPrete` → le dossier crée un document), qui constitue la copie légale et durable.
- Les indicateurs de saisie et la présence sont éphémères (jamais stockés).

Partage de fichiers

1. L'application demande un emplacement de dépôt au stockage de documents → URL présignée vers un compartiment de **quarantaine** (valable 5 min, 50 Mo au plus, types autorisés : PDF, JPEG, PNG, HEIC).
2. Le fichier est analysé (antivirus, vrai type d'après les octets de signature, contenu actif des PDF retiré, métadonnées des images comme la position GPS supprimées), puis chiffré et déplacé dans le compartiment des documents avec sa somme de contrôle SHA-256.
3. Un message « fichier partagé » qui référence l'identifiant du document apparaît dans le chat ; les téléchargements passent par le stockage de documents avec la même autorisation que la consultation, et sont audités.
4. Les fichiers envoyés par le patient sont rattachés automatiquement à la rencontre comme *documents fournis par le patient* ; le médecin décide lesquels classer définitivement dans le dossier.

API (sélection)

Méthode	Point d'accès	Rôle
`POST`	`/v1/consultations/{id}/entree`	Jeton de salle + URL du SFU + identifiants TURN éphémères
`POST`	`/v1/consultations/{id}/admission`	Le médecin admet le patient depuis la salle d'attente
`POST`	`/v1/consultations/{id}/participants`	Inviter un interprète ou un aidant (consentement du patient requis)
`POST`	`/v1/consultations/{id}/fin`	Le médecin termine la consultation
`GET`	`/v1/consultations/{id}/messages?curseur=`	Historique du chat (paginé)
`POST`	`/v1/consultations/{id}/fichiers`	Demander un emplacement de dépôt (délégué au stockage de documents)
`POST`	`/v1/telemetrie/webrtc`	Statistiques de qualité d'appel

Méthode	Point d'accès	Rôle
`WSS`	`/v1/temps-reel` → canal `consultation:{id}`	Chat, accusés, présence

Événements

- **Publie** `consultation.seance.v1` : ConsultationOuverte, ConsultationDemarree, ConsultationTerminee (durée, participants), ConsultationEchouee (personne n'a pu se connecter → remboursement automatique), TranscriptionChatPrete.
- **Consomme** `planification.rendez-vous.v1` (préparer, déplacer ou annuler les salles).

Données détenues

PostgreSQL (`consultation` , `participant` , `evenement_seance` , `synthese_qualite`), Cassandra (`message_chat` , TTL de 30 jours, contenu chiffré), Redis (routage salle → nœud SFU, présence). Les fichiers appartiennent au stockage de documents.

Scalabilité et résilience

- **Dimensionnement (année 3)** : 10 000 séances simultanées → 20 000 participants ; environ 1,2 Mbit/s en moyenne par flux reçu → environ 24 Gbit/s en sortie des SFU. À environ 200 participants par nœud de 8 vCPU (à confirmer par des tests de charge), il faut **une centaine de nœuds média en pointe**, jusqu'à 200 pour la marge ×2, répartis sur trois AZ.
- **Placement** : chaque salle en tête-à-tête vit sur un seul nœud, dans la région la plus proche des participants ; lors d'une réduction de capacité, les nœuds sont **vidés, jamais coupés** (plus de nouvelles salles, les appels en cours se terminent).
- **TURN** dimensionné pour environ 20 % de séances relayées (réseaux restrictifs).
- **Panne d'un nœud média** : les clients se reconnectent automatiquement à un autre nœud en quelques secondes (redémarrage ICE) ; l'état de la salle est recréé depuis le plan de contrôle.
- **Mode dégradé** : si la vidéo est impossible, audio seul ; si le média échoue totalement, le chat continue et le médecin peut appeler le patient par téléphone (l'événement est journalisé).

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
SFU open source auto-hébergé (LiveKit)	CPaaS vidéo (Vonage, Daily…)	Le média reste sur une infrastructure européenne certifiée HDS ; coût plus faible à grande échelle ; E2EE possible. Coût : exploiter des serveurs média (UDP, mise à l'échelle, TURN). Un CPaaS reste une solution de repli si le délai de mise sur le marché prime.
SFU	Maillage pair-à-pair / MCU	Le pair-à-pair ne donne aucun contrôle sur la qualité, le relais ou les appels à plusieurs (interprète) ; un MCU décode et mixe les flux (très gourmand en CPU, incompatible avec l'E2EE). Le SFU relaie des paquets : il monte en charge et reste compatible avec l'E2EE.
E2EE activé par défaut en tête-à-tête	Chiffrement de saut en saut seulement	Confidentialité maximale pour les échanges les plus sensibles. Coût : pas d'enregistrement ni de transcription côté serveur, un peu plus de CPU sur l'appareil.
Historique récent du chat + archive dans le dossier	Chat écrit directement dans le dossier	Messagerie à faible latence sans charger le stockage des dossiers ; le dossier reçoit malgré tout la transcription complète.

2.4 ④ Service de gestion des dossiers patients et accès d'urgence

Priorité	Zone	Criticité	Détient
Haute — H2 gestion des dossiers · H3 accès d'urgence · H5 intégrité · Moyenne — M4 masquage et caviardage	Clinique	**Niveau 0** (lecture, accès d'urgence) · niveau 1 (écritures)	Le dossier médical (ressources FHIR et leur historique), les consentements, les autorisations de soin, les autorisations d'urgence, les résumés critiques, les clés de données des patients

Mission — tenir le dossier médical de chaque patient, tout au long de sa vie, **complet, exact et infalsifiable**, ne le montrer qu'aux bonnes personnes et pour de bonnes raisons, et rendre sa partie critique disponible **en quelques secondes** en cas d'urgence.

Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Stocker et gérer les antécédents, les notes de consultation et les autres éléments du dossier	Ressources **HL7 FHIR R4** (pathologies, allergies, traitements, vaccinations, actes, observations, comptes rendus, rencontres, notes cliniques, documents) stockées par un serveur FHIR (HAPI FHIR sur PostgreSQL) ; fichiers dans le stockage sécurisé de documents.
Permettre aux médecins d'ajouter / modifier après la consultation	Écritures validées avec contrôle de concurrence optimiste ; les notes restent des brouillons jusqu'à leur **signature** ; après signature, toute modification est un **addendum** (nouvelle version avec motif) — l'original n'est jamais perdu. Une saisie sur le mauvais patient est marquée *entered-in-error*, pas supprimée.
Donner aux patients l'accès à leur dossier (avec restrictions)	API du portail patient avec des jetons limités au patient ; règles de publication (par exemple, un résultat publié après la relecture du médecin, là où la loi le permet), informations sur des tiers caviardées, périmètres des mandataires, confidentialité des adolescents.
Garantir l'intégrité des données et la conformité réglementaire	Historique en ajout seul, chaîne de hachage par patient ancrée chaque jour dans un stockage WORM, provenance sur chaque écriture, validation par profils, audit complet des lectures et des écritures, registre des consentements, règles de conservation, chiffrement par patient et effacement cryptographique.
Accès d'urgence (Annexe 2, H3)	Module **Accès d'urgence** déployé à part, qui sert un **résumé patient international** (IPS) précalculé sous une autorisation de bris de glace limitée dans le temps — voir plus bas.

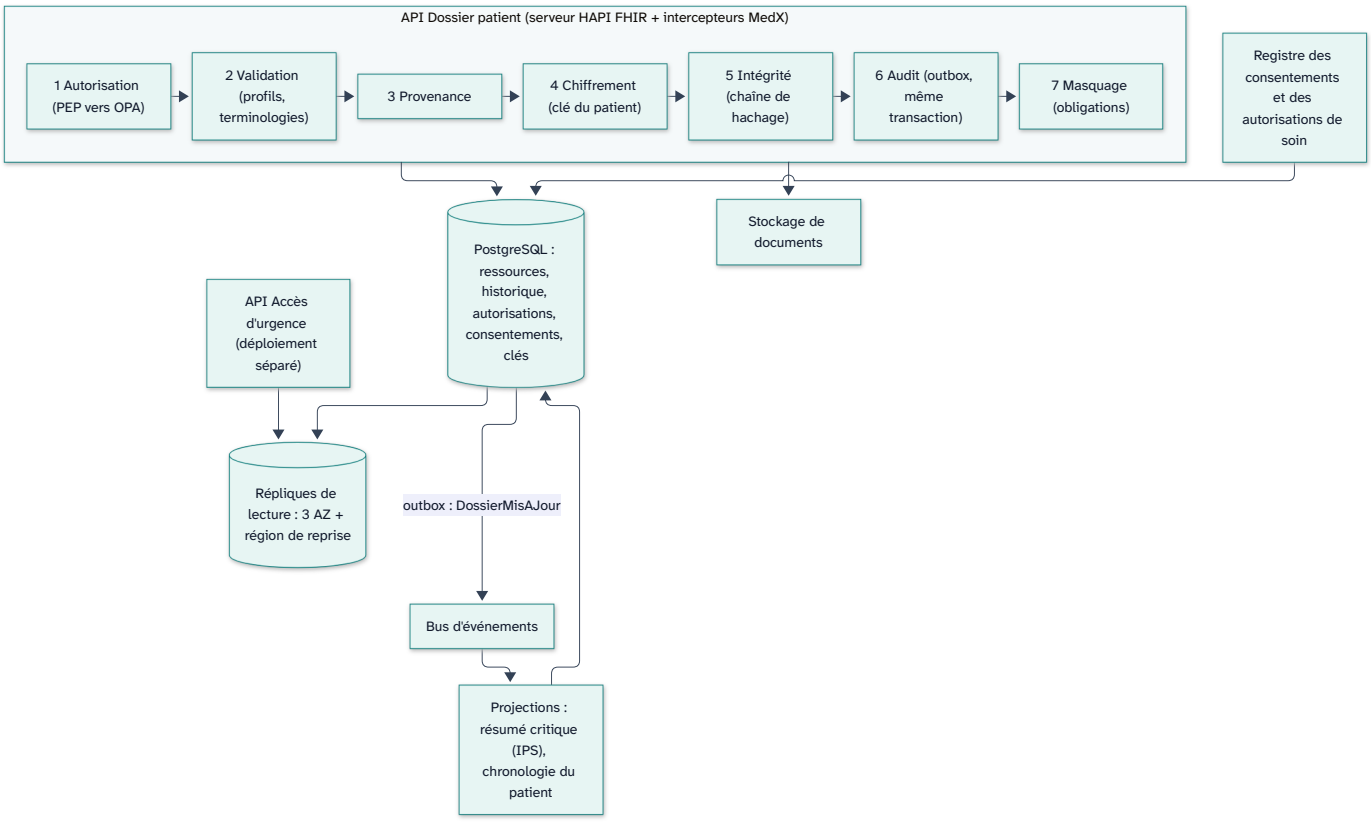
Modèle de données cliniques (FHIR R4)

Notion MedX	Ressource(s) FHIR	Remarques
Identité du patient	`Patient`	Identifiant MedX + identifiant national de santé (INS) stocké chiffré
Antécédents médicaux	`Condition`, `AllergyIntolerance`, `Procedure`, `Immunization`, `FamilyMemberHistory`	Codés en SNOMED CT / CIM-10
Traitements	`MedicationStatement`, `MedicationRequest` (venant des Ordonnances)	Codés en ATC et codes nationaux des médicaments
Mesures et résultats	`Observation`, `DiagnosticReport`	Codes LOINC ; règles de publication applicables
Consultation	`Encounter` (rencontre) + `Composition` (note clinique)	La `Composition` est signée par son auteur
Documents	`DocumentReference` → fichier dans le stockage de documents	Empreinte SHA-256 dans `attachment.hash`

Notion MedX	Ressource(s) FHIR	Remarques
Qui a fait quoi	`Provenance` (chaque écriture) · `AuditEvent` (chaque accès, dans la piste d'audit)	
Choix du patient	`Consent`	Partage, participation à la recherche, opposition au bris de glace là où elle est permise
Résumé d'urgence	`Composition` au profil **IPS**	Projection précalculée

Profils : International Patient Summary (IPS) et profils nationaux (par exemple FR Core) — la validation rejette à l'écriture toute donnée mal formée ou non codée.

Conception interne



Chaque requête traverse la même **chaîne d'intercepteurs**, si bien qu'aucun point d'accès ne peut oublier un contrôle : autorisation → validation → provenance → chiffrement → intégrité → audit → masquage.

Écriture, versionnage et intégrité

1. **Concurrence optimiste** — une mise à jour doit envoyer `If-Match: W/"<version>"` ; une modification concurrente renvoie `412` et le médecin fusionne — aucune mise à jour perdue en silence.
2. **Historique en ajout seul** — chaque modification insère une nouvelle ligne dans `historique_ressource` ; le rôle de base de données du service n'a **aucun droit** `UPDATE` / `DELETE` sur les tables d'historique (imposé par les droits et par des déclencheurs).
3. **Signature des notes** — `Composition.status` passe de `preliminary` à `final` quand l'auteur signe ; ensuite, seuls des addenda sont possibles (`amended` , avec motif et attestation).

4. **Chaîne de hachage par patient** — chaque version stocke `h(n) = SHA-256( h(n-1) || JCS(version de la ressource) || auteur || horodatage )` (JCS = JSON canonique, RFC 8785). Une tâche nocturne recalcule les chaînes ; toute rupture déclenche un incident de sécurité.
5. **Ancrage quotidien** — la racine de Merkle de toutes les têtes de chaîne du jour est signée par une clé HSM, horodatée (horodatage qualifié RFC 3161) et écrite dans un stockage **WORM** : même un administrateur de base de données ne pourrait pas réécrire l'historique sans être détecté.
6. **Provenance** — qui, quand, depuis quelle rencontre, pour le compte de qui, et pourquoi.
7. **Documents** — chaque fichier porte une somme de contrôle SHA-256 calculée au dépôt et vérifiée à chaque téléchargement.

Contrôle d'accès

Voie d'accès	Qui	Conditions	Périmètre
Soi-même	Patient	Identité vérifiée	Son propre dossier, selon les règles de publication
Mandataire	Parent / aidant	Délégation issue de la gestion des utilisateurs	Périmètre délégué ; éléments confidentiels d'un adolescent masqués
Autorisation de soin	Médecin	Créée automatiquement à la réservation, avec le consentement du patient ; valable jusqu'à 30 jours après la consultation ; renouvelable ; désignation de « médecin traitant » pour le suivi au long cours	Dossier complet, sauf catégories restreintes sans consentement explicite
Partage par le patient	Tout médecin vérifié	Le patient partage son dossier (par exemple avec un spécialiste) pour une durée choisie	Selon le choix du patient
Bris de glace	Médecin titulaire de `acces_urgence`	Urgence déclarée, authentification renforcée, pas d'opposition du patient	Lecture seule, 4 heures, ce patient, notes restreintes exclues
Pharmacien	—	**Aucun accès au dossier** — seulement aux ordonnances attribuées à sa pharmacie, via le service Ordonnances	—
Équipes MedX	Support, administrateurs	**Aucun accès aux données cliniques** ; le DPO voit seulement les métadonnées d'audit	—

Labels de sensibilité — les ressources des catégories sensibles (santé mentale, santé sexuelle et reproductive, VIH, génétique, addictions) portent le label `restreint` et exigent le consentement explicite du patient pour être partagées au-delà de leur auteur.

Restrictions côté patient — (1) *règles de publication* : un nouveau résultat peut être retenu jusqu'à ce que le médecin l'ait relu (paramétrable selon le pays ; publication immédiate là où la loi l'exige, par exemple avec les règles américaines contre le blocage de l'information) ; (2) les informations concernant des tiers écrites dans une note peuvent être caviardées dans la vue patient ; (3) les mandataires ne voient que leur périmètre délégué.

Masquage et caviardage (M4)

Le moteur de politiques renvoie des **obligations** avec chaque décision ; une bibliothèque de masquage partagée les applique à la réponse FHIR avant qu'elle ne quitte le service.

Situation	Technique	Exemple
Un agent de support consulte un compte	Masquage partiel	`+33 6 •• •• •• 42`, `j•••@g•••.com`, aucune donnée clinique

Situation	Technique	Exemple
Un pharmacien ouvre une ordonnance	Liste blanche de champs	Nom, date de naissance, médicaments prescrits, prescripteur — ni diagnostic, ni notes
Accès par bris de glace	Exclusion de catégories	Notes de psychothérapie exclues ; traitements et allergies toujours affichés
Portail patient	Règles de publication + caviardage	Résultats retenus masqués ; informations sur des tiers caviardées
Export / partage d'un document	Caviardage des sections marquées ; caviardage PDF qui supprime la couche texte (et pas un simple rectangle noir posé sur le texte)	Lettre de sortie partagée sans les antécédents familiaux
Journaux, traces, analytique	Jamais journalisé ; identifiants tokenisés ; désidentification	Voir le §5.7

Accès d'urgence (bris de glace)

Accès d'urgence (bris de glace)

Exigence de priorité haute H3 · accès immédiat aux données critiques pour les professionnels habilités, avec une traçabilité complète a posteriori

1 Identifier le patient

Recherche exacte uniquement : INS / identifiant MedX, ou nom + date de naissance + sexe
Identité minimale pour confirmer le patient
Ni navigation, ni jokers

2 Déclarer l'urgence

Code motif (inconscient, pronostic vital engagé, consentement impossible…)
Justification en texte libre
Engagement de responsabilité « Je serai audité »

3 MFA renforcée

Passkey ou carte (e-CPS) dans les 15 dernières minutes
Le moteur de politiques vérifie le droit acces_urgence et l'opposition du patient

4 Autorisation limitée

4 heures · lecture seule
Ce patient uniquement
Autorisation + audit écrits dans la même transaction
Renouvelable avec un nouveau motif

5 Synthèse en < 1 s

Résumé patient (IPS) : allergies, problèmes actifs, traitements, groupe sanguin, implants, directives anticipées, contacts
Dossier complet : même accès

Soignant : ≈ 30 secondes de la recherche aux données (étapes humaines) · Système : p95 < 300 ms par appel d'API · Disponibilité 99,99 %

GARDE-FOUS — RESPONSABILITÉ A POSTERIORI (l'accès n'est jamais bloqué, il est toujours justifié)

Audit immuable

AuditEvent, finalité = traitement d'urgence, conservé dans la piste WORM

Alerte en temps réel

Le DPO est alerté via le SIEM dès le début de l'accès

Patient informé

Avis in-app + e-mail sous 24 h : qui, quand, ce qui a été consulté

Revue obligatoire

DPO + responsable médical revoient chaque cas sous 72 h

Détection des abus

L'analyse comportementale repère les anomalies ; sanctions et suspension

RÉSILIENCE — POURQUOI LE CHEMIN DE NIVEAU 0 FONCTIONNE QUAND D'AUTRES SERVICES SONT DÉGRADÉS

Déploiement isolé

cloisonné, capacité réservée

Synthèse pré-calculée

projection, sans jointure

Répliques multi-AZ

+ région de secours active

Jetons validés en local

clés de l'IdP en cache

Décisions locales

sidecar OPA, paquets en cache

Audit via l'outbox

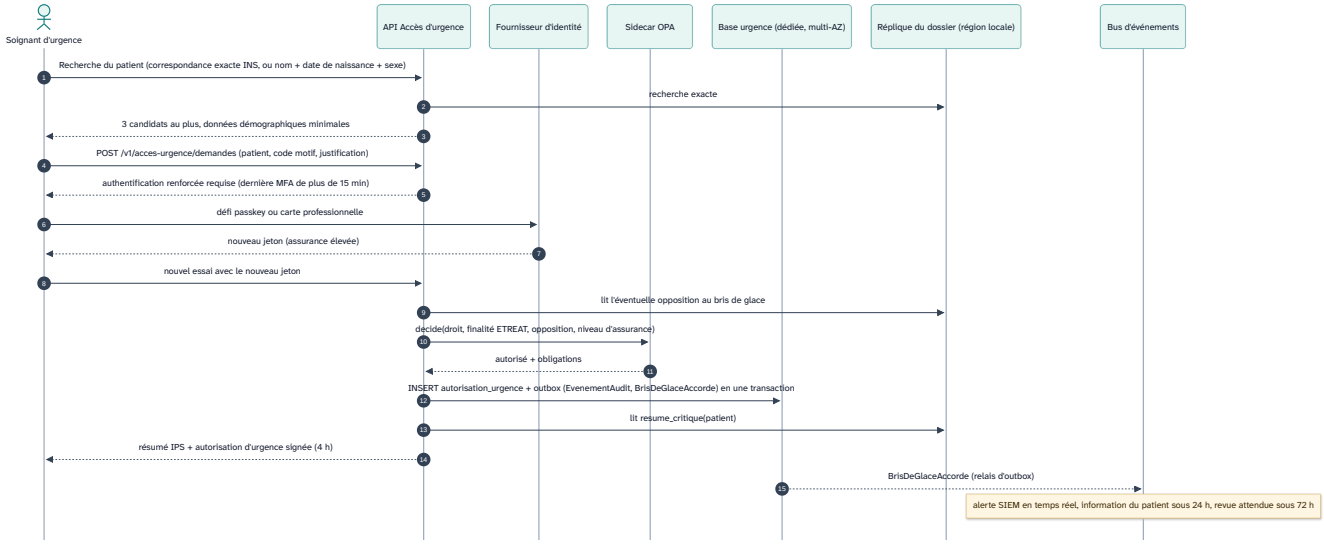
sans dépendre de la chaîne d'audit

Qui peut briser la glace ?

Praticiens vérifiés titulaires du droit acces_urgence (médecine d'urgence, gardes, SAMU), accordé par le responsable médical de MedX et revu chaque trimestre. Les patients peuvent s'y opposer lorsque la loi le permet.

Flux d'accès d'urgence

Principe — en urgence, *l'accès n'est jamais bloqué par une procédure ; on en rend toujours compte après coup*. Un circuit d'approbation préalable est trop lent quand un patient est inconscient ; MedX accorde un accès immédiat, étroit et limité dans le temps, et rend tout abus très visible et sanctionné.



Aspect	Conception
Qui	Praticiens vérifiés titulaires du droit `acces_urgence` (médecine d'urgence, garde, SAMU), attribué par le responsable médical de MedX et recertifié chaque trimestre.
Identification	Recherche par correspondance exacte uniquement (identifiant national de santé, identifiant MedX, ou nom + date de naissance + sexe), qui renvoie au plus trois candidats avec des données démographiques minimales — pas de navigation, pas de joker, débit limité.
Déclaration	Motif codé (patient inconscient, pronostic vital engagé, patient incapable de communiquer…) + justification en texte libre + engagement de responsabilité.
Authentification	Authentification renforcée si la dernière authentification forte date de plus de 15 minutes (passkey ou carte professionnelle).
Autorisation	Lecture seule, pour ce patient uniquement, **4 heures**, renouvelable avec une nouvelle justification ; émise sous forme d'**autorisation d'urgence signée** (JWT lié à la clé du soignant) que l'API Dossier patient habituelle accepte aussi pour le dossier complet.
Données renvoyées	**Résumé patient international (IPS)** : allergies et intolérances, problèmes actifs, traitements en cours, vaccinations, implants et dispositifs, actes passés, groupe sanguin, état de grossesse, directives anticipées, personnes à prévenir. Le dossier complet est accessible avec la même autorisation, notes restreintes exclues.
Choix du patient	Le patient peut s'opposer au bris de glace là où la loi le permet (il est prévenu du risque) ; là où elle ne le permet pas, l'opposition est ignorée.
Responsabilité	EvenementAudit avec `purposeOfUse = ETREAT` écrit **dans la même transaction** que l'autorisation (aucun accès sans audit) ; alerte SIEM en temps réel au DPO ; patient informé (dans l'application + e-mail) sous 24 h : qui, quand, quoi ; **revue obligatoire sous 72 h** par le DPO et un responsable médical ; usage injustifié → suspension et signalement à l'ordre professionnel ; l'analyse comportementale repère les anomalies.

Pourquoi il continue de fonctionner quand le reste est dégradé (niveau 0)

Panne	Effet sur l'accès d'urgence
Base principale du dossier indisponible	Aucun — les résumés sont lus sur les répliques ; les autorisations sont écrites dans la base propre au service Accès d'urgence.
Perte de la région principale	Aucun, hormis la bascule DNS — l'API Accès d'urgence est **active dans la région de reprise**, avec sa propre base d'autorisations et des répliques locales (retard < 1 s).

Panne	Effet sur l'accès d'urgence
Bus d'événements / chaîne d'audit indisponible	Aucun — les événements d'audit attendent dans l'outbox et sont livrés plus tard ; rien n'est perdu.
Serveur de paquets de politiques indisponible	Aucun — les sidecars OPA gardent le dernier paquet signé.
Fournisseur d'identité lent	Les soignants dont l'authentification forte est récente continuent ; les jetons sont validés localement avec des clés en cache. Le fournisseur d'identité est lui-même actif dans les deux régions.
Pic de trafic sur le reste de MedX	Aucun — déploiement séparé avec capacité réservée (cloisonnement) et ses propres limites de débit.

Performance — le résumé critique est une projection précalculée, rafraîchie quelques secondes après chaque modification (sur événement) et stockée sous forme d'une ligne chiffrée par patient : une lecture indexée sur la réplique la plus proche, un déchiffrement de clé en cache, un déchiffrement → **p95 < 300 ms**.

API (sélection)

Méthode	Point d'accès	Rôle
`GET`	`/fhir/Patient/{id}/$summary`	Résumé IPS (patient, équipe soignante)
`GET`	`/fhir/{type}?patient={id}&…`	Recherche FHIR
`POST` / `PUT`	`/fhir/{type}` · `/fhir/{type}/{id}`	Création / mise à jour (`If-Match` obligatoire)
`GET`	`/fhir/{type}/{id}/_history`	Historique des versions
`POST`	`/fhir/Composition/{id}/$sign`	Signer une note clinique
`GET`	`/fhir/Patient/{id}/$everything`	Export complet (droit d'accès / portabilité) — paquet FHIR ou PDF
`POST`	`/v1/acces-urgence/demandes`	Demande de bris de glace → autorisation + résumé critique
`GET`	`/v1/patients/moi/historique-acces`	« Qui a consulté mon dossier » (à partir de la piste d'audit)
`PUT`	`/v1/patients/moi/consentements/{type}`	Partage, recherche, opposition au bris de glace

Événements

- **Publie** `dossier.patient.v1` (DossierMisAJour, DocumentAjoute, ResultatPublie, ConsentementModifie) et `dossier.urgence.v1` (BrisDeGlaceAccorde, RevueBrisDeGlaceAttendue, BrisDeGlaceRevu).
- **Consomme** `identite.utilisateur.v1` (créer le dossier et les clés du patient ; révoquer les autorisations des praticiens suspendus), `planification.rendez-vous.v1` (créer / révoquer les autorisations de soin), `consultation.seance.v1` (rencontre, archivage de la transcription du chat), `ordonnance.v1` (liste des traitements et rafraîchissement du résumé).

Données détenues

Base PostgreSQL `dossier` : `ressource` (versions courantes, JSONB, éléments sensibles chiffrés), `historique_ressource` (ajout seul, chaîne de hachage), index des paramètres de recherche, `autorisation_soin`, `consentement`, `resume_critique`, `cle_patient` (clés de données chiffrées), `outbox`. Le service Accès d'urgence a sa propre petite base (`autorisation_urgence`, `dossier_revue`, `outbox`). Les fichiers sont dans le stockage de documents. Détail au §3.4.

Scalabilité et résilience

- **Beaucoup plus de lectures que d'écritures** (5 à 10 lectures par écriture ; environ 600 lectures/s en pointe en année 3) : une réplique synchrone et deux répliques de lecture réparties sur les trois AZ, plus des répliques dans la région de reprise ; la lecture de ses propres écritures est garantie à l'auteur en dirigeant ses lectures vers la base principale pendant quelques secondes après une écriture.
- Les écrans lisent la **projection chronologique du patient** (une requête par écran) au lieu d'assembler de nombreuses recherches FHIR.
- Trajectoire de croissance : partitionnement des tables par hachage de `id_patient` dès le départ ; si le débit d'écriture dépasse un jour ce qu'une base principale peut absorber, **partitionnement horizontal par `id_patient`** (par exemple Citus) — presque toutes les requêtes portent sur un seul patient, les fragments restent donc indépendants.
- Aucune donnée de santé dans des caches partagés ; le seul cache de données cliniques est le résumé critique, chiffré.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
FHIR R4 comme modèle interne (HAPI FHIR sur PostgreSQL)	Schéma relationnel sur mesure	Interopérabilité (services nationaux, hôpitaux), validation, versionnage et recherche intégrés ; recrutement et audit facilités. Coût : un stockage générique moins efficace → projections pour les écrans.
Historique en ajout seul + chaîne de hachage + ancrage	Mises à jour en place + table d'audit	L'intégrité est une priorité haute : l'historique ne peut pas être réécrit en silence, même par un administrateur. Coût : croissance du stockage (≈ +30 %), acceptable.
Bris de glace avec revue a posteriori	Approbation préalable par un superviseur	Chaque minute compte en urgence ; la dissuasion (audit, alertes, information du patient, revue, sanctions) contrôle les abus.
Clés de chiffrement par patient	Chiffrement de la base seulement	Une sauvegarde, une réplique ou un résultat de requête dérobés sont inutilisables sans le KMS ; effacement cryptographique en fin de conservation. Coût : gestion des clés et environ 1 ms par requête grâce au cache de clés.
Déploiement et base séparés pour l'accès d'urgence	Un point d'accès de l'API Dossier patient	Isolé de la charge et des pannes de l'API principale ; peut être actif dans deux régions. Coût : une unité de déploiement de plus.

2.5 ⑤ Service de gestion des ordonnances

Priorité	Zone	Criticité	Détient
Moyenne — M3 gestion des ordonnances	Clinique	Niveau 1	Ordonnances et leurs versions, signatures, résultats des contrôles de sécurité, statut de délivrance, demandes de renouvellement

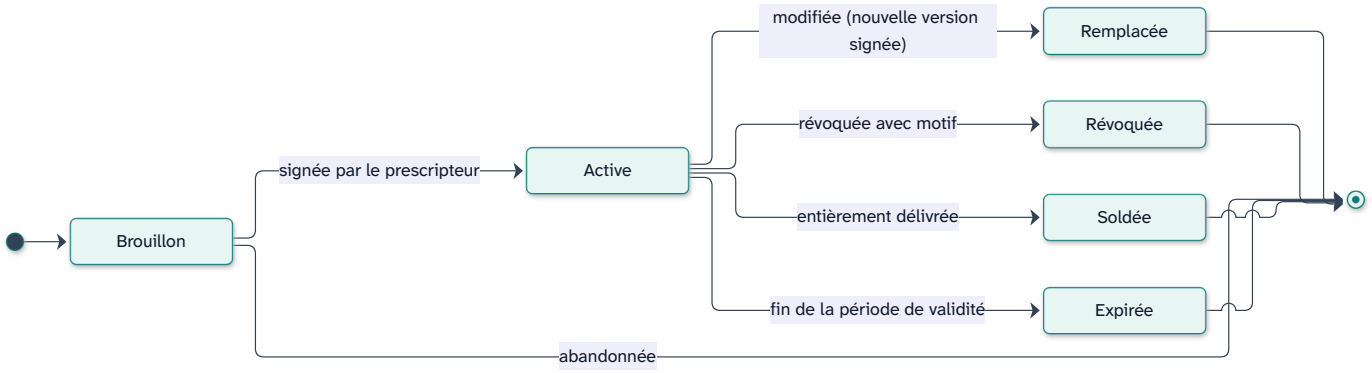
Mission — transformer la décision d'un médecin en une ordonnance électronique **sûre, signée et vérifiable**, qui arrive à la bonne pharmacie en quelques secondes, qui peut être corrigée ou révoquée instantanément, et dont le patient peut suivre l'avancement.

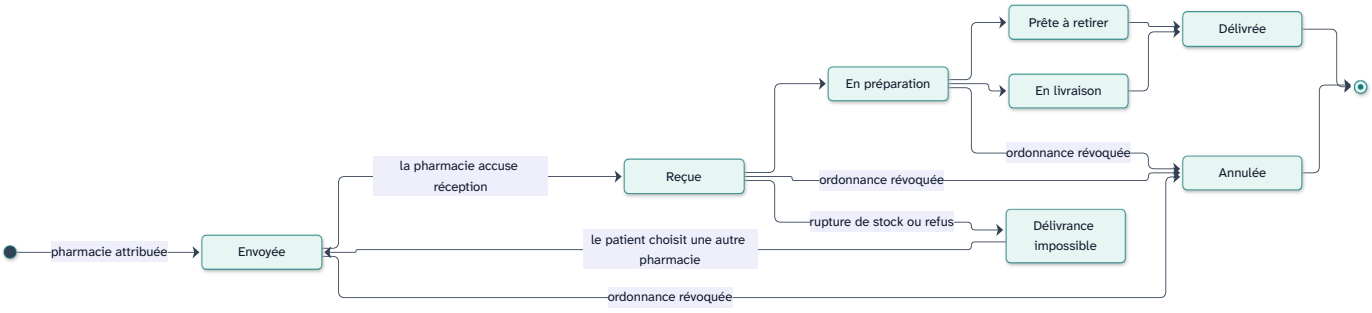
Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Permettre aux médecins de créer, modifier ou révoquer des ordonnances après la consultation	Brouillon rattaché à une rencontre → **contrôles de sécurité** automatiques → **signature électronique** (authentification renforcée) → active. Une modification crée une nouvelle version signée qui remplace la précédente ; une révocation est un changement de statut signé, avec motif.
Prévenir les pharmacies des nouvelles ordonnances ou des changements	Événements `OrdonnanceEmise / OrdonnanceModifiee / OrdonnanceRevoquee` → l'Interface pharmacie pousse vers la boîte de la pharmacie et vers le webhook du LGO ; les révocations sont **critiques** (plusieurs canaux, relances jusqu'à l'accusé de réception).
Permettre aux patients de voir leurs ordonnances actives	API et écran patient : ordonnances actives, renouvellements restants, dates de validité, PDF imprimable avec QR code.
Suivre le statut de délivrance	Machine à états de la délivrance alimentée par les mises à jour de la pharmacie ; chaque changement est visible par le patient et par le prescripteur.

Cycles de vie de l'ordonnance et de la délivrance

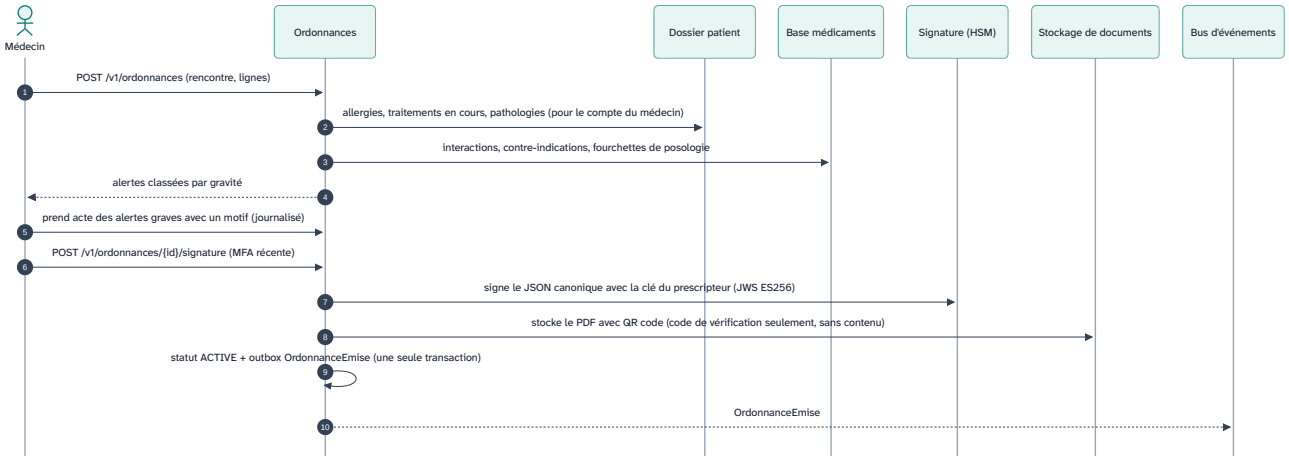
Le **statut légal** de l'ordonnance et le **statut de délivrance** en pharmacie sont deux machines à états distinctes — les confondre est une source d'erreurs classique (par exemple « prête à retirer » sur une ordonnance révoquée).





La délivrance partielle et les renouvellements sont suivis ligne par ligne (`quantite_delivree` , `renouvellements_restants`).

Créer et signer une ordonnance



- **Contrôles de sécurité (aide à la décision clinique)** : interactions médicamenteuses, allergies et allergies croisées, redondances thérapeutiques, contre-indications (grossesse, âge, fonction rénale quand elle est connue), posologie. L'appel au Dossier patient utilise l'**échange de jeton** (RFC 8693) : la requête est autorisée au nom du médecin, pas d'un service privilégié. Si un contrôle est indisponible, le médecin en est explicitement informé et doit en prendre acte avant de signer.
- **Signature** : l'ordonnance canonique (JSON RFC 8785) est signée avec la clé du prescripteur, conservée dans le HSM et utilisable seulement après une MFA récente ; alternativement, signature qualifiée d'un prestataire de confiance ou carte professionnelle (eIDAS). La version signée est **immuable**.
- **QR code / code de vérification** : permet à une pharmacie de vérifier l'authenticité et le **statut actuel** (non révoquée, pas déjà délivrée, non expirée) — il ne contient pas le contenu de l'ordonnance.

Modifier et révoquer

Action	Règles	Côté pharmacie
Modifier	Seulement si l'ordonnance n'est pas entièrement délivrée. Crée la version *n+1* (nouvelle signature), qui référence la version *n* ; celle-ci devient *remplacée* ; les quantités déjà délivrées restent valables.	`OrdonnanceModifiee` (priorité élevée) ; si la préparation a commencé, le pharmacien doit prendre acte du changement avant de continuer.
Révoquer	Motif obligatoire (erreur, effet indésirable, changement de traitement). Changement de statut signé.	`OrdonnanceRevoquee` (**critique**) : alerte sur le portail + webhook du LGO ; sans accusé de réception sous 15 min, relance par SMS ou téléphone vers la pharmacie. Si l'ordonnance est déjà délivrée, le prescripteur est alerté pour contacter le patient.
Renouveler	Le patient demande un renouvellement depuis l'application → tâche pour le prescripteur → nouvelle ordonnance liée à la précédente, ou refus avec un message.	Nouvel `OrdonnanceEmise` .

Les médicaments soumis à une réglementation particulière (stupéfiants) suivent des règles plus strictes, paramétrables selon le pays (exigences d'ordonnance sécurisée, durées maximales, pas de renouvellement à distance, contrôles d'identité supplémentaires en pharmacie).

API (sélection)

Méthode	Point d'accès	Rôle
`POST`	`/v1/ordonnances`	Créer un brouillon (rencontre, lignes)
`POST`	`/v1/ordonnances/{id}/controles`	Lancer / relancer les contrôles de sécurité
`POST`	`/v1/ordonnances/{id}/signature`	Signer (authentification renforcée) → active
`POST`	`/v1/ordonnances/{id}/versions`	Modifier → nouvelle version signée
`POST`	`/v1/ordonnances/{id}/revocation`	Révoquer avec motif
`PUT`	`/v1/ordonnances/{id}/pharmacie`	Le patient choisit ou change de pharmacie
`GET`	`/v1/patients/moi/ordonnances?statut=active`	Vue patient
`GET`	`/v1/ordonnances/{id}/delivrance`	Chronologie du statut de délivrance
`GET`	`/v1/ordonnances/verification?code=`	Vérification par la pharmacie (authenticité + statut)
`GET`	`/fhir/MedicationRequest?patient=`	Vue d'interopérabilité

Événements

- **Publie** `ordonnance.v1` : OrdonnanceEmise, OrdonnanceModifiee, OrdonnanceRevoquee, OrdonnanceExpiree, PharmacieAttribuee, StatutDelivranceModifie.
- **Consomme** `pharmacie.delivrance.v1` (accusés de réception et mises à jour de statut, idempotents grâce au numéro de séquence), `identite.utilisateur.v1` (un prescripteur suspendu ne peut plus signer ; ses ordonnances actives sont signalées pour revue).

Données détenues

PostgreSQL : `ordonnance`, `version_ordonnance` (signée, immuable), `ligne_ordonnance` (code du médicament, posologie structurée, quantité, renouvellements, substitution autorisée), `signature`, `historique_statut` (ajout seul), `delivrance`, `controle_securite` (alertes et dérogations motivées), `demande_renouvellement`, `outbox`. Les données de référence sur les médicaments sont une réplique en lecture seule, rafraîchie depuis la base médicaments (données publiques, pas des données de santé). Détail au §3.4.

Sécurité et confidentialité

- La signature exige une authentification forte récente ; les clés de signature ne quittent jamais le HSM.
- **Le strict nécessaire pour les pharmacies** : nom et date de naissance du patient, (numéro d'assuré quand il est requis), lignes de l'ordonnance, identité et signature du prescripteur — jamais de diagnostic ni de notes.
- Chaque lecture par une pharmacie est auditée ; le point de vérification est limité en débit pour empêcher l'énumération des codes.

Scalabilité et résilience

- 120 000 ordonnances par jour en année 3 (≈ 1,4/s en moyenne, ≈ 15/s en pointe) plus environ 5 mises à jour de statut chacune — une charge légère ; le service monte en charge horizontalement et la recherche de médicaments est en cache.
- La transmission des révocations est pensée pour la **sécurité, pas pour le débit** : outbox (aucun événement perdu), poussée + webhook + relances, et une tâche de rapprochement qui compare toutes les 5 minutes les statuts de l'ordonnance et ceux de la pharmacie.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
Modification = nouvelle version signée	Modification en place	Traçabilité légale : la pharmacie et l'auditeur voient toujours ce qui a été signé, quand, et ce qui l'a remplacé.
Statut légal et statut de délivrance séparés	Un seul champ de statut	Évite les états contradictoires ; chacun a un seul propriétaire (prescripteur d'un côté, pharmacie de l'autre).
Correspondance FHIR `MedicationRequest` / `MedicationDispense` / `Task`	Format propriétaire	Voie directe vers les services nationaux d'ordonnance électronique : là où un tel service existe (par exemple l'*ordonnance numérique* en France), un adaptateur y enregistre chaque ordonnance et le service national devient la référence pour la délivrance.
Contrôle des allergies via le Dossier patient au moment de la signature	Copie locale des allergies	Des données toujours à jour pour une décision de sécurité ; un échec est toujours explicite, jamais silencieux.

2.6 ⑥ Service d'interface pharmacie

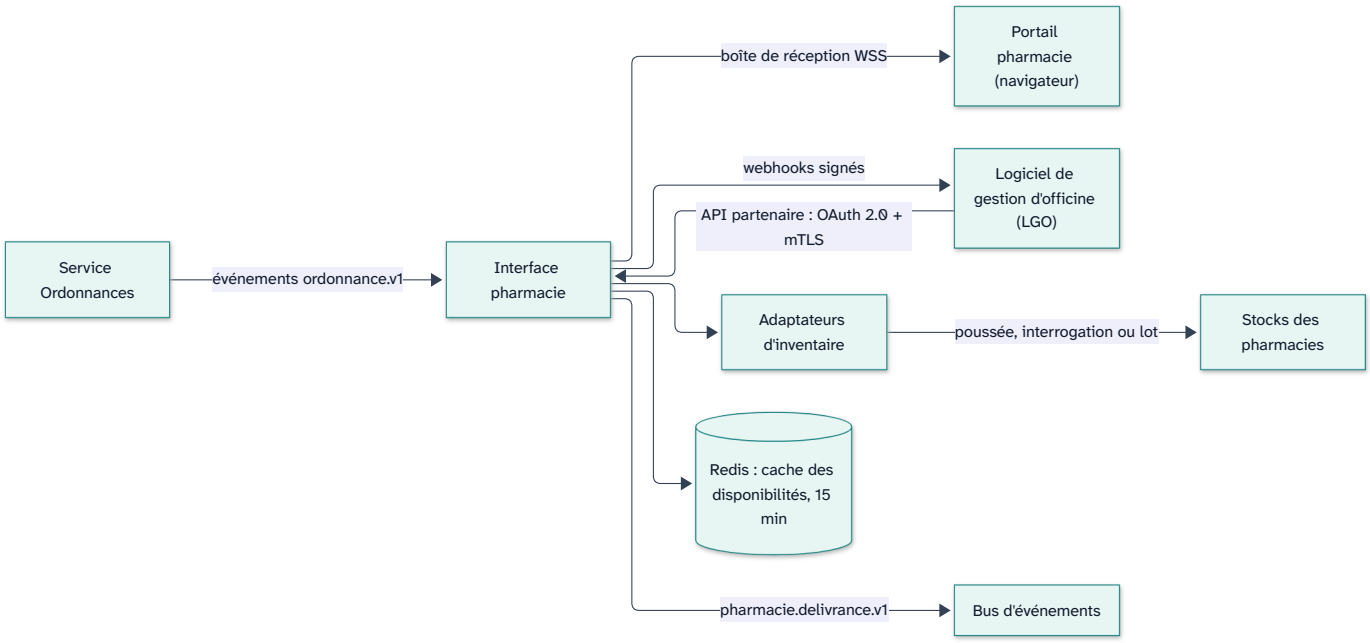
Priorité	Zone	Criticité	Détient
Basse — B1 interface pharmacie	Clinique (données d'ordonnance minimisées)	Niveau 2	Répertoire des pharmacies, intégrations, tâches de délivrance, échanges patient–pharmacie, cache des disponibilités en stock

Mission — relier chaque pharmacie aux ordonnances MedX, de l'officine indépendante équipée d'un simple navigateur au groupement doté de son propre logiciel de gestion d'officine (LGO) — de manière fiable et avec le minimum de données patient.

Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Accuser réception des ordonnances et mettre à jour leur statut (« Prête à retirer », « Expédiée »…)	**Boîte de réception** en temps réel (portail) ou **webhook + API partenaire** (LGO) ; accusé de réception avec suivi du délai ; mises à jour de statut validées par la machine à états de la délivrance, puis transmises au service Ordonnances.
Permettre les échanges entre patients et pharmacies	**Fils de discussion** sécurisés rattachés à une ordonnance (questions de disponibilité, propositions de substitution, horaires de retrait), avec notifications des deux côtés et modèles de messages.
S'intégrer aux systèmes de gestion des stocks	**Adaptateurs d'inventaire** par éditeur de LGO derrière une interface de disponibilité commune ; niveaux de disponibilité en cache ; fonction « trouver une pharmacie proche qui a mon médicament ».

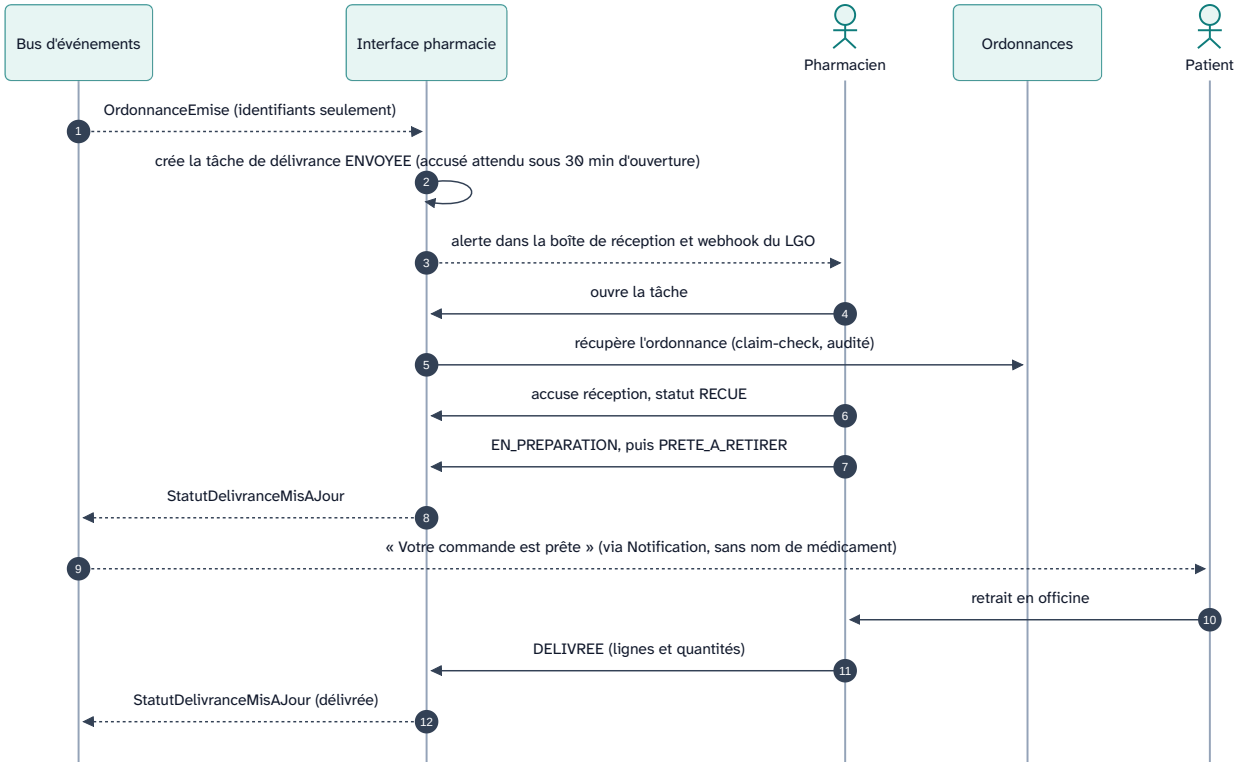
Modes d'intégration



Mode	Pour qui	Détails
Portail pharmacie	Toutes les pharmacies, sans intégration	Application web avec boîte de réception en temps réel, affichage et impression de l'ordonnance, lecture du QR code (webcam) pour la vérification, boutons de statut, échanges avec les patients.

Mode	Pour qui	Détails
API partenaire + webhooks	Pharmacies dont l'éditeur de LGO s'intègre	API REST et FHIR (`Task` , `MedicationDispense`); OAuth 2.0 *client credentials* avec jetons liés au certificat **mTLS**; webhooks sortants **signés (HMAC-SHA256 + horodatage)** avec protection contre le rejeu, nouvelles tentatives avec temporisation exponentielle pendant 24 h, puis file de lettres mortes et repli sur le portail.
Adaptateurs d'inventaire	Pharmacies qui partagent leurs données de stock	Interface commune `verifierDisponibilite(pharmacie, lignes)` qui renvoie EN_STOCK, FAIBLE, RUPTURE ou INCONNU; stratégies: poussée des variations de stock, interrogation en temps réel (délai de 2 à 3 s) ou lot nocturne, selon l'éditeur.

Flux de délivrance



- **Délivrance impossible** (rupture de stock, substitution refusée): le patient est prévenu et se voit proposer des pharmacies proches qui déclarent le médicament en stock; une nouvelle attribution relance le flux.
- **Ordonnances sans accusé de réception**: si le délai est dépassé, le patient est prévenu et peut choisir une autre pharmacie.
- **Les mises à jour de statut sont idempotentes**: chacune porte un numéro de séquence; les doublons et les nouvelles tentatives de webhook arrivées dans le désordre sont ignorés.

Minimisation des données

Une pharmacie ne voit que les ordonnances **qui lui sont attribuées** (ou présentées par le patient via le QR code), et seulement les champs nécessaires à la délivrance: nom et date de naissance du patient, numéro d'assuré quand il est requis, lignes de l'ordonnance, identité et signature du prescripteur. **Ni diagnostic, ni notes de consultation, ni accès au dossier.** Les données de stock sont présentées aux patients sous forme de niveaux de disponibilité, pas de quantités (confidentialité commerciale).

API (sélection)

Méthode	Point d'accès	Rôle
`GET`	`/v1/pharmacie/boite-reception?statut=`	Boîte de réception de la pharmacie
`POST`	`/v1/pharmacie/delivrances/{id}/accuse-reception`	Accuser réception
`POST`	`/v1/pharmacie/delivrances/{id}/statut`	Mettre à jour le statut (numéro de séquence, idempotent)
`POST`	`/v1/pharmacie/delivrances/{id}/delivrance`	Enregistrer les lignes et quantités délivrées
`GET`	`/v1/pharmacies/recherche?lat=&lon=&produit=`	Pharmacies proches avec disponibilité (patient)
`POST`	`/v1/echanges` · `/v1/echanges/{id}/messages`	Échange patient–pharmacie
`GET`	`/partenaire/fhir/Task?owner={pharmacie}&status=requested`	Mode interrogation du LGO
`POST`	`/partenaire/v1/delivrances/{id}/statut`	Envoi de statut par le LGO

Événements

- **Publie** `pharmacie.delivrance.v1` : ReceptionAccusee, StatutDelivranceMisAJour, DelivranceImpossible, MessagePharmaciePublie.
- **Consomme** `ordonnance.v1` : OrdonnanceEmise, OrdonnanceModifiee, OrdonnanceRevoquee, PharmacieAttribuee.

Données détenues

PostgreSQL : `pharmacie` (numéro FINESS, adresse, géolocalisation, horaires, services), `integration` (mode, point d'accès, références d'identifiants dans Vault), `tache_delivrance`, `evenement_statut` (ajout seul), `echange`, `message` (chiffré), `outbox`. Redis : cache des disponibilités. Recherche géographique avec PostGIS. Détail au §3.4.

Scalabilité et résilience

- 15 000 pharmacies, environ 600 000 mises à jour de statut par jour en année 3 (≈ 7/s) : charge légère ; les travailleurs d'envoi des webhooks montent en charge selon le retard de la file.
- Un LGO lent ou en panne ne bloque jamais MedX : les webhooks sont asynchrones, avec nouvelles tentatives et file de lettres mortes, et le portail reste toujours disponible en repli.
- Les requêtes d'inventaire sont mises en cache (15 min) et limitées dans le temps ; « inconnu » est une réponse acceptable.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
Portail **et** API	API seulement	Inclusion : les petites officines peuvent rejoindre MedX dès le premier jour ; les pharmacies intégrées bénéficient de l'automatisation. Coût : deux canaux à maintenir.
Un adaptateur par éditeur de LGO derrière une interface unique	Imposer un format à tous les éditeurs	Les éditeurs s'intègrent à leur rythme ; le cœur de MedX reste propre (couche anti-corruption).
Niveaux de disponibilité plutôt que quantités	Stock exact	Suffisant pour la décision du patient ; protège les données commerciales des pharmacies.

Décision	Alternative	Pourquoi ce choix
Priorité basse, livré après le cœur clinique	Livraison précoce	Respecte les priorités de MedX ; en attendant, l'ordonnance est imprimable avec un QR code vérifiable, utilisable dans n'importe quelle pharmacie.

2.7 ⑦ Service de notification

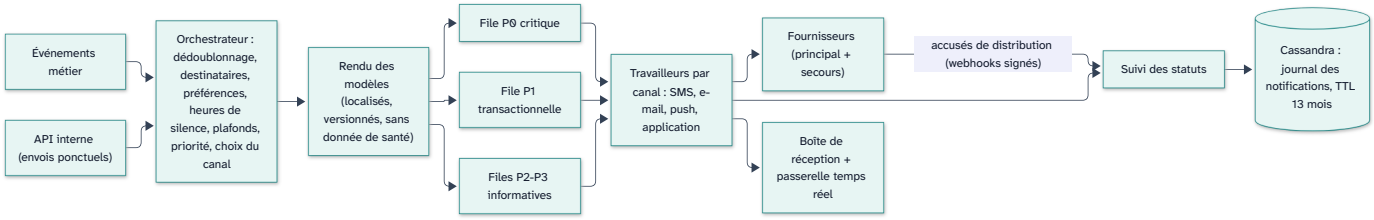
Priorité	Zone	Criticité	Détient
Basse — B2 préférences (appliquées) · B3 suivi de distribution et de lecture — **une version minimale est livrée avec les fonctionnalités de priorité moyenne** (confirmations de réservation, rappels)	Communication (aucune donnée de santé)	Niveau 2 (les messages critiques ont leur propre file)	Modèles, réplique locale des préférences, journal des notifications, statuts de distribution, boîte de réception dans l'application

Mission — dire la bonne chose à la bonne personne, sur le bon canal, au bon moment, **sans jamais mettre d'information de santé dans un SMS, un e-mail ou une bannière de notification**.

Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Envoyer alertes, rappels et mises à jour (SMS, e-mail, dans l'application)	Chaîne de traitement pilotée par les événements, avec des travailleurs par canal pour **SMS, e-mail, push (APNs/FCM) et dans l'application** (passerelle temps réel + boîte de réception) ; deux fournisseurs par canal externe, avec bascule automatique.
Gérer les préférences de notification (consentement, désinscription, fréquence)	Préférences détenues par la gestion des utilisateurs et répliquées localement à partir de `PreferencesMisesAJour` ; évaluées par catégorie × canal, avec heures de silence, plafonds de fréquence et résumés groupés.
Suivre la distribution et la lecture	Machine à états alimentée par les accusés des fournisseurs et les accusés de lecture des applications, stockée dans un journal en ajout seul ; gestion des rejets ; tableaux de bord de distribution.

Chaîne de traitement



Files de priorité

File	Exemples	Comportement	Objectif
P0 critique	Ordonnance révoquée (vers la pharmacie), consultation urgente attribuée (vers un médecin), alerte de bris de glace (vers le DPO)	Ignore les heures de silence ; plusieurs canaux en parallèle ; escalade si non lue (par exemple SMS après 5 min, puis téléphone)	envoi < 10 s
P1 transactionnelle	Confirmation ou modification de réservation, rappels, « traitement prêt », reçu de paiement	Catégorie obligatoire (le canal peut être choisi, pas désactivé)	envoi < 60 s
P2 informative	Nouveau document ou nouveau message disponible	Entièrement pilotée par les préférences ; résumé groupé possible	< 5 min
P3 marketing	Lettre d'information, enquêtes	**Consentement explicite uniquement** (RGPD / ePrivacy), plafonds de fréquence	par lots

Chaque file a son propre topic Kafka et son propre groupe de travailleurs : une rafale de rappels ne peut jamais retarder une alerte de révocation.

Contenus sans données de santé

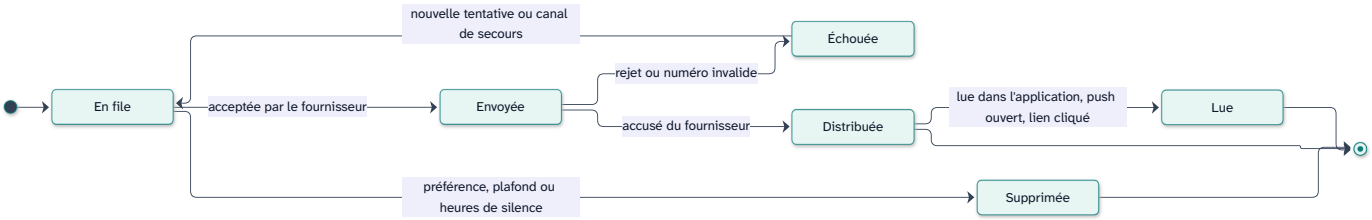
Canal	Exemple de ce que MedX envoie	Ce qu'il ne contient jamais
SMS	« MedX : votre téléconsultation a lieu demain à 10 h 30. Rejoignez-la depuis l'application. »	Nom ou spécialité du médecin, motif, noms de médicaments, résultats
E-mail	Objet générique, lien profond vers l'application, authentification de l'expéditeur (SPF, DKIM, DMARC)	Pièces jointes contenant des données de santé (factures et documents se téléchargent dans l'application)
Push	« Vous avez un nouveau message »	Le contenu du message sur l'écran verrouillé
Dans l'application	Tout le détail, après authentification	—

Les modèles ne peuvent utiliser que des **variables en liste blanche** ; un contrôle en CI rejette tout modèle qui fait référence à un champ clinique.

Préférences

- Détenues et modifiées dans la gestion des utilisateurs (source unique de vérité) ; répliquées ici via les événements `PreferencesMisesAJour` dans une table locale et un cache Redis → aucune dépendance synchrone au moment de l'envoi.
- Évaluées par **catégorie × canal** (rendez-vous, ordonnances, documents, messages, marketing), avec heures de silence dans le fuseau horaire de l'utilisateur, plafonds de fréquence (par exemple 3 SMS non critiques par jour au plus) et résumés quotidiens.
- Les notifications obligatoires (sécurité, légal, P0/P1) ne peuvent pas être entièrement désactivées, seulement redirigées vers un autre canal.

Suivi de distribution et de lecture (B3)



- Les événements de statut sont ajoutés (jamais modifiés en place), avec les références du fournisseur et les horodatages.
- **Aucun pixel de suivi dans les e-mails** (confidentialité) : « lu » signifie pour un e-mail qu'un lien a été cliqué ou que l'élément a été ouvert dans l'application.
- Les rejets définitifs marquent la coordonnée comme invalide et émettent `CoordonneeInvalide` pour que l'utilisateur soit invité à la corriger.
- Tableaux de bord : taux de distribution par canal et par fournisseur, latence par file ; alerte quand un fournisseur se dégrade (bascule automatique vers le second fournisseur).

Fiabilité

- **Idempotence** : clé de dédoublonnage = identifiant de l'événement + destinataire + canal (Redis, 24 h) — un rejeu ne provoque jamais de double envoi.

- Nouvelles tentatives avec temporisation exponentielle et gigue, bascule entre fournisseurs, file de lettres mortes avec rejeu par un opérateur.
- Les lots de rappels (par exemple tous les rendez-vous de 9 h) sont étalés avec de la gigue sur la fenêtre d'envoi.

API (sélection)

Méthode	Point d'accès	Rôle
`POST`	`/v1/notifications`	Envoi ponctuel interne (de service à service uniquement)
`GET`	`/v1/utilisateurs/moi/notifications?curseur=`	Boîte de réception dans l'application
`POST`	`/v1/utilisateurs/moi/notifications/{id}/lecture`	Accusé de lecture
`POST`	`/v1/webhooks/fournisseurs/{fournisseur}`	Accusés de distribution (signature vérifiée)
`GET`	`/v1/admin/notifications/indicateurs`	Statistiques de distribution (agrégées, sans contenu)

Événements

- **Consomme** presque tous les topics métier (voir le catalogue des événements) et `identite.preferences.v1`.
- **Publie** `notification.distribution.v1` : NotificationEnvoyee, NotificationDistribuee, NotificationLue, NotificationEchouee, CoordonneeInvalide.

Données détenues

PostgreSQL : `modele` (versionné, par langue), `replique_preferences`, `config_fournisseur`. Cassandra : `notification_par_destinataire` (partition = destinataire + mois), `evenement_statut_notification`, TTL de 13 mois. Redis : clés de dédoublonnage, compteurs de fréquence, limites de débit. Détail au §3.4.

Scalabilité et résilience

- 2 M de notifications par jour en année 3 (≈ 25/s en moyenne, **≈ 500/s lors des pointes de rappels**) : Kafka absorbe les rafales ; les travailleurs montent en charge selon le retard de chaque file ; les fournisseurs sont limités en débit par compte.
- Cassandra absorbe linéairement ce journal très sollicité en écriture (≈ 4 événements de statut par notification), avec une expiration par TTL plutôt que des suppressions coûteuses.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
Messages externes génériques, sans donnée de santé	Messages riches (« votre rendez-vous de dermatologie… »)	Les SMS et les e-mails ne sont ni privés ni dans le périmètre HDS ; le confort est préservé par des liens profonds vers l'application authentifiée.
Base orientée colonnes (Cassandra) pour le journal	PostgreSQL	Série temporelle très sollicitée en écriture, interrogée par destinataire, avec expiration par TTL : un usage naturel ; PostgreSQL reste utilisé pour les modèles et les préférences.
Construire l'orchestrateur, acheter les canaux	Un SaaS de notification pour tout	Les règles de préférences, de données de santé et de priorité sont propres à MedX et sensibles ; l'acheminement des messages est une commodité.

Décision	Alternative	Pourquoi ce choix
Une file par priorité	Une seule file	Garantit que les messages de sécurité critiques ne sont jamais bloqués derrière des rappels en masse.

2.8 ⑧ Service de facturation et paiement

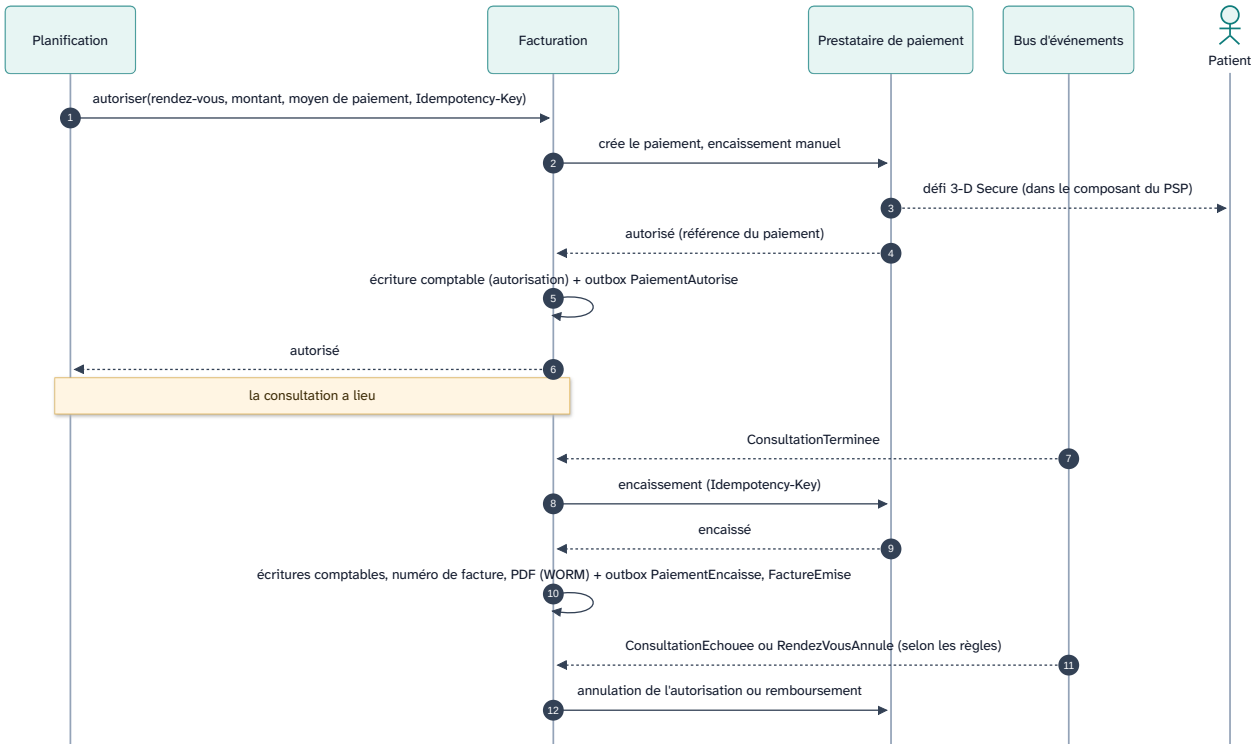
Priorité	Zone	Criticité	Détient
Basse — B5 paiement sécurisé · B6 remboursements	Paiement (périmètre PCI réduit au minimum)	Niveau 2	Tarifs, paiements (références PSP), grand livre en partie double, factures et avoirs, remboursements, versements

Mission — facturer le bon montant au bon moment, ne jamais toucher un numéro de carte, tenir une comptabilité qui se rapproche au centime près, et rembourser vite et de manière traçable quand quelque chose se passe mal.

Responsabilités

Fonctionnalité de l'Annexe 1	Comment MedX la réalise
Gérer les honoraires de consultation et traiter les paiements	Tarif par praticien et par type de consultation ; **pré-autorisation à la réservation, encaissement après la consultation** ; règles d'annulation ; reversements aux praticiens et aux pharmacies via le PSP (modèle de place de marché).
Émettre les factures des consultations et des médicaments	Facture émise à l'encaissement (au nom du praticien ou de la pharmacie) : numérotation continue par émetteur, PDF immuable stocké en WORM, **aucun détail clinique** sur la facture.
Traiter les remboursements si nécessaire	Automatiques (le médecin annule, la consultation a échoué techniquement) ou manuels (support sous un seuil, double validation au-delà) ; avoirs ; trace complète dans le grand livre.
Fournir des mécanismes de transaction sécurisés	**Champs de paiement hébergés par le PSP** (les données de carte n'atteignent jamais MedX) → PCI DSS **SAQ A** ; 3-D Secure 2 (authentification forte DSP2) ; moyens de paiement tokenisés ; webhooks signés ; idempotence partout.

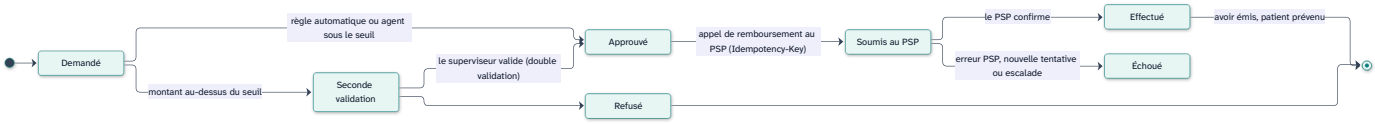
Cycle de vie d'un paiement



- **Expiration des autorisations** — une autorisation de carte expire au bout d'environ 7 jours : pour un rendez-vous réservé plus tôt que cela, la carte est enregistrée avec authentification forte (*setup intent*) et l'autorisation est demandée automatiquement 24 h avant.

- **Règles d'annulation** — gratuite jusqu'à 24 h avant ; frais d'annulation tardive ou d'absence annoncés à la réservation ; **annulation par le médecin ou échec technique → libération / remboursement intégral automatique**.
- **Médicaments** — quand une pharmacie propose la livraison ou le retrait avec paiement en ligne, la commande est payée par le même flux ; la facture est émise au nom de la pharmacie.
- **Reversements** — les comptes de place de marché du PSP répartissent chaque paiement entre le praticien ou la pharmacie et la commission de MedX ; le PSP vérifie l'identité des bénéficiaires (KYC).

Remboursements (B6)



Grand livre et rapprochement

- **Grand livre en partie double, en ajout seul** : chaque mouvement d'argent est une écriture équilibrée (créance patient, dette envers le praticien ou la pharmacie, chiffre d'affaires MedX, compte d'attente PSP, remboursements). Les écritures ne sont jamais modifiées — une correction est une nouvelle écriture.
- **Idempotence** : chaque appel au PSP porte une clé d'idempotence ; chaque webhook du PSP est dédoublonné par identifiant d'événement et son contenu brut est conservé pour l'audit.
- **Rapprochement quotidien** avec le relevé de règlement du PSP ; tout écart ouvre un incident.
- Les **factures** sont immuables ; un remboursement produit un **avoir**, jamais une facture modifiée. Conservation 10 ans (droit commercial), stockage WORM.

Réduction du périmètre PCI DSS

Mesure	Effet
Champs hébergés / composants intégrés du PSP (iframes) dans les applications	Les numéros de carte vont directement de l'appareil au PSP ; MedX ne stocke que des jetons, la marque et les 4 derniers chiffres.
Intégrité des scripts de la page de paiement (CSP, SRI, détection des changements — exigences PCI DSS v4 6.4.3 et 11.6.1)	Protège la page qui intègre le composant du PSP contre l'injection de scripts (*e-skimming*).
Clés d'API PSP restreintes dans Vault, renouvelées	Une clé divulguée ne permet ni de lire des données de carte ni de déplacer des fonds au-delà de ses droits.
Espace de noms paiement isolé par politique réseau	Seuls la Planification, la passerelle (webhooks) et le bus d'événements peuvent joindre la Facturation.
Aucune donnée de santé dans la facturation	Les factures indiquent « Téléconsultation », jamais une spécialité ni un diagnostic.

API (sélection)

Méthode	Point d'accès	Rôle
`POST`	`/v1/moyens-paiement/preparation`	Renvoie un secret client PSP pour les champs hébergés
`POST`	`/v1/paiements/autorisations`	Interne (Planification) : autoriser des honoraires
`POST`	`/v1/paiements/{id}/encaissement`	Interne : encaisser après la consultation

Méthode	Point d'accès	Rôle
`POST`	`/v1/remboursements`	Demander un remboursement (règles automatiques, agent de support)
`POST`	`/v1/remboursements/{id}/validation`	Seconde validation au-delà du seuil
`GET`	`/v1/utilisateurs/moi/factures` · `/v1/factures/{id}/pdf`	Factures du patient
`POST`	`/v1/webhooks/psp`	Événements du PSP (signature vérifiée, dédoublonnés)

Événements

- **Publie** `facturation.paiement.v1` : PaiementAutorise, PaiementEchoue, PaiementEncaisse, PaiementAnnule, RemboursementEffectue, RemboursementEchoue, FactureEmise.
- **Consomme** `consultation.seance.v1` (encaissement ou remboursement), `planification.rendez-vous.v1` (annulations, absences), `pharmacie.delivrance.v1` (commandes de médicaments payées).

Données détenues

PostgreSQL : `client` (référence client PSP), `moyen_paiement` (jeton, marque, 4 derniers chiffres), `paiement`, `compte_comptable`, `ecriture` + `ligne_ecriture` (ajout seul), `facture` + `ligne_facture`, `avoir`, `remboursement`, `evenement_psp` (brut, dédoublonnage), `versement`, `outbox`. Montants stockés en **entiers dans l'unité mineure + devise ISO 4217**. PDF des factures dans le stockage de documents (WORM). Détail au §3.4.

Scalabilité et résilience

- ≈ 200 000 paiements par jour en année 3 (≈ 2 à 3/s) : le débit n'est pas le défi, **l'exactitude** l'est — d'où l'idempotence, l'outbox, le grand livre et le rapprochement.
- Si le PSP est indisponible, les réservations peuvent se poursuivre en mode « payer plus tard » (paramétrable selon le risque), encaissées au retour du PSP ; aucune demande n'est perdue grâce à l'outbox et aux nouvelles tentatives.

Décisions de conception et compromis

Décision	Alternative	Pourquoi ce choix
Champs de paiement hébergés par le PSP (SAQ A)	Manipuler les données de carte (SAQ D)	Supprime le périmètre de conformité le plus lourd et la cible la plus attractive. Coût : moins de maîtrise de l'interface de paiement.
Grand livre en partie double propre à MedX	S'en remettre au tableau de bord du PSP	L'auditabilité, la répartition place de marché, les remboursements et le rapprochement exigent une comptabilité propre à MedX.
Pré-autoriser puis encaisser	Débiter à la réservation	Le patient ne paie que les consultations qui ont eu lieu ; moins de remboursements. Coût : gestion de l'expiration des autorisations.
Priorité basse, mais sécurité dès la conception	Reporter la sécurité avec la fonctionnalité	Le paiement est livré en dernier, mais sa conception écarte déjà les données de carte de MedX.

2.9 Composants de plateforme

Des capacités partagées utilisées par tous les services métier. Plusieurs d'entre elles portent des exigences de **priorité haute** (H1 chiffrement, H4 autorisations, H5 intégrité et stockage sécurisé des fichiers) : elles sont donc construites une seule fois, par l'équipe plateforme, et réutilisées partout.

Composant	Priorité servie	Niveau
Passerelle API et périmètre d'entrée	H1, H4	0
Passerelle temps réel	M2	1
Point de décision de politique (OPA)	H4, M4	0
Bus d'événements (Kafka) et outbox	H5	1
Stockage sécurisé de documents	H1, H5	1
Piste d'audit	H2, H3, H5	1 (écritures tamponnées dans les outbox)
Clés et secrets	H1	0
Observabilité et supervision de sécurité	toutes	1
Plateforme de données désidentifiées	B4	2

Passerelle API et périmètre d'entrée

- Le **CDN** ne sert que des ressources statiques (paquets des applications, images) ; les réponses d'API qui contiennent des données personnelles portent `Cache-Control: no-store` et ne sont jamais mises en cache en bordure.
- **WAF** avec les règles OWASP de base, gestion des robots, réputation géographique et IP, correctifs virtuels ; **protection DDoS** des couches 3 à 7.
- **Passerelle API** (fondée sur Envoy) : terminaison TLS 1.3 (HSTS), routage par public (`/patient` , `/praticien` , `/pharmacie` , `/partenaire` ; `/admin` n'est **pas exposé publiquement** — joignable seulement via le proxy d'accès zéro confiance), validation des JWT de trois émetteurs (realms) avec JWKS en cache, validation des preuves DPoP, mTLS pour les partenaires, **limites de débit et quotas** par utilisateur, par IP et par client (plus strictes sur la connexion, la recherche et la vérification), limites de taille des requêtes, validation par schéma OpenAPI, CORS, en-têtes de sécurité, identifiants de corrélation, réception des webhooks par fournisseur avec vérification de signature.
- Les journaux d'accès ne contiennent que des métadonnées (route, code de statut, latence, sujet pseudonyme) — jamais de corps de requête ni de paramètres contenant des données personnelles.

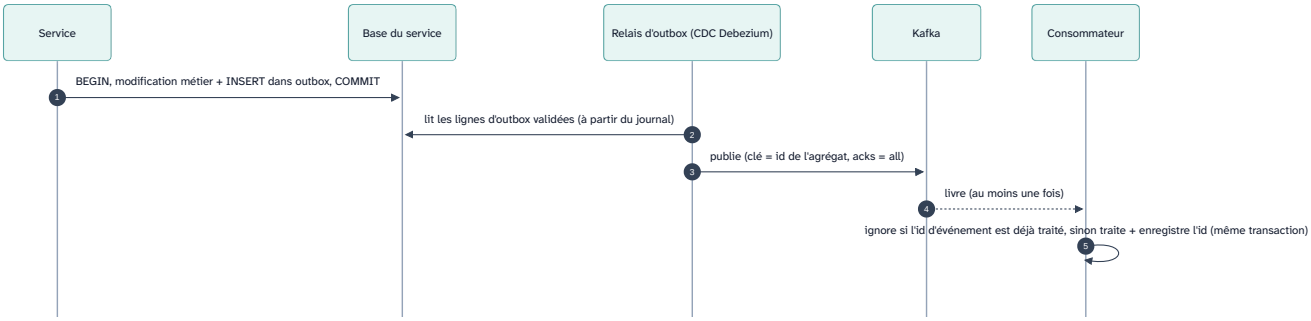
Passerelle temps réel

- Connexions WebSocket (WSS) pour le chat, la présence, les statuts en direct et les notifications dans l'application — **une connexion par application**, qui multiplexe les canaux.
- Authentification à la connexion (jeton d'accès) ; chaque abonnement à un canal (`utilisateur:{id}` , `consultation:{id}` , `pharmacie:{id}`) est autorisé par le service propriétaire ; les connexions sont revalidées au renouvellement du jeton et fermées en cas de révocation.
- Diffusion sans état via Redis pub/sub (ou NATS) : n'importe quel nœud peut livrer à n'importe quel utilisateur ; battements de cœur, jetons de reprise après reconnexion, vidage des connexions lors des déploiements.
- Dimensionnement : 200 000 connexions simultanées en pointe en année 3 ≈ 10 pods d'environ 25 000 connexions chacun, mis à l'échelle selon le nombre de connexions.

Point de décision de politique (OPA)

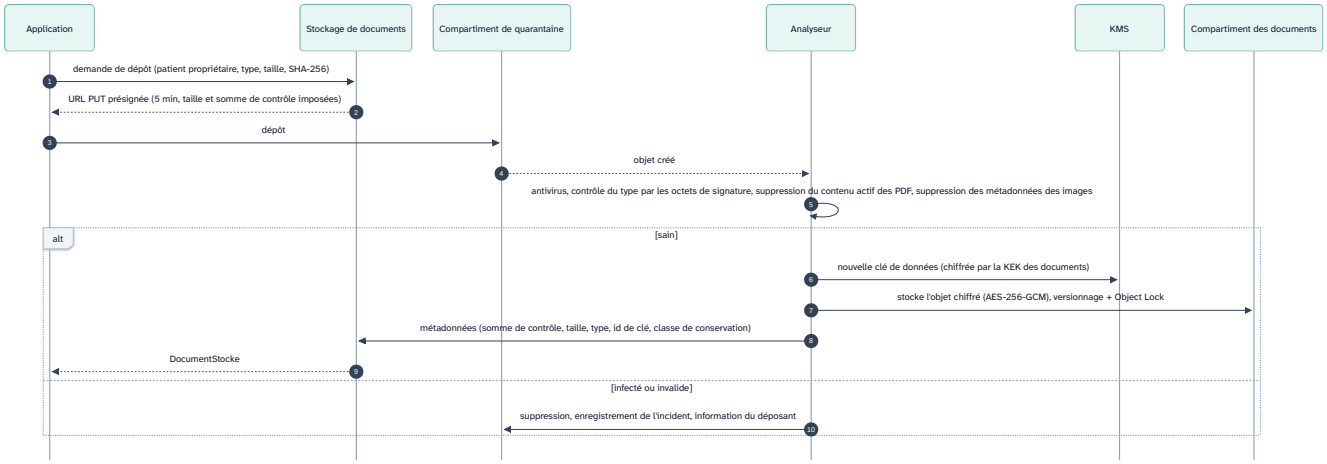
- **Sidecar** à côté de chaque service : décision en moins de 1 ms, sans aller-retour réseau, et qui continue de fonctionner si le serveur de politiques est indisponible.
- Politiques écrites en Rego, conservées dans Git, relues, **testées unitairement en CI** (cas positifs et négatifs pour chaque règle), compilées en **paquets signés** distribués aux sidecars (récupérés toutes les 60 s, dernier paquet valide conservé).
- Entrées : sujet (issu du jeton validé), action, ressource (type, patient propriétaire, labels de sécurité), finalité, et **faits** propres à la requête lus par le service (autorisation de soin, consentement, autorisation d'urgence).
- Sorties : `allow` + **obligations** (masquage, exclusions, niveau d'audit).
- Les journaux de décision (sans donnée de santé) alimentent la chaîne d'audit pour les investigations.

Bus d'événements (Kafka) et outbox



- **Pas de double écriture** : un événement existe si et seulement si la modification métier a été validée.
- Kafka : 3 brokers sur 3 AZ, facteur de réplication 3, `min.insync.replicas = 2`, `acks = all`, producteurs idempotents ; TLS + authentification SASL/mTLS, **ACL par service** (un service ne peut produire que sur ses propres topics et ne consommer que ce dont il a besoin), chiffrement au repos.
- Registre de schémas avec contrôle de compatibilité en CI ; un changement incompatible = une nouvelle version de topic.
- Rétention de 7 jours (30 jours pour `audit.evenements.v1`) ; topic de lettres mortes par groupe de consommateurs, avec alerte et rejeu.

Stockage sécurisé de documents



- **Double chiffrement** : chiffrement applicatif AES-256-GCM avec une clé de données par fichier (chiffrée par la KEK des documents et rattachée au patient propriétaire pour l'effacement cryptographique) **plus** chiffrement SSE-KMS au niveau du compartiment.
- **Intégrité** : SHA-256 calculé par le client, vérifié au dépôt, revérifié à chaque téléchargement et par une tâche hebdomadaire de contrôle ; versionnage des objets ; **Object Lock** (mode conformité) pour les documents soumis à une durée légale de conservation.
- **Accès** : les téléchargements passent par le stockage de documents, qui demande à la politique du service propriétaire (Dossier patient, Consultation, Facturation) si l'appelant peut lire ce document ; déchiffrement en flux ; chaque téléchargement est audité. Les objets en quarantaine sont supprimés au plus tard au bout de 24 h.
- **Limites** : 50 Mo par fichier ; types autorisés PDF, JPEG, PNG, HEIC (l'imagerie DICOM est hors périmètre de la v1).
- **Durabilité** : durabilité du stockage objet de 11 neuf + réplication entre régions + copie de sauvegarde immuable.

Piste d'audit

- **Ce qui est audité** : chaque lecture, création, modification, export, partage, bris de glace, événement d'authentification et action d'administration portant sur des données personnelles. Schéma aligné sur `AuditEvent` FHIR / IHE BALP : qui (sujet, rôle, organisation, niveau d'assurance, appareil, IP), quoi (action, type et id de ressource, patient), quand, pourquoi (**finalité** : soins, soins d'urgence, demande du patient, paiement, exploitation, support), résultat, identifiant de corrélation.
- **Chaîne** : les services écrivent les événements d'audit dans **leur outbox, dans la même transaction** que l'accès → Kafka `audit.evenements.v1` (ACL restreinte) → service d'audit → (1) **archive WORM** : lots chaînés par hachage, racine de Merkle signée par une clé HSM et horodatée chaque jour, stockés avec Object Lock dans le **compte de sécurité** ; (2) **index de recherche** (OpenSearch restreint, 13 mois) pour les investigations et pour la page « qui a consulté mon dossier » du patient ; (3) flux vers le **SIEM** pour les règles en temps réel.
- **Qui peut la lire** : le DPO et les auditeurs (lecture seule, eux-mêmes audités) ; les patients voient l'historique des accès à leur dossier ; aucun ingénieur ne peut modifier ou supprimer des données d'audit.
- **Conservation** : au moins 6 ans, paramétrable jusqu'à la durée de conservation du dossier médical.

Clés et secrets

- **KMS adossé à des HSM** (FIPS 140-3 niveau 3) : clés de chiffrement de clés par service × environnement × classe de données ; usage restreint par politique IAM (le rôle de la Facturation ne peut pas déchiffrer avec les clés du Dossier patient) ; rotation annuelle automatique ; clés multirégions pour la reprise ; chaque usage journalisé.
- **Chiffrement d'enveloppe** dans les services (voir le §5.6) : clés de données par patient / par fichier / par consultation, gardées déchiffrées en mémoire 5 min au plus.
- **HashiCorp Vault** : identifiants de base de données dynamiques (durée de vie 1 h), moteur Transit pour chiffrer les secrets d'intégration (jetons OAuth des agendas, identifiants des LGO), PKI pour les certificats internes, secrets injectés à l'exécution — **aucun secret dans le code, les images ou des variables d'environnement en clair** ; séparation des tâches entre gardiens des clés et administrateurs de données.

Observabilité et supervision de sécurité

- **OpenTelemetry** partout : traces (`traceparent` W3C propagé dans les en-têtes HTTP et Kafka), métriques (RED pour les services, USE pour les ressources), journaux structurés. Outils : Prometheus/Grafana, Loki,

Tempo.

- **Jamais de donnée de santé dans la télémétrie** : champs des journaux en liste blanche, identifiants tokenisés, corps de requête jamais journalisés ; un analyseur échantillonne les journaux à la recherche de motifs de données de santé et alerte.
- **SLO et budgets d'erreur** par niveau de criticité ; alertes multi-fenêtres sur la vitesse de consommation du budget ; **sondes synthétiques** qui appellent le chemin d'urgence chaque minute depuis les deux régions.
- Règles de corrélation du **SIEM** : bris de glace, lectures massives de dossiers, tentatives d'accès sans relation de soin, voyages impossibles, MFA désactivée, élévation de privilèges, exports anormaux ; **analyse comportementale des utilisateurs et des entités (UEBA)** pour détecter les « curieux internes » (par exemple un médecin qui ouvre les dossiers de patients sans rendez-vous, ou celui d'une célébrité).

Plateforme de données désidentifiées

- Usages : analytique produit, planification de capacité, indicateurs de qualité, recherche (avec consentement), et **jeux de données pour la recette, la démonstration et les tests** (B4).
- Capture des changements depuis les répliques des services vers une **enclave de traitement sécurisée** dans le compte de production, où tournent les tâches de pseudonymisation et d'anonymisation ; seules les sorties désidentifiées quittent l'enclave (fichiers en colonnes interrogés par un moteur analytique).
- Techniques et contrôles décrits au §5.7 : suppression des identifiants directs, pseudonymes à clé, généralisation, décalage des dates, contrôles de k-anonymat, validation du DPO.
- La recette et la démonstration utilisent des **patients synthétiques** (par exemple générés avec Synthea au format FHIR) — jamais de vraies données de santé.

3. Modèle de données et stratégie de stockage

Livrable 3. Analyse synthétique du modèle de données et du stockage retenu pour chaque composant. Le comportement des composants est décrit dans le document 2 — Conception détaillée des composants.

3.1 Principes

1. **Une base par service.** Chaque service possède son schéma, ses identifiants de connexion et ses migrations ; aucun autre service ne lit ses tables. Les références entre services sont **uniquement des identifiants** (UUIDv7), résolus via les API ou les événements.
2. **PostgreSQL par défaut.** Transactions, contraintes, JSONB, réplication et restauration à un instant donné éprouvées, offre managée multi-AZ dans le périmètre HDS, et compétences faciles à recruter. Une base spécialisée n'est ajoutée que si elle résout un problème que PostgreSQL traite mal (§3.3).
3. **Classer avant de stocker.** Chaque champ appartient à une classe de données (§3.2) qui décide de son chiffrement, de son masquage, de sa journalisation et de sa durée de conservation.
4. **Ajout seul pour tout ce qui est clinique, légal ou financier.** Dossiers, ordonnances, statuts de délivrance, grand livre et audit ne sont jamais modifiés en place — un changement est une nouvelle version ou une nouvelle écriture.
5. **Les données dérivées sont jetables.** Caches, index de recherche et projections peuvent être reconstruits à partir des systèmes de référence ; ils ne sont jamais l'unique copie de quoi que ce soit.
6. **Chaque base est chiffrée, privée, sauvegardée, supervisée et soumise à une règle de conservation** — sans exception.

Convention de nommage — suivant le langage du domaine (DDD), les tables, colonnes, événements et API portent des noms français en `snake_case` sans accents ; les noms normalisés (ressources FHIR comme `Patient` ou `MedicationRequest`, types SQL, champs CloudEvents) restent inchangés.

3.2 Classification des données

Classe	Définition	Exemples	Contrôles obligatoires
C4 — Données de santé sensibles	Contenu clinique, catégories sensibles, identifiant national de santé	Notes, diagnostics, résultats, documents, contenu du chat, santé mentale ou sexuelle, génétique, INS	Zone clinique uniquement · chiffrement applicatif par patient + chiffrement du stockage · ABAC avec finalité · jamais en cache (sauf le résumé d'urgence chiffré) · jamais dans les journaux, les événements, les index de recherche ni hors production
C3 — Données personnelles liées à la santé	Données révélant qu'une personne est prise en charge	Rendez-vous, liens médecin–patient, ordonnances, statuts de délivrance	Zone clinique · chiffrement du stockage, champs sensibles chiffrés · minimisées pour les pharmacies · accès audités
C2 — Données personnelles	Données d'identité et de contact sans information de santé	Nom, e-mail, téléphone, adresse, préférences, factures	Chiffrement au niveau du champ pour les coordonnées · masquage pour le support · droits RGPD appliqués
C1 — Interne	Opérationnel, non personnel	Configuration, métriques, télémétrie pseudonyme	Contrôle d'accès, chiffrement standard
C0 — Public	Destiné à être publié	Profils publics des médecins, données de référence des médicaments, contenus statiques	Contrôles d'intégrité

3.3 Choix des technologies de stockage

Technologie	Rôle chez MedX	Retenue parce que	Volontairement pas utilisée pour
PostgreSQL (managé, multi-AZ, réplique synchrone, répliques de lecture, réplique entre régions)	Système de référence des huit services, entrepôt FHIR, autorisations d'urgence, métadonnées des documents	ACID, contraintes riches (par exemple la contrainte d'exclusion contre les doubles réservations), JSONB pour les ressources FHIR, sécurité au niveau des lignes, restauration à un instant donné, haute disponibilité éprouvée	Les journaux très volumineux en ajout seul avec expiration (historique récent du chat, journal des notifications)
Redis / Valkey (cluster, répliques dans 3 AZ, TLS, chiffrement au repos)	Blocages de créneaux, cache des disponibilités, sessions et liste de refus des jetons, limites de débit, clés d'idempotence, présence, pub/sub	Latence inférieure à la milliseconde, `SET NX` atomique, TTL, pub/sub	Toute source de vérité (tout ce qui est dans Redis peut être reconstruit)
Cassandra (RF 3 sur 3 AZ, TLS, chiffrement au repos)	Historique récent du chat de consultation (30 jours), journal des notifications (13 mois)	Scalabilité linéaire en écriture, partitions ordonnées dans le temps, TTL natif, réplication multi-datacenter	L'intégrité relationnelle, les requêtes ad hoc, le stockage clinique de long terme
Stockage objet (compatible S3 : versionnage, Object Lock, SSE-KMS, réplication entre régions)	Documents médicaux, transcriptions de chat, PDF d'ordonnances, factures, archive d'audit, sauvegardes	Durabilité de 11 neuf, conservation WORM, niveaux de stockage, faible coût pour 150 To	Les petits enregistrements structurés
OpenSearch (privé, chiffré, contrôle d'accès fin)	Annuaire des médecins, recherche dans le catalogue des médicaments, index d'investigation d'audit (restreint)	Plein texte, facettes, requêtes géographiques, agrégations rapides	Le stockage de contenu clinique (ce **n'est pas** une base de données de santé)
Kafka (3 brokers, RF 3)	Journal d'événements, 7 jours (30 jours pour l'audit)	Durable, ordonné par clé, rejouable	Le stockage de long terme
Stockage analytique en colonnes (fichiers Parquet + moteur de requêtes)	Analytique sur données désidentifiées	Parcours peu coûteux de gros volumes	Les données identifiantes

Alternatives étudiées — une base orientée documents pour le JSON FHIR (le JSONB de PostgreSQL offre la même souplesse avec des transactions entre ressources et une technologie de moins à sécuriser) ; une base de type registre immuable pour l'audit (des lots chaînés par hachage sur un stockage objet WORM apportent la preuve d'intégrité sans produit de niche) ; des bases clé-valeur propriétaires d'un fournisseur (dépendance et portabilité plus difficile entre hébergeurs HDS).

3.4 Modèles logiques par service

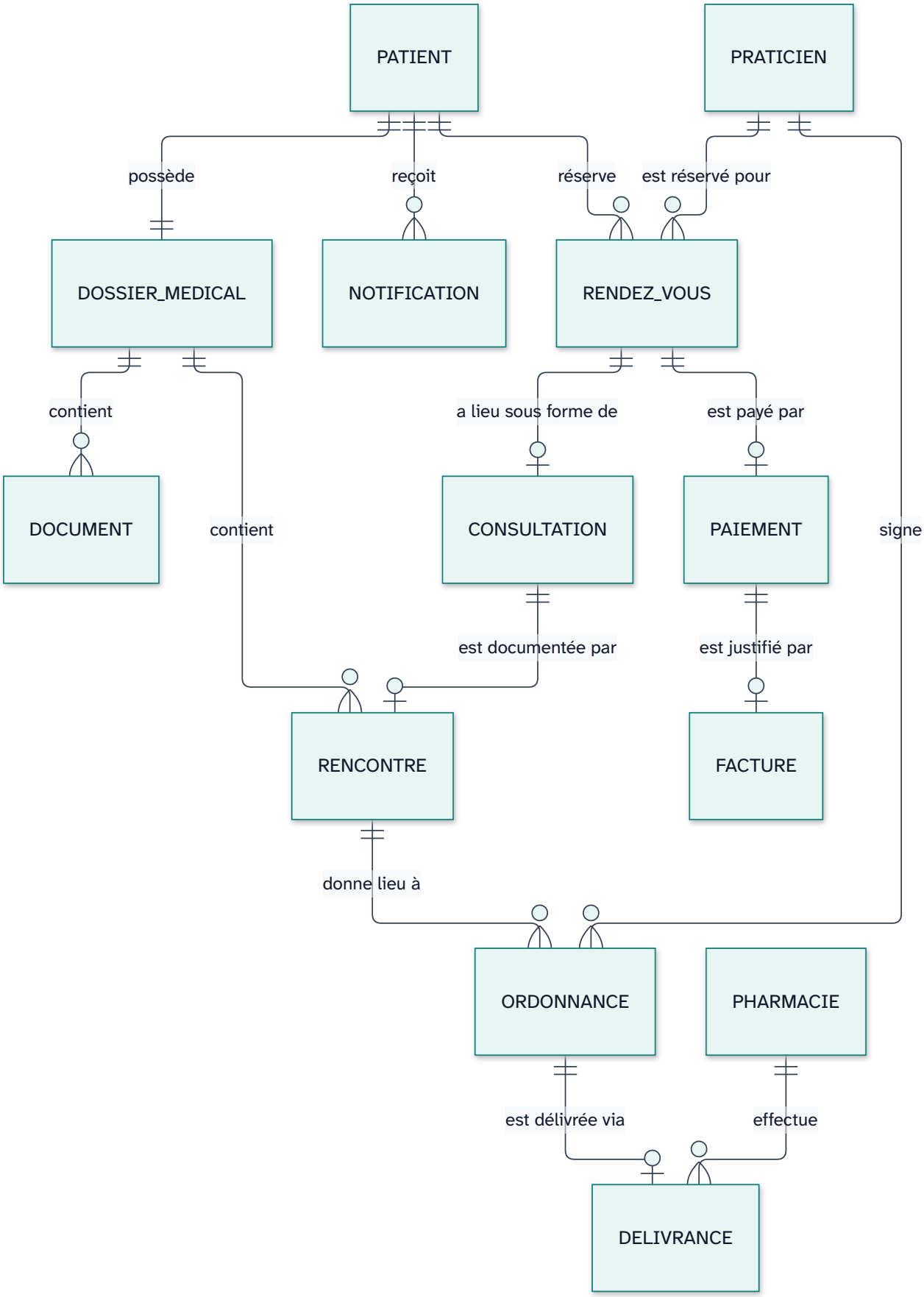
Stratégie de stockage par composant — synthèse

Composant	Système de référence	Stockages secondaires	Points clés de conception	Volume (année 3)
① Gestion des utilisateurs	PostgreSQL `gestion_utilisateurs` + base PostgreSQL de Keycloak	Redis (sessions, liste de refus)	Coordonnées chiffrées, index aveugle pour l'e-mail, préférences en JSONB versionné	~50 Go

Composant	Système de référence	Stockages secondaires	Points clés de conception	Volume (année 3)
② Planification	PostgreSQL `planification`	Redis (blocages, disponibilités, files), OpenSearch (annuaire)	Contrainte d'exclusion, historique en ajout seul, motif chiffré	~250 Go/an
③ Consultation	PostgreSQL `consultation`	Cassandra (chat, TTL 30 jours), Redis (routage, présence), stockage de documents	Chat chiffré par consultation, transcription archivée dans le dossier	~50 Go/an + ~120 Go de chat récent
④ Dossier patient	PostgreSQL `dossier` (ressources FHIR + historique)	Répliques de lecture (3 AZ + reprise), stockage de documents	Historique en ajout seul, chaîne de hachage, clés par patient, projections	**~10 To** structurés
④ Accès d'urgence	PostgreSQL `urgence` (propre au service, par région)	Répliques de lecture du dossier	Autorisation + audit dans une seule transaction, actif dans deux régions	< 10 Go
⑤ Ordonnances	PostgreSQL `ordonnances`	Réplique de la base médicaments, OpenSearch (recherche de médicaments)	Versions signées immuables, deux machines à états	~250 Go/an
⑥ Interface pharmacie	PostgreSQL `pharmacie` (+ PostGIS)	Redis (cache des disponibilités)	Événements de statut en ajout seul, identifiants dans Vault	~100 Go/an
⑦ Notification	Cassandra (journal, TTL 13 mois)	PostgreSQL (modèles, réplique des préférences), Redis (dédoublonnage, plafonds)	Aucune donnée de santé stockée	~1,2 To (13 mois, avant réplication)
⑧ Facturation et paiement	PostgreSQL `facturation`	Stockage de documents (PDF des factures, WORM)	Grand livre en partie double en ajout seul, entiers en unité mineure, jetons PSP uniquement	~100 Go/an
Stockage de documents	Stockage objet	PostgreSQL (métadonnées, clés chiffrées)	Quarantaine → analyse → chiffrement → Object Lock	**~150 To** cumulés
Piste d'audit	Stockage objet (WORM, compte de sécurité)	OpenSearch (13 mois), SIEM	Lots chaînés par hachage, racines de Merkle signées chaque jour	~0,7 To/an compressé

Modèle de domaine transverse

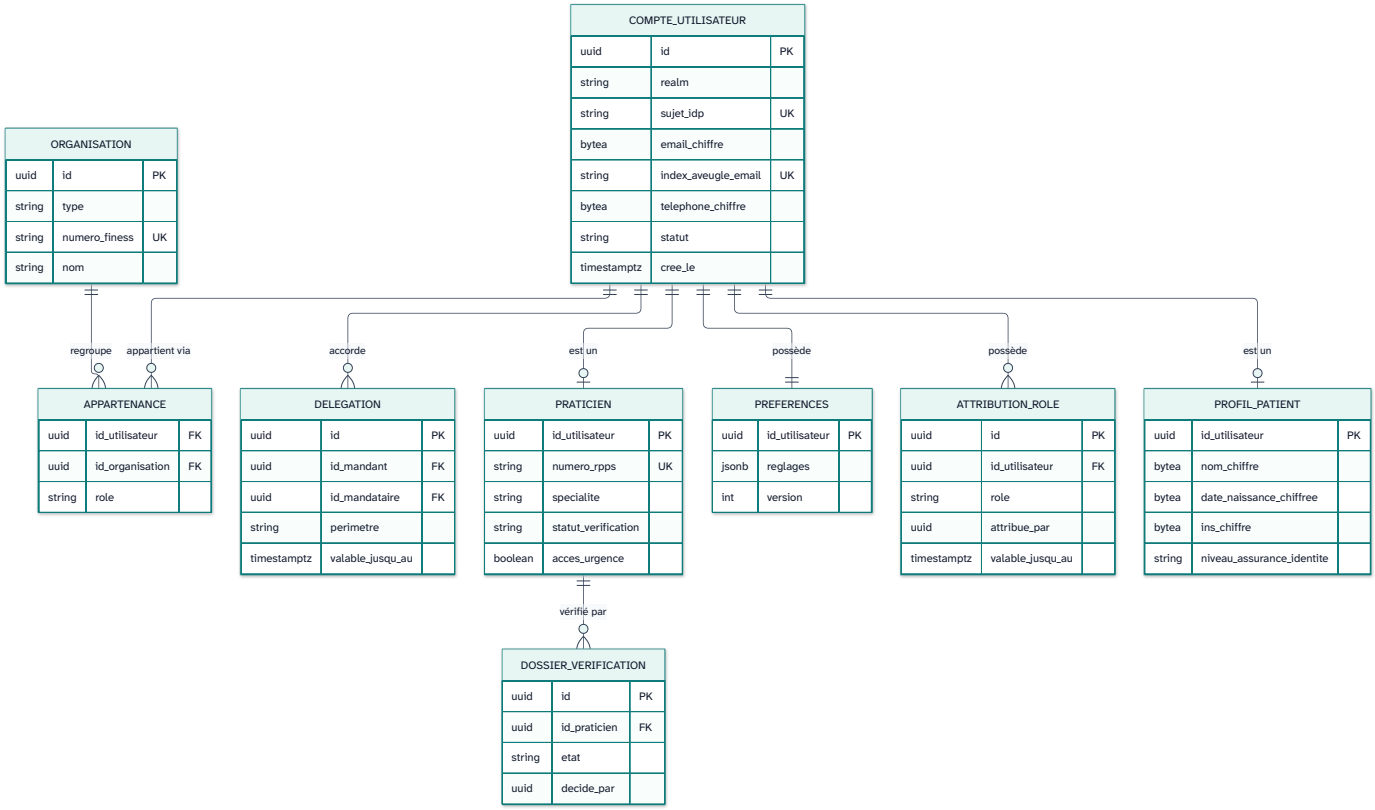
Chaque entité appartient à un seul service ; les relations entre services sont des références par identifiant.



Entité	Service propriétaire	Stockage
Patient, praticien, pharmacie (identité, organisation)	① Gestion des utilisateurs	PostgreSQL

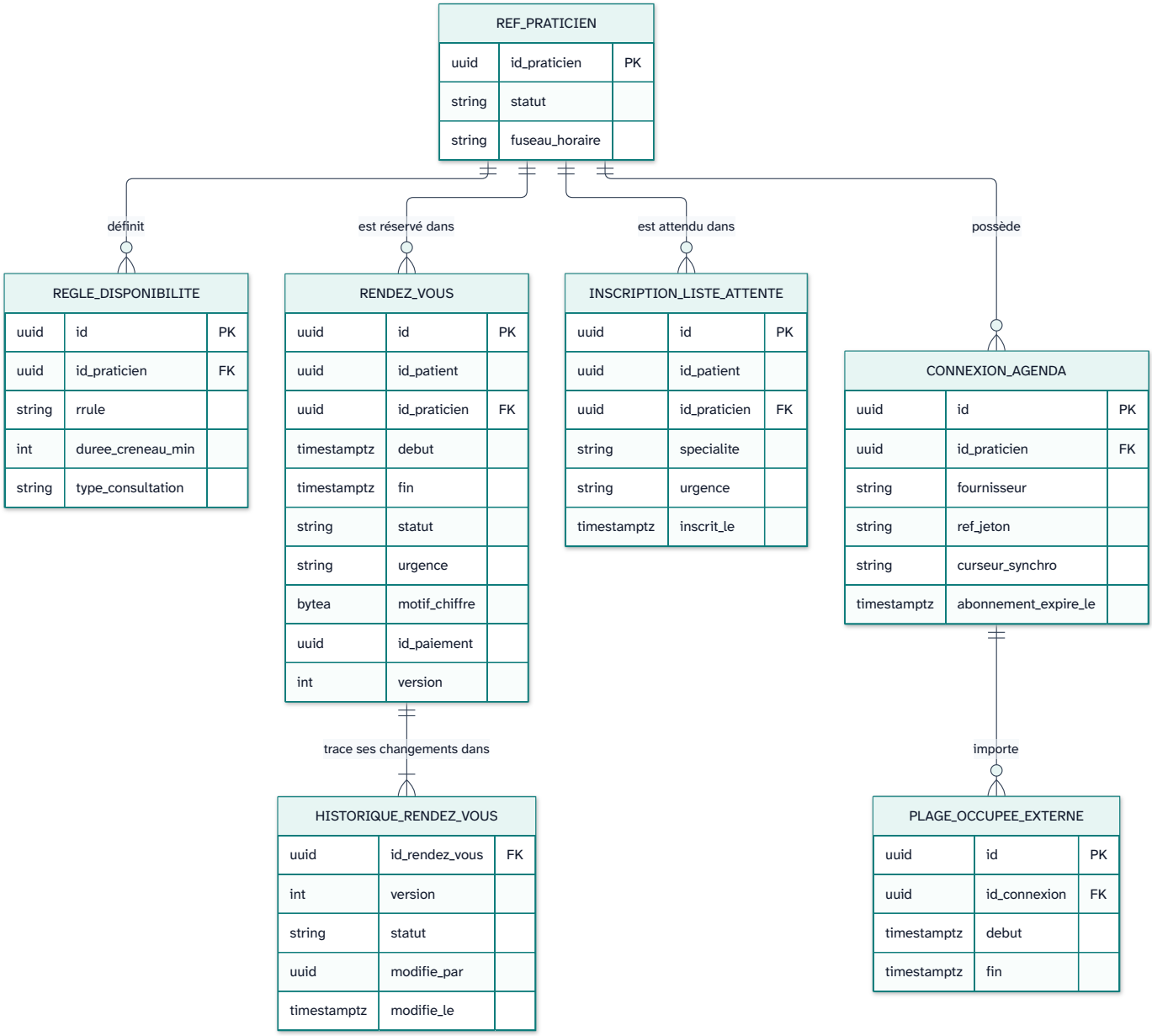
Entité	Service propriétaire	Stockage
Rendez-vous	② Planification	PostgreSQL
Consultation	③ Consultation	PostgreSQL + Cassandra (chat)
Dossier médical, rencontre, ressources cliniques	④ Dossier patient	PostgreSQL (FHIR)
Document	Stockage de documents (métadonnées) / ④ (référence clinique)	Stockage objet + PostgreSQL
Ordonnance	⑤ Ordonnances	PostgreSQL
Délivrance	⑥ Interface pharmacie (opérationnel) / ⑤ (statut légal)	PostgreSQL
Notification	⑦ Notification	Cassandra
Paiement, facture	⑧ Facturation et paiement	PostgreSQL + stockage objet

① Gestion des utilisateurs



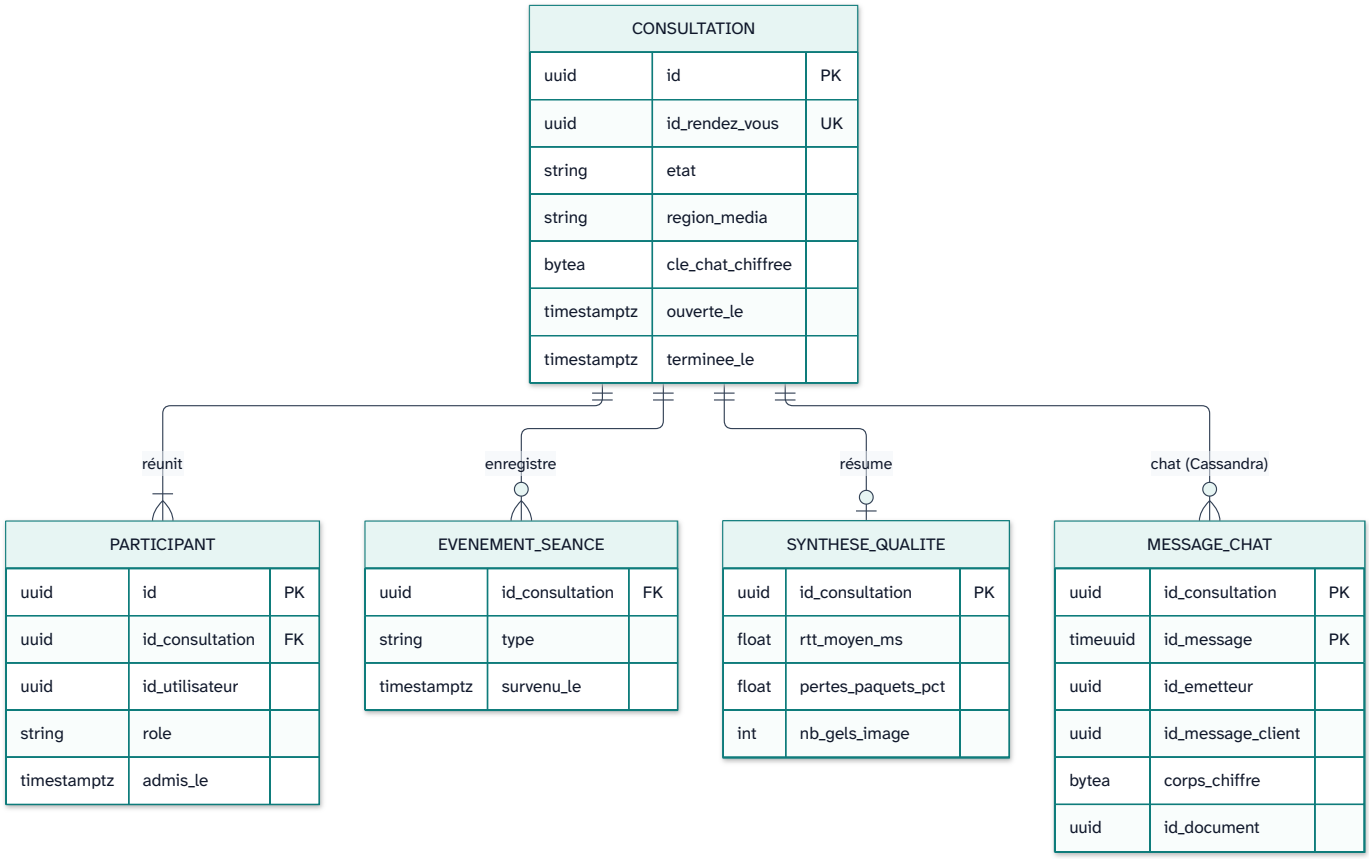
Index aveugle : `index_aveugle_email = HMAC-SHA256(k, e-mail normalisé)` permet de retrouver un compte par e-mail sans stocker l'adresse en clair ; la clé HMAC est conservée dans Vault.

② Planification



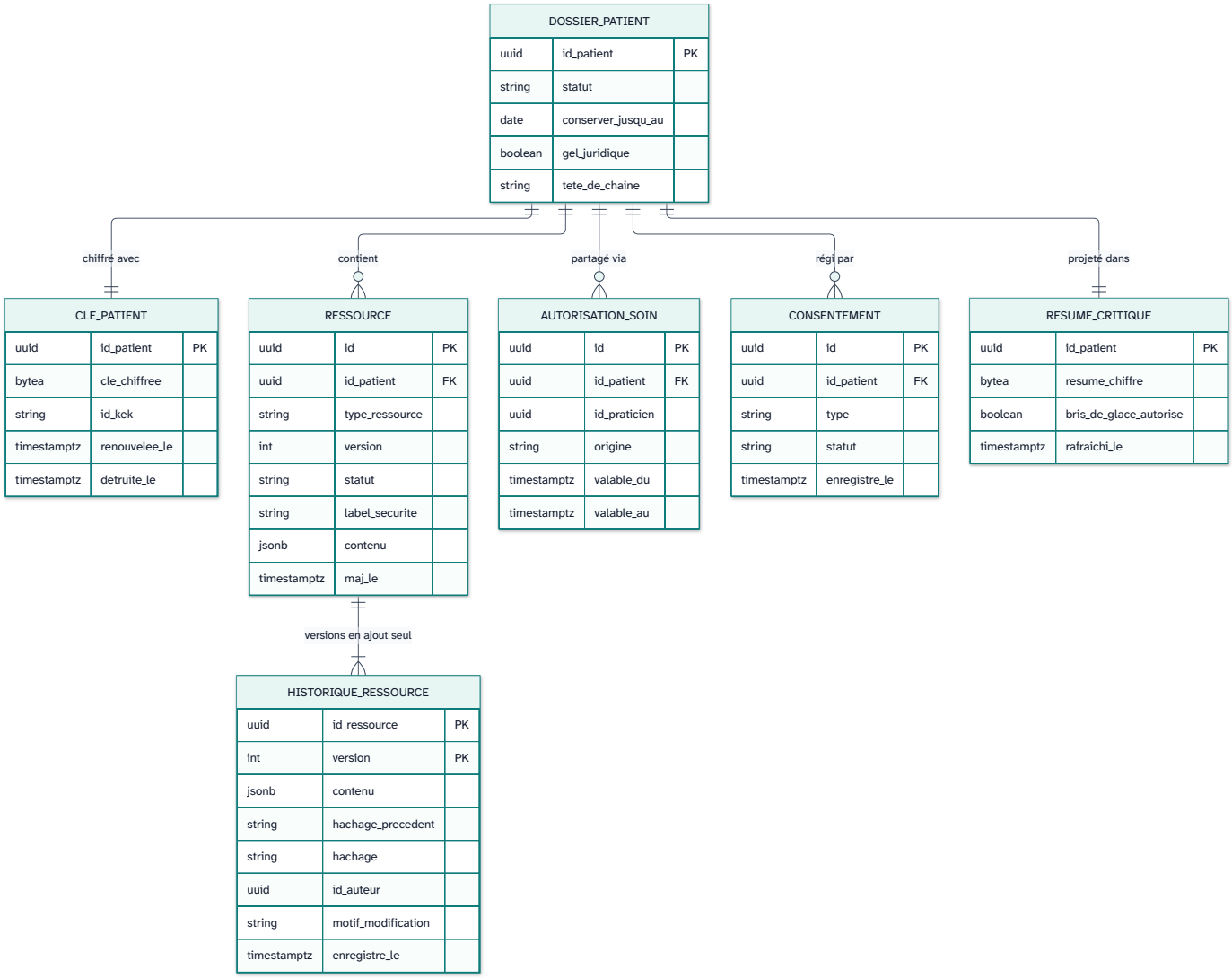
La contrainte d'exclusion sur `(id_praticien, tstzrange(debut, fin))` pour les statuts actifs est décrite au §2.2. Clés Redis : `blocage:{praticien}:{debut}` (TTL 10 min), `dispo:{praticien}:{date}` (table des créneaux libres), `attente:{praticien|specialite}` (ensemble trié par urgence puis ancienneté).

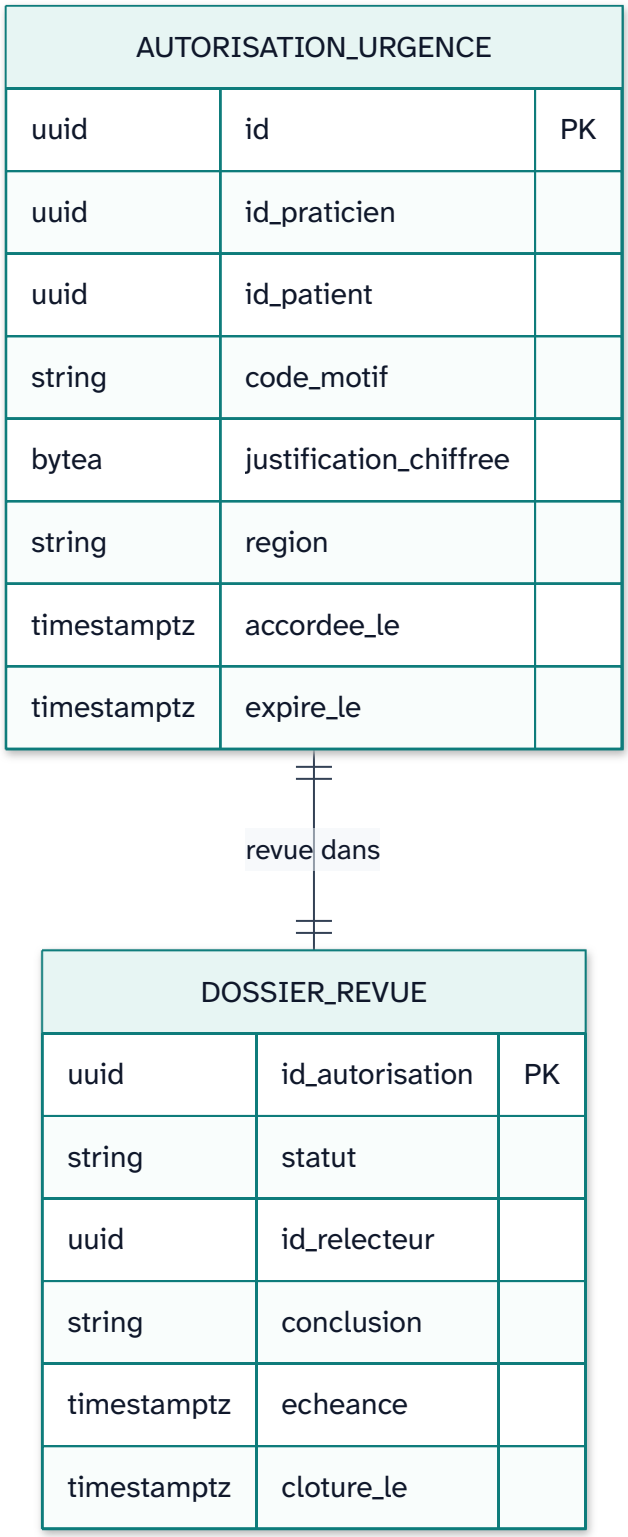
③ Consultation



Partition Cassandra = `id_consultation` (tous les messages d'une consultation ensemble, ordonnés par `timeuuid`) ; `default_time_to_live` = 30 jours ; la transcription est archivée dans le dossier avant l'expiration.

④ Dossier patient et accès d'urgence

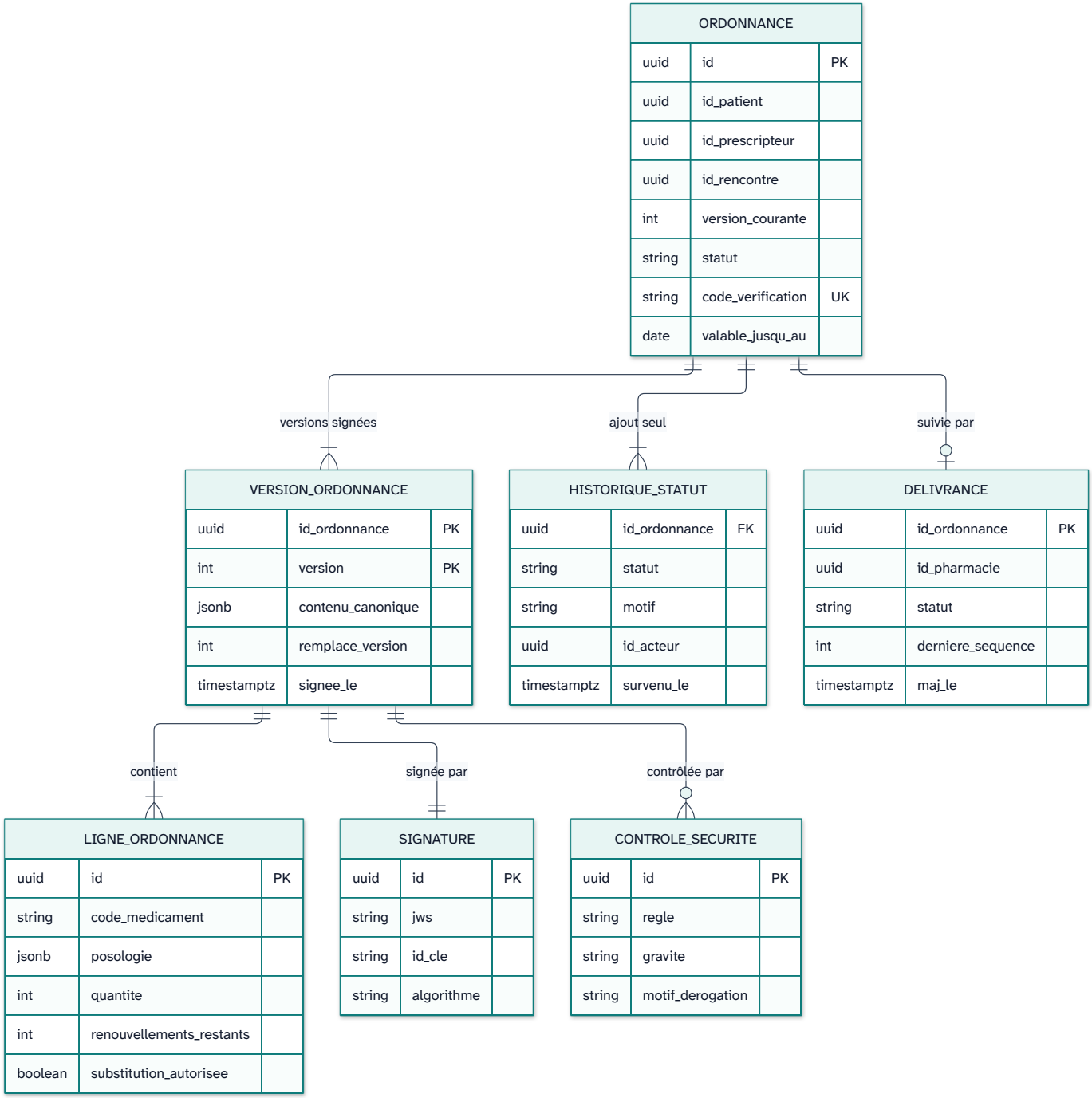




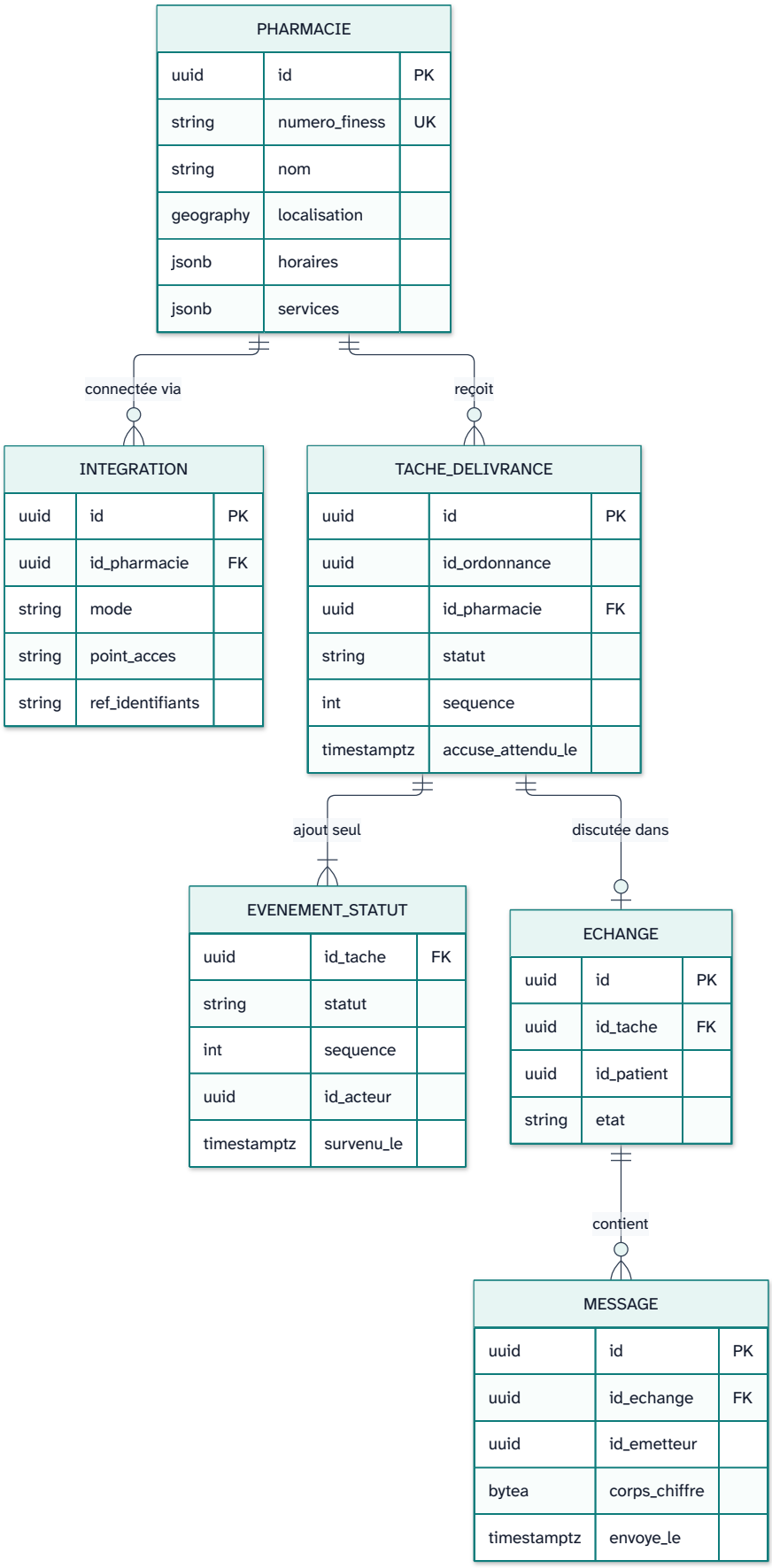
- `RESSOURCE.contenu` contient le JSON FHIR ; les éléments classés C4 (notes en texte libre, catégories sensibles, identifiant national) y sont remplacés par un **texte chiffré avec la clé du patient** (AES-256-GCM, données authentifiées additionnelles = id de ressource + version, pour qu'un texte chiffré ne puisse pas être déplacé vers une autre ressource).
- Les paramètres de recherche FHIR sont extraits dans des tables indexées à l'écriture (comme le fait HAPI FHIR) — seuls des paramètres non sensibles (codes, dates, statuts) sont indexés en clair.
- Les tables sont **partitionnées par hachage de `id_patient`** dès le départ, ce qui prépare le partitionnement horizontal par patient.

- Le rôle de base de données du service n'a que `INSERT/SELECT` sur `HISTORIQUE_RESSOURCE` ; un déclencheur rejette toute modification.

⑤ Ordonnances



⑥ Interface pharmacie



⑦ Notification (Cassandra)

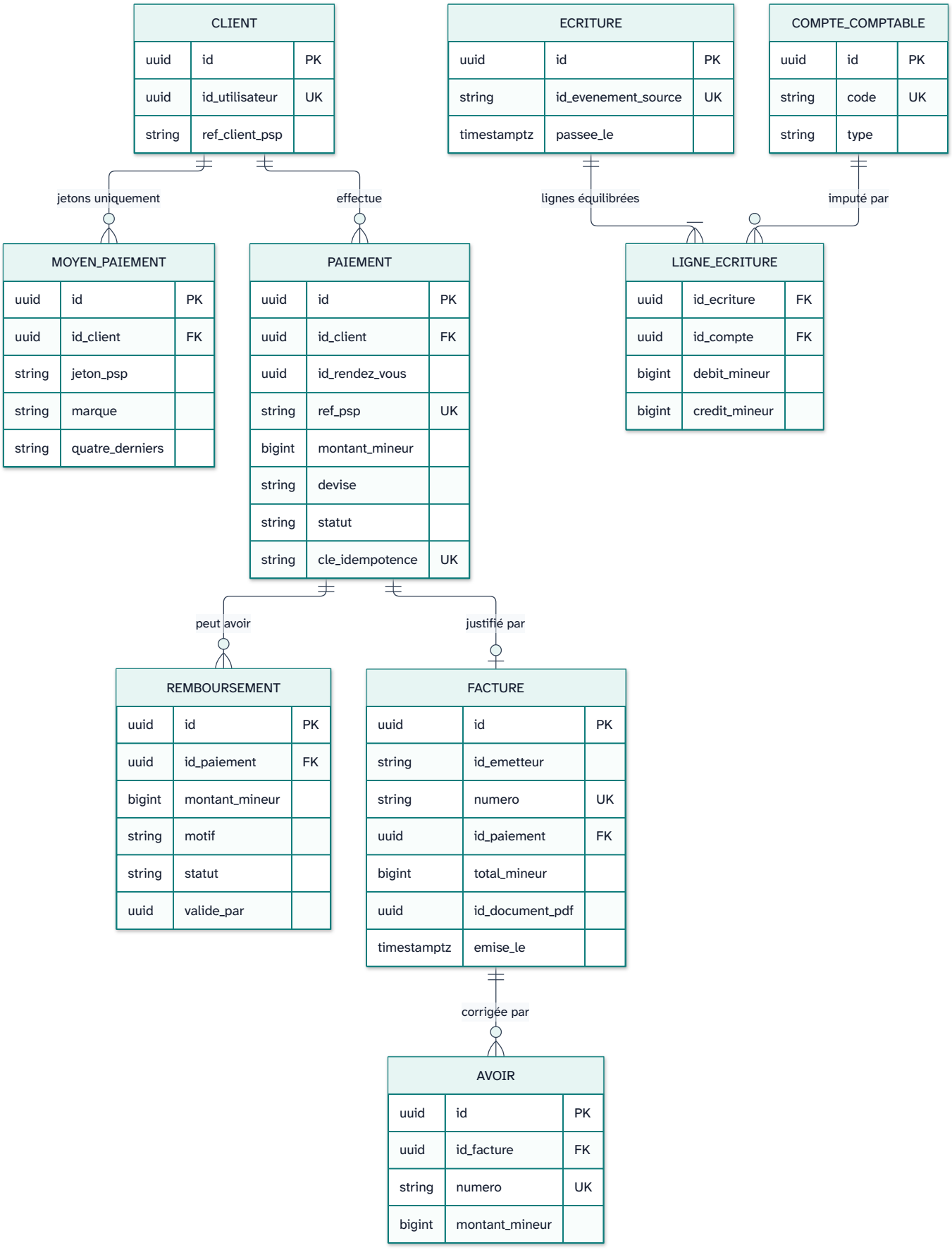
Tables conçues à partir des requêtes : « les notifications d'un utilisateur, les plus récentes d'abord » et « l'historique des statuts d'une notification ».

```
CREATE TABLE notification_par_destinataire (
    id_destinataire  uuid,
    mois             text,          -- '2026-03' : borne la taille des partitions
    cree_le          timeuuid,
    id_notification  uuid,
    categorie        text,
    priorite         text,
    canal            text,
    id_modele        text,
    statut           text,
    PRIMARY KEY ((id_destinataire, mois), cree_le)
) WITH CLUSTERING ORDER BY (cree_le DESC)
  AND default_time_to_live = 34214400;   -- 396 jours, environ 13 mois

CREATE TABLE evenement_statut_notification (
    id_notification  uuid,
    survenu_le       timeuuid,
    statut           text,
    fournisseur      text,
    ref_fournisseur  text,
    PRIMARY KEY ((id_notification), survenu_le)
) WITH default_time_to_live = 34214400;
```

Aucun corps de message au contenu personnel n'est stocké — seulement l'identifiant du modèle et les références des variables de rendu.

⑧ Facturation et paiement



Invariant imposé par un déclencheur de contrainte différé : pour chaque `ECRITURE`, Σ débits = Σ crédits. `id_evenement_source` est unique → le même événement PSP ne peut jamais être comptabilisé deux fois.

Piste d'audit (archive WORM + index)

```
{
  "id": "0192a4c1-8f3e-7b21-9c4d-2e5f6a7b8c9d",
  "enregistreLe": "2026-03-02T03:12:44.182Z",
  "action": "lecture",
  "finalite": "ETREAT",
  "resultat": "succes",
  "brisDeGlace": true,
  "acteur": { "id": "0192…", "role": "medecin", "organisation": "0192…", "niveauAssurance": 3,
"ip": "203.0.113.10", "appareil": "web" },
  "entite": { "idPatient": "0192…", "typeRessource": "Composition", "idRessource": "0192…" },
  "source": { "service": "acces-urgence", "region": "eu-central", "idTrace":
"4bf92f3577b34da6a3ce929d0e0e4736" },
  "lot": { "id": "2026-03-02T03:12Z-eu-central-17", "hachagePrecedent": "9f2c…", "hachage":
"b71e…" }
}
```

3.5 Modèle de cohérence

Donnée	Cohérence requise	Mécanisme
Unicité des créneaux	**Forte**	Contrainte d'exclusion (base principale unique) + blocage Redis
Écritures dans le dossier clinique	**Forte**, aucune mise à jour perdue	Base principale unique, concurrence optimiste `If-Match`, lectures de l'auteur dirigées vers la base principale
Statut légal des ordonnances	**Forte** dans le service Ordonnances ; propagée aux pharmacies en quelques secondes	Machine à états + outbox + rapprochement toutes les 5 min
Paiements et grand livre	**Forte**, effet exactement une fois	Clés d'idempotence, identifiants d'événements source uniques, écritures équilibrées
Réservation + paiement entre services	**Transaction métier à cohérence à terme**	Saga avec compensation (libérer le créneau, annuler l'autorisation)
Cache des disponibilités, annuaire, chronologie	À terme (quelques secondes)	Recalculés à partir des événements ; reconstructibles
Résumé critique (urgence)	À terme (p99 < 5 s)	Projection sur événement ; la vue d'urgence liste aussi les changements des dernières 24 h, lus directement sur la réplique
Réplique des préférences de notification	À terme (quelques secondes)	Événements `PreferencesMisesAJour`

3.6 Identifiants

- **UUIDv7** pour chaque entité : uniques entre services et régions, ordonnés dans le temps (bonne localité d'index), impossibles à deviner séquentiellement — jamais d'entiers auto-incrémentés exposés dans les URL (protection contre les attaques par énumération).
- **Identité du patient** : identifiant patient MedX (interne, pseudonyme) + identifiant national de santé (INS) stocké chiffré, utilisé seulement pour le rapprochement d'identité et les échanges avec les services nationaux.
- Les références destinées aux humains (numéros de facture, codes de vérification des ordonnances) sont des identifiants distincts, dédiés à leur usage.

3.7 Cycle de vie et conservation des données

Donnée	Durée de conservation	Fin de vie	Fondement
Dossier médical (ressources, documents, transcriptions, ordonnances)	**20 ans après la dernière consultation** (France ; davantage pour les mineurs), paramétrable selon le pays ; gel juridique possible	**Effacement cryptographique** (destruction des clés du patient), puis suppression physique	Code de la santé publique
Historique récent du chat	30 jours (transcription déjà archivée dans le dossier)	Expiration par TTL	Minimisation
Vidéo / audio	**Non enregistrés**	—	Confidentialité dès la conception
Rendez-vous	5 ans après le rendez-vous, puis anonymisation pour les statistiques	Tâche d'anonymisation	Preuve de prise en charge, litiges
Compte utilisateur (patient)	Tant qu'il est actif ; clôturé après 3 ans d'inactivité, avec préavis	Suppression des données C2 ; le dossier médical suit sa propre règle	Limitation de la conservation (RGPD)
Identité des praticiens	Tant que des dossiers y font référence	Conservée (attribution des dossiers)	Intégrité des dossiers
Factures, grand livre	10 ans	Suppression	Code de commerce
Jetons de paiement	Jusqu'à leur retrait par l'utilisateur, ou 13 mois après la dernière utilisation	Supprimés chez le PSP et localement	PCI DSS, minimisation
Journal des notifications	13 mois	Expiration par TTL	Preuve de distribution
Piste d'audit	≥ 6 ans, paramétrable jusqu'à la durée de conservation du dossier	Fin de l'Object Lock puis suppression	Responsabilité
Journaux techniques et de sécurité	12 mois	Suppression	Investigations de sécurité
Sauvegardes	Restauration à un instant donné 35 jours · instantanés quotidiens 35 jours · instantanés mensuels 12 mois	Expiration automatique (immuables jusque-là)	Reprise
Registres de clés (clés patient chiffrées)	Sauvegardes conservées 35 jours seulement	Expiration	Rend l'effacement cryptographique effectif dans les sauvegardes
Analytique désidentifiée	Données anonymes : illimitée · jeux pseudonymisés : 2 ans	Suppression	Recherche, statistiques

Droit à l'effacement et conservation médicale — l'article 17(3) du RGPD exclut les données qui doivent être conservées pour les soins ou pour une obligation légale : un patient peut clôturer son compte et faire supprimer ses coordonnées, mais le dossier médical reste soumis à sa durée légale de conservation (le patient en est clairement informé).

3.8 Mécanismes d'intégrité des données

Menace	Mécanismes
Modifications concurrentes (mise à jour perdue)	Concurrence optimiste (`If-Match` / version), base principale unique pour les écritures
Données invalides ou incohérentes	Validation par profils FHIR et terminologies, clés étrangères et contraintes de vérification, machines à états, contrainte d'exclusion

Menace	Mécanismes
Pannes partielles entre services	Outbox transactionnelle, consommateurs idempotents, sagas avec compensation, tâches de rapprochement
Altération silencieuse (malveillance interne, administrateur compromis)	Historique en ajout seul, chaînes de hachage par patient, racine de Merkle quotidienne signée par HSM et horodatée, archive d'audit WORM, tâches de vérification
Fichiers corrompus	Somme de contrôle SHA-256 au dépôt, à chaque téléchargement et lors de contrôles hebdomadaires ; versionnage des objets
Suppression accidentelle ou malveillante, rançongiciel	Aucun droit de suppression pour les rôles applicatifs sur l'historique ; Object Lock (mode conformité) ; **coffre de sauvegardes immuable dans un autre compte** ; protection contre la suppression des bases
Perte d'une zone ou d'une région	Réplique synchrone dans une autre AZ (RPO 0), répliques entre régions (RPO ≤ 1 min), stockage objet répliqué
Défaillance de sauvegarde non détectée	Tests de restauration automatisés chaque semaine (échantillon) et exercice de restauration complète chaque trimestre, avec vérification d'intégrité

3.9 Sauvegarde et restauration

Stockage	Sauvegarde	Objectif de restauration
PostgreSQL (tous les services)	Archivage continu des WAL → **restauration à un instant donné sur 35 jours** ; instantanés quotidiens ; instantanés mensuels sur 12 mois ; copies dans le coffre immuable (autre compte, autre région)	Restauration à un instant donné d'un seul service sans toucher aux autres
Cassandra	Instantanés quotidiens + sauvegardes incrémentales vers le stockage objet	Le chat se reconstruit à partir des transcriptions du dossier ; le journal des notifications n'est pas critique
Stockage objet	Versionnage + Object Lock + réplication entre régions + copie dans le coffre	Restauration d'un objet ou d'une version ; bascule régionale
Kafka	Pas sauvegardé en tant que stockage (les événements sont aussi en base) ; MirrorMaker vers la reprise pour la continuité	Rejeu depuis les outbox si nécessaire
Redis / OpenSearch	Pas sauvegardés (données dérivées) — reconstruits à partir des systèmes de référence	Tâches de reconstruction (de quelques minutes à quelques heures)
Clés (KMS/HSM)	Gérées par le fournisseur, clés multirégions ; réplication de reprise de Vault	—

3.10 Résidence et réplication des données

- Toutes les données de santé sont stockées et traitées dans l'**EEE**, dans des régions certifiées HDS (principale en France, reprise en Allemagne).
- La réplication entre régions est chiffrée en transit et rechiffrée au repos avec des clés multirégions.
- L'ouverture à un autre pays (par exemple les États-Unis) se fait avec une **cellule régionale séparée** : une copie complète de la plateforme, avec ses propres données, ses clés et son périmètre de conformité (HIPAA) ; seule la configuration non personnelle est partagée au niveau global. Les données patient ne circulent jamais entre cellules, sauf à la demande du patient.

4. Scalabilité et performances

Livrable 4. Comment MedX absorbe la croissance de ses utilisateurs et tient ses performances — chiffres à l'appui. Les objectifs viennent des §0.7 Objectifs de capacité et §0.8 Niveaux de service et criticité.

4.1 La stratégie en une page

Levier	Ce que fait MedX
Monter en largeur, pas en hauteur	Services sans état sur Kubernetes, mis à l'échelle automatiquement sur la métrique qui limite réellement chacun (requêtes, connexions, retard de file, participants).
Séparer ce qui évolue différemment	Plan média, dossier patient, notifications et paiements ont des mises à l'échelle et des domaines de panne indépendants.
Garder le chemin critique court	Validation des jetons et décisions de politique en local, disponibilités et synthèses d'urgence pré-calculées, au plus deux sauts synchrones.
Absorber les pointes de manière asynchrone	Kafka et les files de priorité transforment les pics en arriérés résorbés en quelques secondes, jamais en erreurs.
Protéger ce qui compte le plus	Cloisonnement et ordre de délestage : accès d'urgence → consultations en cours → écritures cliniques → réservation → le reste.
Grandir par paliers, sur des déclencheurs explicites	Répliques → partitionnement → sharding par patient → cellules régionales ; chaque palier est déclenché par des seuils mesurés.
Le prouver en continu	Tests de charge, d'endurance, de chaos et WebRTC à 2× la pointe prévue avant chaque version majeure ; SLO avec budgets d'erreur.

4.2 Modèle de charge

Profil	Description	Réponse de conception
Cycle quotidien	Pointes le lundi de 8 h à 10 h et de 18 h à 20 h ; la nuit ≈ 5 % de la pointe	Pré-dimensionnement planifié + mise à l'échelle automatique ; traitements par lots la nuit
Pics saisonniers	Grippe, épidémies : demande **× 3 à × 5** en quelques jours	Plan de gestion des pics (§4.10), marge × 2 dès la conception, la région de secours peut absorber du trafic en lecture
Rafales de rappels	Des milliers de rappels dus aux heures rondes	Fenêtre d'envoi avec gigue, file de notification dédiée
Données cliniques surtout lues	Le dossier est lu ≈ 5 à 10 fois plus qu'il n'est écrit	Répliques, projections, requêtes circonscrites au patient
Connexions longues	WebSocket pour la messagerie et les statuts, WebRTC pour le média	Passerelles et nœuds média dédiés, dimensionnés sur les connexions et les participants

4.3 Estimations de capacité (année 3)

Grandeur	Estimation	Résultat	Capacité de conception
Débit d'API	≈ 75 M d'appels/jour ÷ 86 400 s × facteur de pointe 5	**≈ 4 300 req/s**	10 000 req/s
Sessions vidéo simultanées	200 000 consultations/jour × 12 % à l'heure de pointe × 20 min	**≈ 8 000**	10 000 (mise à l'échelle jusqu'à 20 000)
Bande passante sortante SFU	20 000 participants × ≈ 1,2 Mbit/s reçus	**≈ 24 Gbit/s**	48 Gbit/s

Grandeur	Estimation	Résultat	Capacité de conception
Nœuds média (8 vCPU)	20 000 participants ÷ ≈ 200 par nœud	**≈ 100 nœuds**	jusqu'à 200
Connexions WebSocket	1 M d'utilisateurs quotidiens × ≈ 20 % connectés en pointe	**≈ 200 000**	400 000
Lectures du dossier	≈ 10 M/jour, facteur de pointe 5	**≈ 600 req/s**	2 000 req/s
Écritures du dossier	200 000 consultations × ≈ 10 ressources, sur les heures ouvrées	**≈ 55/s, pointes ≈ 110/s**	500/s
Événements métier	≈ 50 M/jour	**≈ 600/s en moyenne, 3 000/s en pointe**	trivial pour un cluster Kafka de 3 brokers
Événements d'audit	20 M/jour	**≈ 230/s en moyenne, 1 200/s en pointe**	écritures par lots vers le stockage WORM
Notifications	2 M/jour	**≈ 25/s en moyenne, 500/s aux pointes de rappels**	2 000/s (limites des fournisseurs)
Stockage de documents	≈ 1 Mo/consultation + dépôts des patients	**≈ 75 To/an** au rythme de l'année 3, 150 To cumulés	stockage objet (pas de limite pratique)
Données cliniques structurées	≈ 50 Ko/consultation, historique et index compris	**≈ 4 To/an**, 10 To en année 3	un primaire + répliques ; trajectoire de sharding prête

4.4 Objectifs de performance et budgets de latence

Les SLO sont définis par niveau de criticité au §0.8. Chaque requête critique dispose d'un **budget de latence** que la conception doit respecter :

Synthèse critique d'urgence (objectif p95 < 300 ms côté serveur)

Étape	Budget
Passerelle : signature du JWT (JWKS en cache), contrôle DPoP, limitation de débit	≤ 5 ms
Saut mTLS vers le pod d'accès d'urgence	≤ 2 ms
Décision OPA (sidecar, en mémoire)	≤ 1 ms
Insertion de l'autorisation + outbox d'audit (validation synchrone multi-AZ)	≤ 15 ms
Lecture de la synthèse pré-calculée (une ligne indexée, réplique locale)	≤ 10 ms
Déchiffrement de la clé patient (cache mémoire ; KMS en cas d'absence)	≤ 1 ms (≤ 30 ms sinon)
Déchiffrement, application des obligations, sérialisation	≤ 5 ms
Total typique	**≈ 40 à 70 ms**, soit une large marge sous les 300 ms

Confirmation de réservation (objectif p95 < 800 ms hors 3-D Secure) — blocage du créneau ≤ 20 ms (Redis + insertion), autorisation de paiement 300 à 600 ms (PSP, le terme dominant), validation + outbox ≤ 20 ms.

Message de discussion (objectif p95 < 500 ms) — passerelle ≤ 5 ms, autorisation + chiffrement ≤ 3 ms, écriture Cassandra (`LOCAL_QUORUM`) ≤ 10 ms, diffusion pub/sub ≤ 5 ms ; le reste est du réseau.

4.5 Mise à l'échelle par couche et par service

Couche	Mécanisme
Périmètre	Le CDN décharge les ressources statiques ; WAF et répartiteurs de charge managés s'adaptent automatiquement ; pods de passerelle mis à l'échelle sur le débit et le CPU.
Services	Horizontal Pod Autoscaler de Kubernetes sur le CPU et des métriques métier (débit, latence p95, retard Kafka via KEDA) ; l'autoscaler de cluster ajoute des nœuds ; l'anti-affinité répartit les répliques sur 3 AZ ; 3 répliques au minimum pour les niveaux 0 et 1.
Données	Dimensionnement vertical + répliques en lecture + mutualisation des connexions (PgBouncer) + partitionnement ; trajectoire de sharding pour le dossier patient (§4.7).
Événements	Topics partitionnés par clé d'agrégat (12 à 48 partitions) ; les groupes de consommateurs montent jusqu'au nombre de partitions.
Temps réel	Pods WebSocket dimensionnés sur les connexions ouvertes ; cluster Redis pub/sub pour la diffusion.
Média	Nœuds SFU dimensionnés sur les participants et la bande passante sortante ; placement selon la région ; vidange avant retrait.

Service	Facteur de charge	Signal de mise à l'échelle	Répliques (année 3, min–max)	Goulet principal → parade
Passerelle d'API	Requêtes	Débit, CPU	6 – 40	—
Passerelle temps réel	Connexions	Connexions par pod (≈ 25 000)	4 – 20	Mémoire par connexion → trames légères, battements de cœur
① Gestion des utilisateurs + IdP	Connexions, rafraîchissements	CPU	3 – 12	CPU du hachage de mots de passe → limitation de débit, passkeys
② Planification	Recherches, réservations	Débit	3 – 30	Calcul des disponibilités → cache Redis pré-calculé
③ Consultation (plan de contrôle)	Entrées en salle, messagerie	Débit, messages WebSocket	3 – 20	—
Plan média (SFU + TURN)	Participants	Participants par nœud, bande passante	10 – 200 nœuds	Bande passante → simulcast, flux adaptatif, audio seul
④ Dossier patient	Lectures	Débit, latence p95	4 – 30	Base de données → répliques, projections, trajectoire de sharding
Accès d'urgence	Demandes de bris de glace	**Capacité réservée** + débit	3 par région (plancher fixe) – 12	Isolé par conception (cloisonnement)
⑤ Ordonnances	Écritures, contrôles	Débit	3 – 12	Contrôles médicamenteux → référentiel en cache
⑥ Interface pharmacie	Webhooks, mises à jour de statut	Retard de file	2 – 12	Logiciels de pharmacie lents → webhooks asynchrones
⑦ Notification	Événements	Retard de consommation par file de priorité	2 – 40	Limites des fournisseurs → deux fournisseurs par canal
⑧ Facturation et paiement	Paiements	Débit	3 – 8	Latence du PSP → encaissement asynchrone
Piste d'audit	Événements d'audit	Retard de consommation	2 – 10	Écritures en stockage objet → lots d'une minute

4.6 Stratégie de cache

Cache	Contenu	Emplacement	Fraîcheur	Données de santé ?
CDN	Paquets applicatifs, images	Périphérie	Versionné, immuable	Non

Cache	Contenu	Emplacement	Fraîcheur	Données de santé ?
Clés et politiques	JWKS, paquets OPA	Dans le processus	5 min / récupérés toutes les 60 s	Non
Disponibilités	Créneaux libres par médecin et par jour (60 jours)	Redis	Recalculé sur événement (secondes)	Aucune donnée patient
Annuaire	Profils publics des médecins + prochain créneau libre	OpenSearch	Piloté par les événements	Non (public)
Référentiel médicamenteux	Catalogue des médicaments, interactions	Dans le processus + OpenSearch	Rafraîchi chaque jour	Non
Synthèse d'urgence	Résumé patient international (IPS) par patient	Projection PostgreSQL + répliques	Pilotée par les événements (p99 < 5 s)	**Oui — chiffrée**
Clés de données	Clés patient / fichier déchiffrées	Mémoire du service uniquement	≤ 5 min, LRU borné	Matériel cryptographique, jamais persisté
Stocks	Niveau de disponibilité par pharmacie et par produit	Redis	15 min	Non

Règles — aucune donnée de santé dans les caches partagés (la synthèse d'urgence chiffrée est la seule exception) ; les réponses contenant des données personnelles portent `Cache-Control: no-store` ; les caches utilisent des TTL avec gigue et le regroupement des requêtes pour éviter les effets de ruée ; tout cache est reconstructible à partir de son système de référence.

4.7 Trajectoire de mise à l'échelle des bases de données

Palier	Déclencheur (mesuré)	Action
1 — Lancement	—	Un primaire multi-AZ (secours synchrone) par service ; dossier patient avec 2 répliques en lecture ; PgBouncer ; `statement_timeout` et quotas de connexions par service
2 — Croissance	Dossier > 2 To, retard de réplique > 1 s, ou CPU du primaire > 60 % en pointe	Instances plus grandes, davantage de répliques, élagage de partitions, anciennes partitions d'historique déplacées vers un stockage moins coûteux
3 — Montée en largeur	Écritures du dossier > ≈ 5 000/s ou > 20 To	**Sharding par hachage de `id_patient`** (Citus ou routage applicatif, par exemple) ; chaque shard a ses propres répliques — presque toutes les requêtes sont circonscrites à un patient, les shards sont donc indépendants
4 — Nouvelle juridiction	Nouveau pays ou nouvelle réglementation	Nouvelle **cellule régionale** (§4.12)

L'hygiène des requêtes fait partie de la définition de « terminé » : index revus avec `EXPLAIN` en CI pour les nouvelles requêtes, tableaux de bord `pg_stat_statements`, pagination par curseur (pas d'`OFFSET` profond), aucun accès de type N+1.

4.8 La vidéo à grande échelle

- **Une salle par nœud SFU** pour les consultations en tête-à-tête (pas de relais entre nœuds) ; les salles à plusieurs participants (interprète) peuvent être réparties en cascade sur plusieurs nœuds.
- **Placement** : choix de la région au RTT mesuré le plus faible pour les deux participants, puis du nœud le moins chargé (CPU, bande passante, participants).
- **Simulcast + dynacast + flux adaptatif** : chaque destinataire ne reçoit que la résolution dont son écran et son réseau ont besoin ; débit moyen reçu ≈ 1,2 Mbit/s au lieu de 2,5 Mbit/s en 720p complet.

- **L'audio d'abord** : en cas de congestion, la vidéo se dégrade en premier ; sous ≈ 150 kbit/s, l'appel passe en audio seul.
- **TURN** : flotte dimensionnée pour ≈ 20 % de sessions relayées ; TURN sur TLS 443 pour les réseaux restrictifs.
- **Retrait par vidange** : un nœud marqué pour suppression n'accepte plus de nouvelle salle et disparaît à la fin de son dernier appel.
- **Tests de charge** : des robots à navigateur sans interface génèrent des milliers d'appels simultanés avec perte de paquets et gigue injectées ; la capacité par nœud (≈ 200 participants pour 8 vCPU) est remesurée à chaque mise à jour du SFU.
- **Levier de coût à évaluer** : le média en pair-à-pair direct pour les appels en tête-à-tête, quand les réseaux le permettent, réduirait la bande passante SFU, au prix d'une supervision et d'une maîtrise de la qualité plus faibles — gardé comme optimisation, pas comme base.

4.9 Haute disponibilité et reprise après sinistre

Composant	Dans la région (panne d'une AZ)	Entre régions (panne d'une région)
Passerelles, services	≥ 3 répliques sur 3 AZ ; contrôles de santé du répartiteur de charge	Pré-déployés en secours, montés en charge par la procédure
Accès d'urgence, IdP	≥ 3 répliques sur 3 AZ	**Actifs dans les deux régions** (routage DNS avec contrôle de santé)
PostgreSQL	Secours synchrone dans une autre AZ, bascule automatique < 60 s (RPO 0)	Réplique asynchrone inter-régions (retard < 1 s, RPO ≤ 1 min), promue par la procédure
Redis	Répliques dans d'autres AZ, bascule automatique	Reconstruit (données dérivées)
Kafka	3 brokers / 3 AZ, RF 3, `min.insync.replicas = 2`	MirrorMaker 2 vers le cluster de secours
Cassandra	RF 3 sur les AZ, `LOCAL_QUORUM`	Second datacenter en région de secours (asynchrone)
Stockage objet	Service régional (multi-AZ par conception)	Réplication inter-régions
Plan média	Nœuds dans 3 AZ, les clients se reconnectent	Montée en charge des nœuds média de secours

Procédure de bascule régionale (répétée deux fois par an) :

1. Détection par sondes synthétiques et contrôles de santé → incident déclaré, communication lancée.
2. Le niveau 0 continue immédiatement : l'accès d'urgence et la connexion sont déjà servis par la région de secours.
3. Promotion des répliques de base de données de secours pour les services de niveau 1 (scriptée, dans l'ordre des dépendances), bascule des producteurs vers le cluster Kafka de secours (positions des consommateurs traduites).
4. Montée des groupes de nœuds Kubernetes de secours à la taille de production (réservations de capacité pré-approuvées) → **niveau 1 rétabli en ≤ 1 h**.
5. Rétablissement des services de niveau 2 et reconstruction des magasins dérivés (caches, recherche) → **niveau 2 rétabli en ≤ 4 h**.
6. Retour sur la région principale après rétablissement, par réplication inverse, en dehors des heures de pointe.

4.10 Modèles de résilience et dégradation maîtrisée

- **Des délais partout** (aucun appel sans échéance), **nouvelles tentatives avec temporisation exponentielle et gigue** uniquement pour les opérations idempotentes, **disjoncteurs** dans le maillage de services,

cloisonnement (pools et déploiements séparés pour le chemin d'urgence et pour chaque file de priorité), **clés d'idempotence** sur chaque création.

- **Ordre de délestage** sous charge extrême, appliqué par les priorités de routes de la passerelle, les classes de priorité Kubernetes et les files : ① accès d'urgence → ② consultations en cours → ③ écritures cliniques (notes, ordonnances) → ④ réservation → ⑤ notifications non critiques → ⑥ analyses et exports.

Panne	Comportement dégradé
Prestataire de paiement indisponible	Les blocages conservent les créneaux ; nouvelles tentatives ; réservation « payer plus tard » possible pour les patients connus
Fournisseur d'agenda indisponible	Utilisation des dernières plages occupées connues ; le médecin est averti du retard de synchronisation
Fournisseur SMS / e-mail indisponible	Bascule automatique vers le second fournisseur ; les notifications dans l'application continuent
Base de médicaments indisponible	Prescription possible uniquement après avoir explicitement reconnu que les contrôles sont indisponibles
Bus d'événements indisponible	Les transactions essentielles continuent ; les événements attendent dans les outbox ; notifications et projections rattrapent ensuite
Base primaire du dossier indisponible	Bascule automatique (< 60 s) ; les lectures continuent sur les répliques ; l'accès d'urgence n'est pas affecté
Panne d'un nœud média	Les clients se reconnectent à un autre nœud en quelques secondes
Cluster de recherche indisponible	Recherche de repli par spécialité servie par PostgreSQL
Région entière indisponible	Le niveau 0 continue en secours ; niveau 1 en ≤ 1 h ; niveau 2 en ≤ 4 h

Plan de gestion des pics (épidémie, demande × 3 à × 5) : pré-dimensionnement planifié ; « mode pic » qui relève les planchers de mise à l'échelle ; médecins d'astreinte supplémentaires sur la file des consultations urgentes ; interrupteurs de fonctionnalités qui coupent le non-essentiel (exports, recommandations) ; une **salle d'attente virtuelle** devant la réservation si nécessaire, pour que la plateforme reste réactive pour les personnes déjà prises en charge.

4.11 Pratiques d'ingénierie de la performance

Pratique	Fréquence
Budgets de performance vérifiés en CI (points d'accès clés, p95)	À chaque fusion
Tests de charge à 1× et **2× la pointe prévue** (k6 / Gatling), y compris des robots WebRTC avec dégradation réseau	À chaque version majeure
Tests d'endurance (24 h) pour détecter fuites et dégradations lentes	Mensuelle
Expériences de chaos (arrêt de pods, perte d'une AZ, injection de latence, panne d'une dépendance)	Mensuelle en préproduction, journées d'exercice trimestrielles en production
Exercice de bascule de reprise après sinistre	Deux fois par an
Revue de capacité par rapport aux prévisions (utilisateurs, bande passante, stockage)	Mensuelle
Revue des SLO avec **budgets d'erreur** — les développements fonctionnels s'arrêtent au profit de la fiabilité quand un budget est épuisé	Hebdomadaire

4.12 Croissance au-delà de l'année 3 — les cellules

Quand MedX dépasse une région ou entre dans une nouvelle juridiction, la plateforme grandit par **cellules** : une cellule est une copie complète et isolée de la plateforme (services, données, clés) qui sert une population (un pays, ou un sous-ensemble de patients). Une fine couche de routage globale — qui ne détient **aucune donnée de santé** — dirige chaque utilisateur vers sa cellule de rattachement. Les cellules limitent le rayon d'impact de tout incident, simplifient la résidence des données (une cellule américaine sous HIPAA, des cellules européennes sous RGPD / HDS) et font de la croissance un déploiement reproductible plutôt qu'une refonte.

4.13 Maîtrise des coûts

- Planchers de mise à l'échelle abaissés la nuit ; environnements hors production réduits à zéro en dehors des heures ouvrées.
- Capacité réservée pour la charge de base stable ; capacité *spot* / préemptible uniquement pour les charges sans état et non critiques (jamais le niveau 0, jamais le média).
- Cycle de vie du stockage : les documents de plus d'un an passent sur un niveau d'accès peu fréquent, ceux de plus de 5 ans sur un niveau d'archive — avec conservation Object Lock préservée.
- La bande passante média est le premier coût variable : simulcast, repli en audio seul et débits ajustés sont à la fois des mesures de qualité et de coût ; le **coût par consultation** est suivi comme indicateur clé.

5. Sécurité et conformité

Livrable 5. Protocoles de sécurité, méthodes de chiffrement et mesures de conformité qui protègent les données de santé de MedX. C'est ici que les exigences de priorité haute H1 (confidentialité des données), H3 (contrôle de l'accès d'urgence), H4 (authentification et autorisation) et H5 (intégrité) deviennent des contrôles concrets.

5.1 Objectifs et principes

Objectif	Signification pour MedX
Confidentialité	Les données de santé ne sont vues que par le patient et les professionnels qui le soignent, pour une finalité légitime.
Intégrité	Dossiers, ordonnances et paiements sont complets, exacts, et toute altération est détectable.
Disponibilité	Les informations critiques restent accessibles en urgence, même pendant une panne (niveau 0).
Traçabilité	Chaque accès à une donnée de santé peut être attribué, justifié et contrôlé.
Protection de la vie privée	Collecter le minimum, ne l'utiliser que pour sa finalité, ne le conserver que le temps requis, respecter les droits des patients.

Principes : défense en profondeur · zéro confiance (aucune confiance implicite accordée au réseau : chaque appel est authentifié, autorisé et chiffré) · moindre privilège · refus par défaut · protection des données dès la conception et par défaut · présomption de compromission (limiter le rayon d'impact, détecter vite, restaurer depuis des sauvegardes immuables) · sécurité sous forme de code (politiques, infrastructure et contrôles versionnés et testés).

5.2 Cadre réglementaire et normatif

Cadre	Pourquoi il s'applique	Obligations clés	Comment la conception s'y conforme
RGPD (UE 2016/679)	Les données de santé sont une catégorie particulière (art. 9)	Base légale (art. 9(2)(h), prise en charge sanitaire), protection des données dès la conception (art. 25), sécurité (art. 32), **AIPD** (art. 35), DPO (art. 37), registre des traitements (art. 30), droits des personnes, notification des violations sous **72 h** (art. 33-34), contrats de sous-traitance (art. 28), aucun transfert hors EEE sans garanties	§5.11 opérations de conformité ; chiffrement, minimisation et conservation intégrés ; hébergement exclusivement dans l'EEE
Certification HDS (Code de la santé publique, art. L.1111-8)	Hébergement de données de santé de patients français	Hébergement par des prestataires certifiés HDS ; HDS v2 (2024) impose un hébergement dans l'EEE ; certification de MedX pour les activités qu'elle opère elle-même	Régions cloud certifiées HDS (France + Allemagne) ; seuls des services certifiés traitent des données de santé ; plan de certification de MedX (§5.12)
Référentiels nationaux de la e-santé (ANS : PGSSI-S, INS, Pro Santé Connect, cadre d'interopérabilité)	Systèmes d'information de santé français	Politique de sécurité, identifiant national de santé, authentification des professionnels, formats interopérables	Politiques alignées sur la PGSSI-S, INS dans la ressource Patient, fédération Pro Santé Connect, modèle FHIR / IPS

Cadre	Pourquoi il s'applique	Obligations clés	Comment la conception s'y conforme
Règles de la télémédecine (Code de la santé publique, art. R.6316-1 et suivants)	Téléconsultations	Professionnels authentifiés, patients identifiés et consentants, échanges sécurisés, compte rendu au dossier	Praticiens vérifiés + MFA, assurance de l'identité du patient, consentement à la réservation, vidéo chiffrée de bout en bout, compte rendu de consultation au dossier
HIPAA (États-Unis) — en cas d'expansion	Données de santé de patients américains	Privacy, Security et Breach Notification Rules ; BAA ; « minimum nécessaire »	Cellule américaine séparée, mêmes contrôles, BAA avec les sous-traitants
PCI DSS v4.0	Paiements par carte	Protéger les données des titulaires de carte	Champs hébergés par le PSP → **SAQ A** ; intégrité des scripts de la page de paiement
eIDAS (UE 910/2014 modifié par 2024/1183)	Signatures et horodatages électroniques	Valeur juridique des signatures et des horodatages	Signatures des prescripteurs (options qualifiées), horodatages qualifiés pour les ancrages d'intégrité
NIS2 (UE 2022/2555)	La santé est un secteur hautement critique	Mesures de gestion des risques ; signalement des incidents : alerte précoce sous 24 h, notification sous 72 h, rapport final sous 1 mois	Mesures adoptées dès la conception (§5.8 à 5.10) ; processus de signalement dans le plan de gestion des incidents
Espace européen des données de santé (UE 2025/327)	Accès des patients à leurs données de santé électroniques et échanges (obligations progressives)	Droits d'accès et de partage des patients, exigences d'interopérabilité et de journalisation des systèmes de DSE	Modèle FHIR / IPS, export patient et journal des accès, piste d'audit
Règlement relatif aux dispositifs médicaux (UE 2017/745)	Un logiciel d'aide à la décision clinique peut être un dispositif médical	Qualification, marquage CE si concerné	Triage et contrôles de prescription évalués pour qualification ; maintenus à base de règles et validés
Normes	Assurance et bonnes pratiques	ISO/IEC 27001 et 27701, ISO 27799 (santé), OWASP ASVS et API Top 10, NIST SP 800-63B, CIS Benchmarks, sécurité FHIR (portées SMART), IHE BALP (audit)	Utilisées comme référentiels de contrôles (§5.8)

5.3 Modèle de menaces

Construit avec STRIDE à partir des flux de données de l'architecture ; le tableau liste les menaces au plus fort impact pour MedX.

#	Menace	Exemple	Principales parades	Risque résiduel
T1	Prise de contrôle de compte	Bourrage d'identifiants sur des patients, hameçonnage d'un médecin	MFA (résistante à l'hameçonnage pour les professionnels), vérification des mots de passe compromis, limitation de débit, jetons liés par DPoP, alertes de nouvel appareil	Faible
T2	Contrôle d'accès défaillant au niveau objet	Modifier un identifiant dans une URL pour lire le dossier d'un autre patient	Décision ABAC sur chaque objet, UUID, tests d'autorisation négatifs en CI, validation de schéma à la passerelle	Faible

#	Menace	Exemple	Principales parades	Risque résiduel
T3	Curiosité d'un initié	Un employé ou un médecin qui consulte le dossier d'une célébrité	Aucun accès du personnel aux données de santé, modèle d'autorisations de soin, audit de chaque lecture, alertes UEBA, journal des accès visible par le patient, sanctions	Moyen → Faible
T4	Rançongiciel / attaque destructrice	Chiffrement ou suppression des bases et des sauvegardes	Coffre de sauvegarde immuable dans un compte séparé, Object Lock, moindre privilège, segmentation, EDR, restaurations testées	Faible
T5	Exfiltration de données	Instantané divulgué, compartiment mal configuré, service compromis	Chiffrement applicatif par patient (les données volées sont chiffrées), politiques de clés KMS, listes blanches en sortie, CSPM, DLP sur les journaux	Faible
T6	Injections et attaques web	Injection SQL, XSS, SSRF	Requêtes paramétrées, encodage des sorties, CSP stricte, WAF, SAST / DAST, contrôle des sorties réseau	Faible
T7	Écoute des consultations	Homme du milieu sur la vidéo	DTLS-SRTP + chiffrement de bout en bout, TLS 1.3, épinglage de certificats dans les applications	Faible
T8	Dépôt de fichier malveillant	Logiciel malveillant déguisé en PDF médical	Quarantaine, antivirus, contrôle du type par signature binaire, assainissement des PDF, analyseurs isolés	Faible
T9	Compromission de la chaîne d'approvisionnement	Dépendance ou image de base malveillante	Analyse des dépendances, versions épinglées, SBOM, images signées vérifiées à l'admission, provenance des builds	Moyen
T10	Déni de service et abus	Robots de réservation, aspiration de l'annuaire	CDN / WAF, gestion des robots, limitation de débit, salle d'attente virtuelle	Faible
T11	Fraude à l'ordonnance	Ordonnances falsifiées ou réutilisées	Ordonnances signées, point de vérification avec statut en temps réel, QR codes sans contenu	Faible
T12	Abus du bris de glace	Fausse urgence pour lire un dossier	Droit dédié, justification, MFA renforcée, alerte en temps réel, information du patient, revue obligatoire, sanctions	Faible à moyen
T13	Fraude au paiement	Cartes volées	3-D Secure (authentification forte), score de risque du PSP, limites de vélocité	Faible
T14	Fuite par les notifications	Un SMS qui révèle un diagnostic à un proche	Aucune donnée de santé dans les messages externes, variables de modèle en liste blanche	Faible
T15	Mauvaise configuration du cloud	Compartiment public, journalisation désactivée	Garde-fous d'organisation (accès public interdit, désactivation du chiffrement ou de la journalisation interdite), analyse de l'IaC, CSPM	Faible

5.4 Gestion des identités et des accès

Le détail se trouve au §2.1 Gestion des utilisateurs ; les règles qui touchent à la sécurité sont :

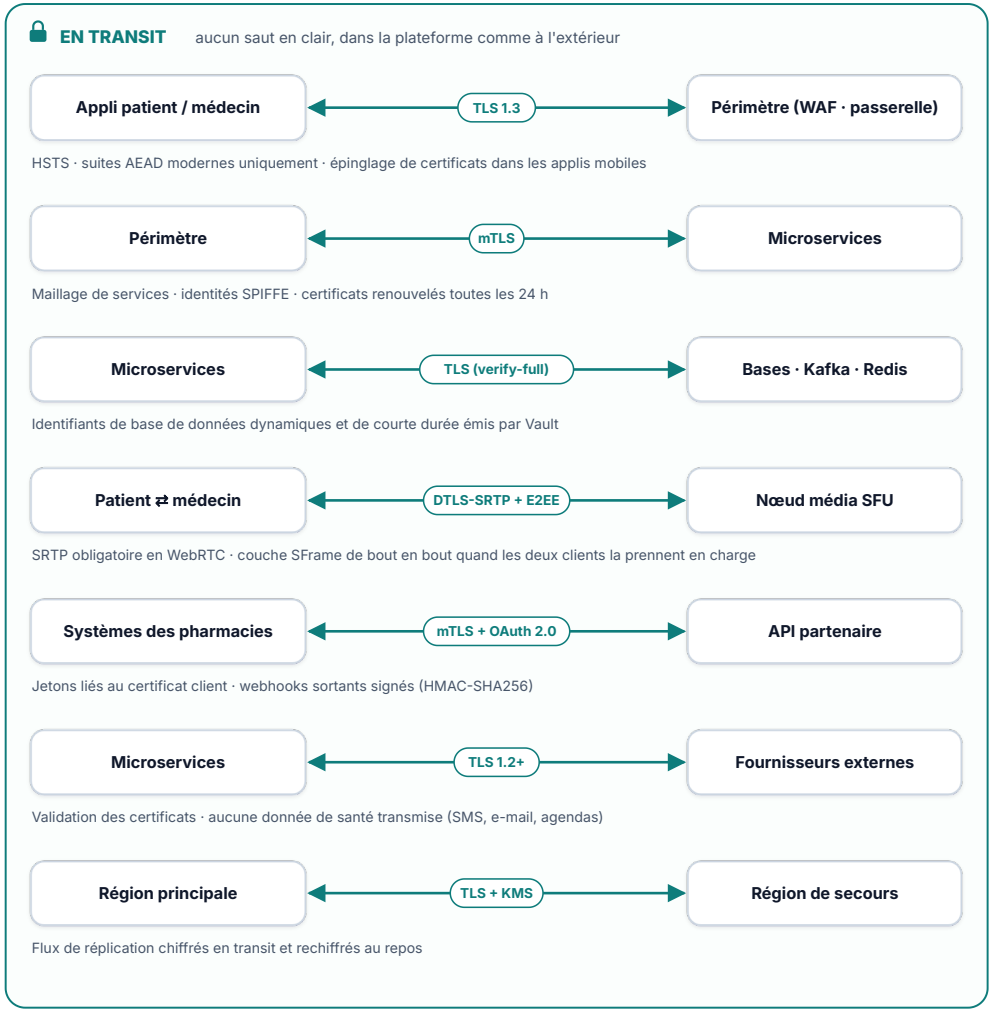
- **Niveau d'authentification** — patients : mot de passe ou passkey + MFA selon le risque ; professionnels : MFA résistante à l'hameçonnage en permanence (passkeys, clés de sécurité, carte professionnelle via Pro Santé Connect) ; **la signature d'une ordonnance et le bris de glace exigent une authentification récente liée à un matériel** (renforcement dans les 15 minutes). Jetons de courte durée, restreints à une audience, liés par DPoP ou par certificat.
- **Autorisation** — RBAC pour les permissions générales + ABAC (relation de soin, consentement, finalité, étiquettes de sensibilité, organisation) évalué par OPA à côté de chaque service ; refus par défaut ; obligations de masquage.
- **Accès à privilèges** — aucun accès administrateur permanent à la production : élévation juste-à-temps avec approbation, MFA, 4 heures au maximum et enregistrement de session ; les administrateurs de la plateforme **ne peuvent pas lire les données de santé** (les clés de chiffrement applicatif ne sont pas utilisables par leurs rôles).

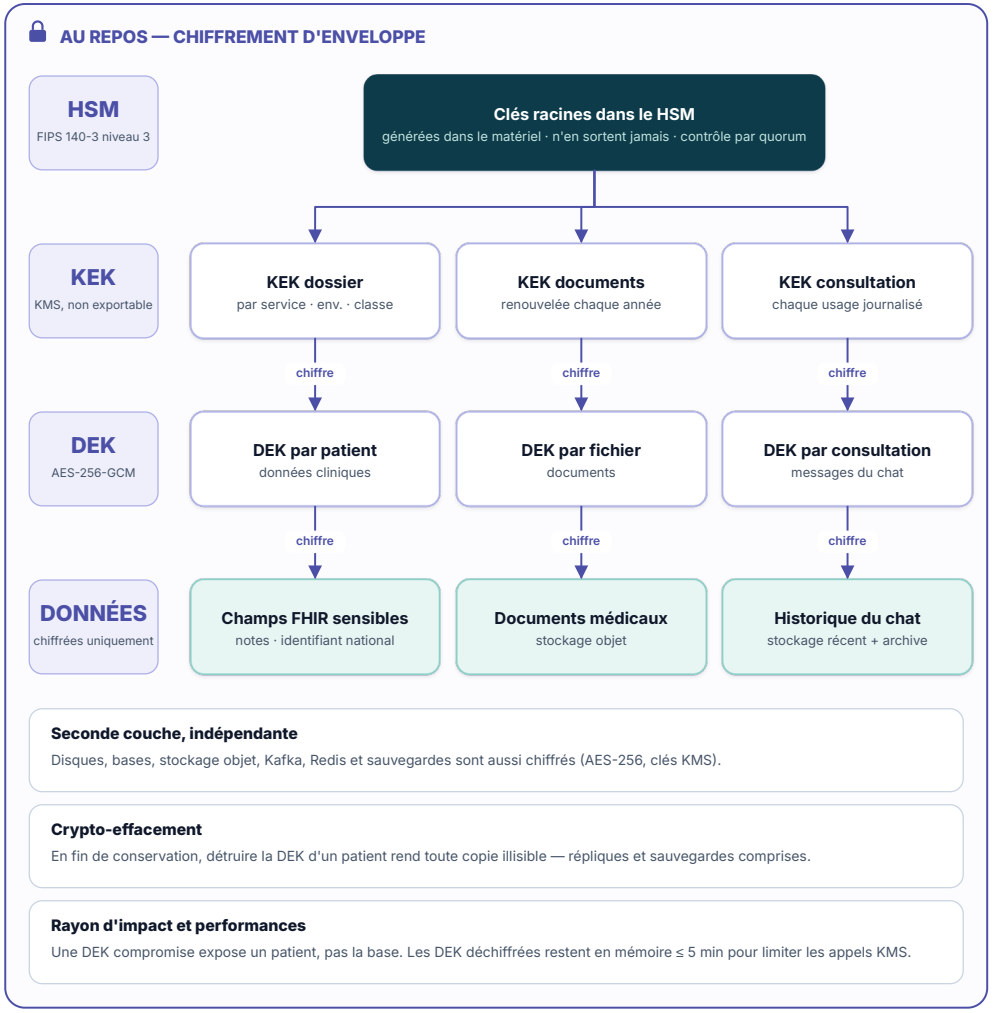
- **Identités de service** — identités SPIFFE via le maillage (mTLS) ; les politiques d'autorisation du maillage définissent quel service peut appeler quel service ; un rôle IAM cloud par service, au moindre privilège (par exemple, seul le rôle du dossier patient peut utiliser la KEK du dossier patient).
- **Cycle de vie** — désactivation automatique des comptes des collaborateurs qui partent ; synchronisation mensuelle avec les registres professionnels qui suspend les praticiens radiés ; **recertification trimestrielle** des droits tels que `acces_urgence` ; séparation des tâches entre développeurs, administrateurs de bases de données et dépositaires de clés ; principe des quatre yeux pour les opérations sensibles.

5.5 Chiffrement en transit

Chiffrement en transit et au repos

Exigence de priorité haute H1 · chaque saut chiffré · deux couches indépendantes au repos · clés générées et conservées dans un KMS adossé à des HSM





Chiffrement en transit et au repos

Canal	Protocole	Configuration
Applications ↔ périmètre	**TLS 1.3** (TLS 1.2 avec suites ECDHE + AEAD uniquement pour les anciens appareils ; TLS ≤ 1.1 désactivé)	HSTS avec préchargement, agrafage OCSP, renouvellement automatique des certificats, épinglage de clés publiques (avec clés de secours) dans les applications mobiles
Périmètre ↔ services, service ↔ service	**mTLS** (maillage de services, mode STRICT — le texte clair est refusé)	Identités SPIFFE des charges de travail, certificats renouvelés toutes les 24 h, politiques d'autorisation par appelant
Services ↔ bases de données	TLS avec vérification du serveur	PostgreSQL `sslmode=verify-full` ; TLS pour Redis, Kafka (plus authentification client mTLS), Cassandra (client et entre nœuds), OpenSearch
Audio / vidéo	**DTLS-SRTP** (obligatoire en WebRTC) + **chiffrement de bout en bout** (SFrame) pour le tête-à-tête lorsque c'est pris en charge	TURN sur TLS 443 sur les réseaux restrictifs
Logiciels de pharmacie, partenaires	**mTLS + OAuth 2.0** avec jetons liés au certificat	Webhooks sortants signés HMAC-SHA256 avec horodatage et protection contre le rejeu
Fournisseurs externes (SMS, e-mail, push, agendas, PSP)	TLS 1.2+ avec validation des certificats	Aucune donnée de santé dans les contenus ; SMTP avec MTA-STS, SPF / DKIM / DMARC
Réplication entre régions	TLS	Rechiffré au repos avec des clés multi-régions

Politique cryptographique — suites TLS 1.3 (AES-128/256-GCM, ChaCha20-Poly1305) avec confidentialité persistante (X25519, P-256). Comme les données de santé doivent rester confidentielles pendant des décennies, MedX active l'**échange de clés hybride post-quantique** (X25519 + ML-KEM) partout où les clients et les répartiteurs de charge le prennent en charge, contre les attaques « collecter maintenant, déchiffrer plus tard » (l'agilité cryptographique est une exigence de conception : les algorithmes relèvent de la configuration, pas du code).

5.6 Chiffrement au repos et gestion des clés

Deux couches indépendantes

Couche	Portée	Mécanisme	Protège contre
1 — Chiffrement du stockage	Chaque volume, base de données, instantané, sauvegarde, objet, journal Kafka, Redis, Cassandra, OpenSearch	AES-256 avec des clés KMS gérées par MedX	Disques perdus, instantanés volés, accès aux supports côté fournisseur
2 — Chiffrement applicatif (enveloppe)	Données C4 : éléments FHIR sensibles, documents, messagerie, identifiants nationaux, coordonnées	**AES-256-GCM** dans le service avec des clés de données par patient / par fichier / par consultation ; les données authentifiées additionnelles lient le chiffré à son enregistrement	Compromission au niveau de la base, administrateurs aux privilèges excessifs, répliques ou exports mal configurés, injection SQL renvoyant des lignes brutes

Hiérarchie des clés — clés racines dans des **HSM (FIPS 140-3 niveau 3)** → **KEK** dans le KMS par service × environnement × classe de données (jamais exportées) → **clés de données (DEK)** générées par le KMS, stockées uniquement sous forme chiffrée à côté des données → données chiffrées.

Étape du cycle de vie	Règle
Génération	Uniquement dans le HSM / KMS ; aucune clé à long terme générée par une application
Accès	Politiques de clés KMS : seul le rôle du service propriétaire peut déchiffrer avec sa KEK ; les administrateurs de clés ne peuvent pas les utiliser pour déchiffrer ; chaque usage est journalisé dans le compte de sécurité

Étape du cycle de vie	Règle
Cache	DEK déchiffrées conservées en mémoire du processus ≤ 5 minutes (LRU borné), jamais écrites sur disque ni dans les journaux
Renouvellement	KEK renouvelées automatiquement chaque année (anciennes versions conservées pour le déchiffrement ; DEK rechiffrées progressivement) ; DEK renouvelées en cas de soupçon de compromission
Séparation	Clés de production inutilisables depuis les comptes hors production → un instantané de production ne peut pas être déchiffré hors production
Reprise après sinistre	Clés multi-régions pour la région de secours ; Vault répliqué
Destruction	**Crypto-effacement** : à la fin de la durée de conservation, les clés de données du patient sont détruites ; les registres de clés ne gardent que 35 jours de sauvegardes, de sorte que toute copie restante des données — répliques, sauvegardes — devient illisible

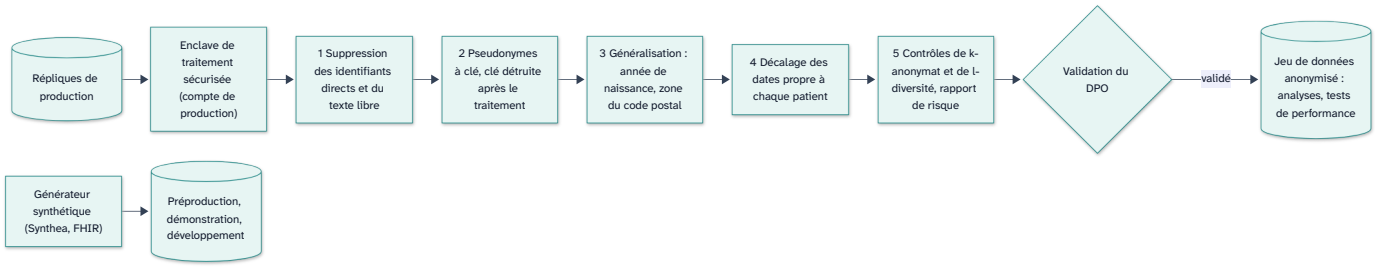
Autres protections — mots de passe hachés avec Argon2id ; secrets dans Vault (identifiants de base de données dynamiques, chiffrement Transit pour les jetons d'intégration) ; cartes de paiement tokenisées par le PSP ; les applications mobiles ne conservent aucune donnée de santé au-delà de la session, sauf les documents explicitement téléchargés par l'utilisateur, protégés par le chiffrement de fichiers adossé au trousseau du système et effacés à la déconnexion.

5.7 Masquage, caviardage et anonymisation

Masquage dynamique (M4) — le moteur de politiques renvoie des obligations de masquage appliquées avant que la moindre réponse ne quitte un service (les agents de support voient `+33 6 •• •• •• 42`, les pharmaciens ne voient aucun diagnostic, le bris de glace exclut les notes de psychothérapie…). La matrice complète est au §2.4.

Caviardage — les documents partagés ou exportés peuvent être expurgés des sections étiquetées ; le caviardage des PDF supprime la couche de texte (un vrai caviardage, pas un rectangle noir) ; journaux et traces ne contiennent jamais de données de santé (champs en liste blanche, identifiants tokenisés, analyseur automatique sur des échantillons de journaux).

Anonymisation pour la préproduction et les démonstrations (B4) — règle : *les données de santé de production ne quittent jamais la production*.



Environnement	Données	Contrôles
Développement, préproduction, démonstration	Patients **synthétiques** (par exemple des lots FHIR Synthea) et rendez-vous, ordonnances et paiements générés ; locataire de démonstration marqué « DÉMO »	Comptes séparés, aucun chemin réseau ni accès aux clés de production

Environnement	Données	Contrôles
Tests de performance nécessitant des distributions réalistes	Extraits **anonymisés** produits par la chaîne ci-dessus	k ≥ 10 sur les quasi-identifiants, l-diversité sur les attributs sensibles, analyse documentée du risque de réidentification, validation du DPO, expiration du jeu de données
Analyses et recherche	Données anonymisées ; données pseudonymisées uniquement sous des contrôles de niveau production et avec base légale ou consentement	Registre des finalités, revues des accès

5.8 Sécurité des applications et des API

- **Cycle de développement sécurisé** — modélisation des menaces pour chaque fonctionnalité significative, référents sécurité dans chaque équipe, socle **OWASP ASVS niveau 2** et **niveau 3** pour la gestion des utilisateurs, le dossier patient, l'accès d'urgence et les ordonnances ; critères d'acceptation de sécurité dans la définition de « terminé ».
- **Contrôles automatiques en CI** — SAST, analyse des dépendances (SCA), détection de secrets, analyse de l'infrastructure sous forme de code, analyse des images de conteneurs ; DAST et fuzzing d'API sur la préproduction ; **suites de tests d'autorisation** avec cas négatifs (le patient A ne doit jamais lire le patient B).
- **Tests indépendants** — test d'intrusion avant le lancement puis chaque année et après tout changement majeur ; programme de bug bounty après le lancement.
- **Protections des API (OWASP API Top 10)** — autorisation au niveau des objets et des propriétés, listes blanches des réponses (pas d'exposition massive), modèles de requête explicites (pas d'affectation de masse), limites de débit et quotas, protection SSRF par une passerelle de sortie aux destinations en liste blanche, inventaire complet des API dans la passerelle.
- **Web** — CSP stricte à base de nonces, Trusted Types, SRI, HSTS, `frame-ancestors 'none'` (sauf le composant du PSP), cookies SameSite, jetons CSRF pour les sessions par cookie.
- **Mobile (OWASP MASVS)** — épinglage de certificats, attestation de l'application, écrans sensibles masqués dans les captures d'écran et le sélecteur de tâches, aucune donnée de santé dans les journaux de l'appareil, appareils rootés / jailbreakés traités comme un signal de risque.
- **Chaîne d'approvisionnement** — dépendances épinglées, SBOM pour chaque image, images de base minimales (distroless) mises à jour chaque semaine, **images signées vérifiées à l'admission**, provenance des builds (SLSA), uniquement des modifications revues (branches protégées).

5.9 Sécurité de l'infrastructure et du réseau

- **Zone d'atterrissage** — comptes séparés (production, secours, sécurité et archive des journaux, services partagés, hors production) sous garde-fous d'organisation : stockage public interdit, désactivation du chiffrement ou de la journalisation interdite, régions hors EEE interdites.
- **Réseau** — sous-réseaux privés pour tous les services et toutes les bases ; exposition publique limitée aux répartiteurs de charge et aux nœuds média ; politiques réseau Kubernetes en **refus par défaut** ; politiques d'autorisation du maillage ; points d'accès privés vers les services cloud ; sorties uniquement via des passerelles contrôlées avec listes blanches.
- **Durcissement des charges de travail** — benchmarks CIS, profil Pod Security « restricted », conteneurs non root et en lecture seule, seccomp / AppArmor, détection des menaces à l'exécution, EDR sur les nœuds ; délais de correction des vulnérabilités : critiques < 7 jours, élevées < 30 jours.
- **Accès du personnel** — proxy zéro confiance tenant compte de l'identité (ni VPN, ni SSH) ; accès à la production uniquement par élévation juste-à-temps.
- **Sécurité physique** — héritée du fournisseur cloud certifié HDS / ISO 27001.

5.10 Journalisation, détection et réponse aux incidents

- **Journalisation de sécurité** — événements d'authentification, refus d'autorisation, actions d'administration, usage du KMS, flux réseau, piste d'audit ; envoyés vers le **compte de sécurité** (immuable, 12 mois pour les journaux techniques, ≥ 6 ans pour la piste d'audit).
- **Détection (SIEM + UEBA)** — événements de bris de glace, tentatives d'accès sans relation de soin, lectures ou exports massifs de dossiers, déplacements impossibles, MFA désactivée, élévation de privilèges, volumes anormaux de déchiffrements KMS, nouveau point d'accès public.
- **Réponse** — plans documentés pour les violations de données, les rançongiciels, les prises de contrôle de compte et les abus du bris de glace ; astreinte 24 h/24 et 7 j/7 ; niveaux de gravité ; préparation à l'investigation (journaux conservés, procédures d'instantanés) ; exercices sur table deux fois par an.

Obligation de notification	Délai
RGPD — autorité de contrôle (CNIL)	**72 h** après en avoir pris connaissance (art. 33)
RGPD — patients concernés	Dans les meilleurs délais lorsque le risque est élevé (art. 34)
NIS2 — CSIRT / autorité nationale	Alerte précoce sous **24 h**, notification sous **72 h**, rapport final sous **1 mois**
Secteur de la santé en France — incidents graves	Déclaration sur le portail de signalement des autorités sanitaires / CERT Santé
HIPAA (cellule américaine)	Personnes concernées sous 60 jours ; HHS selon les règles applicables

5.11 Opérations de conformité à la protection des données

Domaine	Mesure
Gouvernance	DPO désigné ; registre des traitements ; **AIPD avant le lancement** et à chaque changement majeur (obligatoire pour des données de santé à grande échelle) ; revue de protection des données dans le processus de conception
Bases légales	Soins : art. 9(2)(h) ; contrat et obligations légales pour la facturation ; **consentement explicite** uniquement lorsqu'il est requis (recherche, marketing, partages facultatifs, cookies non essentiels)
Transparence	Mentions d'information à plusieurs niveaux dans les applications ; page **« qui a consulté mon dossier »** pour les patients
Droits des personnes	Export en libre-service (lot FHIR / PDF), rectification par le médecin traitant (l'amendement conserve l'historique), effacement des données de compte (le dossier médical est conservé pendant sa durée légale), opposition et limitation lorsqu'elles s'appliquent (par exemple recherche, bris de glace lorsque la loi le permet) ; réponse sous un mois
Sous-traitants	Contrats de sous-traitance, hébergement certifié HDS, prestataires établis dans l'UE pour toute donnée personnelle ; **aucune donnée de santé envoyée aux fournisseurs de messagerie ou d'agenda** ; BAA pour une future cellule américaine
Mineurs	Délégation parentale, règles de confidentialité des adolescents appliquées par les politiques
Protection par défaut	Recherche et marketing désactivés par défaut ; partage minimal ; aucun traceur tiers dans les espaces authentifiés

5.12 Feuille de route de conformité et d'assurance

Jalon	Échéance
AIPD, registre des traitements, politiques de sécurité (alignées sur la PGSSI-S), contrat d'hébergement certifié HDS	Avant le premier vrai patient
Test d'intrusion externe	Avant le lancement, puis chaque année
Certification HDS pour les activités opérées par MedX elle-même	Avant le lancement (selon le périmètre)
Attestation PCI DSS SAQ A	Au lancement du paiement

Jalon	Échéance
Certification ISO/IEC 27001 (+ 27701)	Années 1 à 2
SOC 2 Type II, préparation HIPAA	Avant une expansion aux États-Unis

La conformité est continue : garde-fous et politiques sous forme de code, collecte automatisée des preuves, revues trimestrielles des accès, exercices annuels de reprise après sinistre et de gestion d'incident.

5.13 Exigences de priorité haute — contrôles et preuves

Exigence	Contrôles	Comment c'est vérifié
H1 Confidentialité des données (chiffrement au repos et en transit)	TLS 1.3 / mTLS partout ; chiffrement AES-256 du stockage ; chiffrement d'enveloppe par patient ; clés adossées à des HSM ; aucune donnée de santé hors de la zone clinique	Contrôles de conformité du chiffrement sur 100 % des stockages ; analyses de configuration TLS ; maillage en mode STRICT ; détecteur de données de santé dans les journaux
H2 Dossier patient	Entrepôt FHIR, validation, versionnage, registre des consentements, audit de chaque accès	Vérification nocturne des chaînes de hachage ; tests de couverture de l'audit ; suite de tests du contrôle d'accès
H3 Accès d'urgence	Bris de glace avec droit dédié, MFA renforcée, autorisation limitée dans le temps, déploiement de niveau 0 dans deux régions, revue a posteriori	Sondes synthétiques (p95, disponibilité) ; **100 % des bris de glace revus sous 72 h** ; exercices de reprise
H4 Authentification et autorisation	Keycloak (OIDC, MFA), OPA RBAC + ABAC, accès à privilèges juste-à-temps	100 % de MFA pour les professionnels ; recertification trimestrielle réalisée ; tests unitaires des politiques en CI
H5 Intégrité des données et fichiers sécurisés	ACID, ajout seul, chaînes de hachage + ancrage, sommes de contrôle, Object Lock, sauvegardes immuables, analyse des fichiers	Tests de restauration hebdomadaires + exercice complet trimestriel ; vérification des sommes de contrôle sans aucune divergence ; contrôles de configuration WORM

6. Décisions d'architecture et compromis

Pourquoi la conception a cette forme. Chaque décision est rattachée aux priorités de MedX (Annexe 2) et indique **ce à quoi on renonce** — une conception sans coûts assumés n'est pas une conception.

6.1 Les tensions qui ont façonné l'architecture

Tension	Comment MedX la résout	Priorité qui a tranché
Confidentialité ⟷ disponibilité en urgence	L'accès en urgence n'est jamais bloqué par un circuit d'approbation ; il est étroit, limité dans le temps, entièrement audité et revu (bris de glace).	H1 + H3
Sécurité ⟷ facilité d'usage	Strict pour les professionnels (MFA résistante à l'hameçonnage, authentification renforcée), fluide pour les patients (passkeys, MFA selon le risque, biométrie).	H4, puis M1-M2
Cohérence ⟷ disponibilité	Cohérence forte là où une erreur nuit (écritures au dossier, réservations, ordonnances, paiements) ; cohérence à terme ailleurs ; le chemin d'urgence privilégie la disponibilité avec une fraîcheur bornée (< 5 s).	H2, H3, H5
Isolation ⟷ complexité d'exploitation	Huit services métier (pas davantage), regroupés en zones, sur une plateforme commune au modèle de service standardisé.	H1, H3
Résilience ⟷ coût	Actif-actif uniquement pour le niveau 0 (accès d'urgence, connexion) ; secours tiède pour le reste.	H3
Messages riches ⟷ confidentialité	Messages externes génériques + liens profonds vers l'application authentifiée.	H1
Construire ⟷ acheter	Construire ce qui différencie ou est sensible (dossier, accès d'urgence, parcours de soin, politiques) ; acheter les commodités (logiciel d'IdP, PSP, messagerie, logiciel SFU).	Toutes — libère de la capacité pour les priorités hautes

6.2 Registre des décisions

ADR	Décision	Lien avec les priorités	Principale alternative écartée	Ce à quoi on renonce
01	Microservices par contexte métier, regroupés en zones de sécurité	H1, H3, scalabilité	Monolithe modulaire	Une exploitation plus simple
02	HL7 FHIR R4 (+ IPS) comme modèle clinique, sur PostgreSQL	H2, interopérabilité	Schéma relationnel sur mesure	Un peu d'efficacité de stockage
03	PostgreSQL par défaut ; stockages spécialisés uniquement si c'est justifié	H5, simplicité	Persistance polyglotte « NoSQL d'abord »	Une très forte capacité d'écriture dès le départ
04	Historique clinique en ajout seul + chaînes de hachage + ancrages quotidiens signés	H2, H5	Mises à jour en place + table d'audit	≈ 30 % de stockage en plus
05	Deux couches de chiffrement avec des clés d'enveloppe par patient	H1	Chiffrement du stockage seul	De la complexité, ≈ 1 ms par requête
06	Bris de glace avec revue a posteriori sur un chemin de niveau 0 isolé et présent dans deux régions	H3	Circuit d'approbation préalable	Un certain risque d'abus (atténué)
07	IdP éprouvé (Keycloak) + politiques OPA (RBAC + ABAC) appliquées localement	H4	Authentification maison ; RBAC seul	Exploiter un cluster d'IdP avec état
08	Intégration pilotée par les événements (Kafka) avec outbox transactionnelle	H5, scalabilité	Chaînes d'appels synchrones	Une cohérence à terme à maîtriser
09	SFU WebRTC auto-hébergé (LiveKit), chiffrement de bout en bout par défaut en tête-à-tête	H1, M2	CPaaS vidéo ; pair-à-pair ; MCU	Exploiter des serveurs média ; pas d'enregistrement

ADR	Décision	Lien avec les priorités	Principale alternative écartée	Ce à quoi on renonce
10	Aucune donnée de santé hors de la frontière de confiance (messages, agendas, événements, journaux)	H1	Notifications riches	Un peu de confort
11	Champs de paiement hébergés par le PSP → PCI DSS SAQ A	B5, H1	Manipuler les données de carte	La maîtrise de l'interface de paiement
12	Multi-AZ partout + secours tiède ; actif-actif uniquement pour le niveau 0	H3, H5	Actif-actif complet	Un RTO de 1 à 4 h pour les niveaux 1-2
13	Données synthétiques par défaut hors production ; anonymisation sous contrôle du DPO	B4, H1	Copies masquées de la production	Un peu de réalisme dans les tests
14	Livrer par priorité : socle sécurisé → parcours de soin → écosystème	Toutes	MVP guidé par les fonctionnalités	Un lancement commercial plus tardif

6.3 Fiches de décision

ADR-01 — Microservices par contexte métier, regroupés en zones de sécurité

- **Contexte** — huit capacités métier aux sensibilités de données très différentes (données de santé, données proches du paiement, coordonnées), aux profils de charge très différents (bande passante vidéo, lectures du dossier, exactitude des paiements) et à la criticité variable (niveaux 0 à 2).
- **Décision** — un service par composant de l'Annexe 1, plus des services de plateforme ; des zones (identité, clinique, communication, paiement) avec des pools de nœuds et des politiques réseau dédiés.
- **Alternatives** — monolithe (un seul rayon d'impact) ; monolithe modulaire (bon point de départ, mais sans isolation du chemin d'urgence ni des périmètres de conformité) ; fonctions en tant que service (démarrages à froid, peu adaptées à WebRTC / WebSocket).
- **Conséquences** — ✅ isolation des données de santé et des pannes, mise à l'échelle et livraisons indépendantes ; ❌ complexité des systèmes distribués → modèle de service standardisé, maillage de services, équipe plateforme, limite stricte du nombre de services.

ADR-02 — HL7 FHIR R4 (+ International Patient Summary) comme modèle de données clinique

- **Contexte** — le dossier doit être complet, valide, versionné et échangeable avec les services nationaux et les hôpitaux ; l'accès d'urgence a besoin d'une synthèse normalisée.
- **Décision** — ressources FHIR stockées par un serveur FHIR (HAPI FHIR sur PostgreSQL) ; profil IPS pour la synthèse critique ; profils nationaux pour la validation.
- **Alternatives** — schéma sur mesure (démarrage plus rapide, intégrations coûteuses ensuite) ; base documentaire (souple, mais transactions plus faibles et une technologie de plus).
- **Conséquences** — ✅ interopérabilité, validation, historique et recherche disponibles d'emblée ; ❌ un stockage générique moins efficace → projections pour l'interface et partitionnement.

ADR-03 — PostgreSQL par défaut, stockages spécialisés uniquement si c'est justifié

- **Décision** — PostgreSQL pour tous les systèmes de référence ; Redis (éphémère), Cassandra (journaux en ajout intensif avec TTL), stockage objet (fichiers), OpenSearch (recherche) seulement là où PostgreSQL convient mal.
- **Pourquoi** — moins de technologies à sécuriser, certifier, sauvegarder et maîtriser ; contraintes et transactions protègent l'intégrité (par exemple la contrainte d'exclusion contre la double réservation).

- **Conséquences** — ✅ intégrité et simplicité ; ❌ une très forte charge en écriture passe par la trajectoire de sharding (§4.7).

ADR-04 — Historique clinique en ajout seul, chaînes de hachage et ancrages signés

- **Décision** — aucune mise à jour en place ni suppression physique de données cliniques pendant la durée de conservation ; chaque version est chaînée par hachage ; une racine de Merkle quotidienne est signée dans le HSM, horodatée et stockée en WORM.
- **Pourquoi** — intégrité des données (H5) et conformité du dossier (H2) : l'historique doit être prouvable, pas simplement « journalisé ».
- **Conséquences** — ✅ toute altération est détectable, même par un administrateur ; ❌ ≈ 30 % de stockage en plus, des traitements de vérification.

ADR-05 — Deux couches de chiffrement avec des clés d'enveloppe par patient

- **Décision** — chiffrement du stockage partout + chiffrement applicatif AES-256-GCM des données C4 avec des clés par patient / par fichier / par consultation, elles-mêmes chiffrées par des KEK adossées à des HSM.
- **Alternatives** — chiffrement du stockage seul (ne protège ni contre une compromission au niveau de la base ni contre des exports divulgués) ; une clé KMS par patient (des millions de clés KMS : coût et quotas).
- **Conséquences** — ✅ les données volées sont inutilisables, le rayon d'impact d'une clé = un patient, crypto-effacement en fin de conservation ; ❌ complexité de la gestion des clés, ≈ 1 ms de surcoût avec cache des clés, politiques de sauvegarde des clés à soigner.

ADR-06 — Bris de glace avec revue a posteriori, sur un chemin de niveau 0 isolé

- **Contexte** — H3 exige un accès *immédiat* pour les professionnels habilités ; H1 exige une confidentialité stricte.
- **Décision** — bris de glace en libre-service (droit dédié + justification + MFA renforcée) → autorisation en lecture seule de 4 heures → synthèse IPS pré-calculée ; alerte en temps réel, information du patient, revue obligatoire sous 72 h ; déploiement et base de données séparés, actifs dans deux régions.
- **Alternatives** — approbation préalable par un superviseur (trop lent à 3 h du matin aux urgences) ; accès ouvert à tous les médecins (risque inacceptable pour la vie privée).
- **Conséquences** — ✅ accès en quelques secondes, même en cas de panne ; ❌ un abus reste possible, mais il est visible, attribuable et sanctionné ; une unité de déploiement de plus.

ADR-07 — IdP éprouvé + autorisation sous forme de politiques en code

- **Décision** — Keycloak pour l'authentification (OIDC, MFA, passkeys, fédération) ; sidecars OPA qui évaluent des politiques RBAC + ABAC à partir de paquets signés ; jetons de courte durée validés localement.
- **Alternatives** — authentification maison (risque élevé) ; RBAC seul (incapable d'exprimer la relation de soin, le consentement ou l'urgence) ; serveur d'autorisation central appelé à chaque requête (latence et point de défaillance unique).
- **Conséquences** — ✅ robuste, standard, testable, rapide ; ❌ la révocation n'est pas instantanée (bornée par des jetons de 5 à 10 min + liste de refus), un IdP avec état à exploiter dans deux régions.

ADR-08 — Intégration pilotée par les événements avec outbox transactionnelle

- **Décision** — les services publient des événements métier (identifiants et statuts uniquement) via une outbox relayée vers Kafka ; les consommateurs sont idempotents ; appels synchrones uniquement quand un utilisateur

attend (≤ 2 sauts).

- **Alternatives** — chaînes synchrones (pannes en cascade, couplage fort) ; publication après validation sans outbox (événements perdus ou fantômes).
- **Conséquences** — ✅ découplage, résilience, alimentation naturelle de l'audit et des projections ; ❌ une cohérence à terme à prendre en compte dans la conception (sagas, traitements de rapprochement).

ADR-09 — SFU WebRTC auto-hébergé avec chiffrement de bout en bout

- **Décision** — SFU LiveKit et serveurs TURN sur une infrastructure certifiée HDS ; simulcast et débit adaptatif ; chiffrement de bout en bout activé par défaut pour les consultations en tête-à-tête ; aucun enregistrement.
- **Alternatives** — CPaaS (intégration rapide, mais média traité hors du périmètre certifié de MedX et coûteux à grande échelle — conservé comme solution de repli) ; maillage pair-à-pair (aucune maîtrise de la qualité, problèmes de relais) ; MCU (gourmand en CPU, incompatible avec le chiffrement de bout en bout).
- **Conséquences** — ✅ souveraineté des données, confidentialité, maîtrise des coûts ; ❌ compétences d'exploitation média nécessaires, aucun enregistrement ni transcription côté serveur tant que le chiffrement de bout en bout est actif.

ADR-10 — Aucune donnée de santé hors de la frontière de confiance

- **Décision** — SMS, e-mails, bannières push, agendas externes, contenus des événements, journaux et traces ne contiennent jamais de données de santé ; le détail n'est affiché qu'après authentification dans l'application.
- **Conséquences** — ✅ supprime des catégories entières de fuites et tient les fournisseurs tiers hors du périmètre HDS ; ❌ des messages moins informatifs (compensés par les liens profonds).

ADR-11 — Champs de paiement hébergés par le PSP (PCI DSS SAQ A)

- **Décision** — les données de carte vont directement de l'appareil au PSP ; MedX ne stocke que des jetons ; 3-D Secure ; grand livre en partie double propre à MedX pour les mouvements d'argent.
- **Conséquences** — ✅ périmètre PCI minimal et aucune donnée de carte à voler ; ❌ interface de paiement contrainte par les composants du PSP.

ADR-12 — Multi-AZ partout, secours tiède, actif-actif uniquement pour le niveau 0

- **Décision** — chaque couche est redondée sur 3 AZ (RPO 0 dans la région) ; une seconde région européenne en secours tiède (RPO ≤ 1 min) ; accès d'urgence et connexion actifs dans les deux régions.
- **Alternatives** — actif-actif complet (conflits multi-maîtres sur les données cliniques, coût doublé) ; région unique (inacceptable pour le niveau 0).
- **Conséquences** — ✅ l'accès d'urgence survit à la panne d'une région, les coûts restent raisonnables ; ❌ les niveaux 1 et 2 sont rétablis respectivement en 1 h et en 4 h.

ADR-13 — Données synthétiques par défaut hors production

- **Décision** — développement, préproduction et démonstration utilisent des patients FHIR synthétiques ; des jeux de données réalistes uniquement via la chaîne d'anonymisation, avec validation du DPO ; clés de production inutilisables hors production.
- **Conséquences** — ✅ jamais de vraie donnée de santé hors production ; ❌ certains cas limites découverts plus tard → jeux anonymisés ciblés et tests de charge proches de la production.

ADR-14 — Livrer par priorité, acheter ce qui ne différencie pas

- **Décision** — le socle sécurisé d'abord (priorité haute), les parcours de soin ensuite (priorité moyenne), l'écosystème en dernier (priorité basse) — voir la feuille de route. Les capacités de priorité basse s'appuient sur des partenaires (PSP, fournisseurs de messagerie) et n'arrivent plus tôt que sous forme de tranches minimales exigées par des fonctionnalités de priorité moyenne.
- **Conséquences** — ✅ les fondations dont dépend chaque fonctionnalité ultérieure sont justes dès le premier jour ; ❌ le lancement commercial attend le socle sécurisé (un pilote avec des cliniques partenaires se déroule pendant la phase 2).

7. Matrice de traçabilité des exigences

Preuve d'exhaustivité : chaque priorité de l'Annexe 2, chaque fonctionnalité de l'Annexe 1 et chaque livrable est rattaché à l'élément de conception qui y répond.

7.1 Priorités (Annexe 2)

ID	Exigence	Réponse de conception	Où
H1	Confidentialité des données — chiffrement au repos et en transit	TLS 1.3 en périphérie, mTLS dans le maillage (STRICT), TLS vers tous les stockages, DTLS-SRTP + chiffrement de bout en bout pour le média ; chiffrement AES-256 du stockage partout + chiffrement d'enveloppe par patient avec KMS adossé à des HSM ; aucune donnée de santé hors de la zone clinique	§5.5, §5.6, §1.5
H2	Gestion du dossier patient — sécurité, intégrité, conformité	Service Dossier patient dédié fondé sur FHIR, validation, notes et addenda signés, registre des consentements, autorisations de soin, audit complet, conservation et crypto-effacement	§2.4, §3.4
H3	Accès d'urgence pour les professionnels de santé	Bris de glace : droit dédié + justification + MFA renforcée → autorisation en lecture seule de 4 heures → synthèse critique IPS en < 300 ms ; déploiement de niveau 0 isolé, actif dans deux régions ; alertes, information du patient, revue sous 72 heures	§2.4 Accès d'urgence, §4.9
H4	Authentification et autorisation	Keycloak (OIDC, MFA, passkeys, fédération), un realm par population, jetons liés de courte durée, OPA RBAC + ABAC appliqué localement, accès à privilèges juste-à-temps, recertification trimestrielle	§2.1, §5.4
H5	Intégrité des données — ni perte ni corruption, stockage sécurisé des fichiers	ACID + contraintes, concurrence optimiste, historique en ajout seul, chaînes de hachage + ancrages signés, outbox, sommes de contrôle, Object Lock, sauvegardes immuables, stockage de documents analysé et chiffré, tests de restauration	§3.8, §2.9 Stockage de documents
M1	Planification des téléconsultations avec notifications aux médecins	Service de planification : blocages de créneaux, saga, contrainte d'exclusion, liste d'attente, file urgente, mises à jour de l'agenda en temps réel + notifications	§2.2
M2	Vidéo / audio, messagerie et partage de fichiers fiables	Plan de contrôle de la consultation + plan média SFU, qualité adaptative, chiffrement de bout en bout, messagerie avec accusés, dépôts via le stockage de documents	§2.3
M3	Gestion des ordonnances avec notifications	Versions signées, contrôles de sécurité, règles de modification et de révocation, alertes critiques de révocation, suivi de la délivrance	§2.5
M4	Masquage et caviardage des données	Obligations de politique appliquées par une bibliothèque de masquage partagée ; masquage partiel, listes blanches, exclusion par catégorie, vrai caviardage des PDF, journaux sans données de santé	§2.4 Masquage, §5.7
M5	Intégration aux agendas externes	Adaptateurs Google, Microsoft 365, CalDAV ; portées OAuth minimales ; synchronisation par notification + delta ; plages libres / occupées uniquement ; aucune donnée de santé écrite	§2.2 Agendas
B1	Interface pharmacie et stocks	Portail + API partenaire + webhooks signés, machine à états de la délivrance, adaptateurs d'inventaire, disponibilité à proximité	§2.6
B2	Gestion des préférences utilisateur	API de préférences dans la gestion des utilisateurs, répliquée vers la notification par événements	§2.1, §2.7
B3	Suivi de la distribution et de la lecture des notifications	Machine à états, accusés des fournisseurs, accusés de lecture dans l'application, journal en ajout seul (Cassandra, 13 mois), aucun pixel de suivi dans les e-mails	§2.7

ID	Exigence	Réponse de conception	Où
B4	Anonymisation des données pour la préproduction et les démonstrations	Données synthétiques par défaut ; chaîne d'anonymisation (suppression des identifiants, pseudonymes à clé, généralisation, décalage des dates, k-anonymat), validation du DPO	§5.7, §2.9
B5	Passerelle de paiement sécurisée	Champs hébergés par le PSP (SAQ A), 3-D Secure, jetons uniquement, pré-autorisation + encaissement, grand livre	§2.8
B6	Remboursement des transactions	Machine à états des remboursements, règles automatiques, double validation au-delà d'un seuil, avoirs, écritures comptables	§2.8 Remboursements

Couverture : 5/5 exigences hautes, 5/5 moyennes et 6/6 basses sont conçues. L'ordre de livraison suit les priorités (feuille de route).

7.2 Fonctionnalités de l'Annexe 1

Composant	Fonctionnalité	Mécanisme	Où
① Gestion des utilisateurs	Inscriptions et mises à jour du profil	Inscription autonome du patient avec assurance de l'identité ; intégration des professionnels avec vérification dans les registres ; organisations de pharmacie	§2.1
	Authentifier patients, médecins et personnel de pharmacie	Realms Keycloak, OIDC + PKCE, MFA, passkeys, fédération e-CPS	§2.1
	Autoriser selon le rôle	Matrice RBAC + politiques ABAC (OPA)	§2.1
	Préférences	API de préférences + événements `PreferencesMisesAJour`	§2.1
② Planification	Réserver, déplacer, annuler	Blocages de créneaux, saga avec la facturation, règles d'annulation	§2.2
	Notifier les médecins	Événements → Notification + agenda en direct via la passerelle temps réel	§2.2
	Agendas des médecins	Adaptateurs Google / Microsoft / CalDAV	§2.2
	Listes d'attente et priorité aux urgences	Appariement de la liste d'attente, triage, file urgente, capacité réservée	§2.2
③ Consultation	Salles virtuelles	Cycle de vie des salles, salle d'attente, jetons à portée restreinte	§2.3
	Flux vidéo et audio	SFU WebRTC + TURN, simulcast, repli en audio seul	§2.3
	Messagerie texte	Messagerie WSS, accusés, archivage au dossier	§2.3
	Transferts de fichiers	Chaîne du stockage de documents	§2.3
④ Dossier patient	Stocker antécédents, notes et dossiers	Ressources FHIR + documents	§2.4
	Ajout et modification par les médecins après consultation	Versionnage, signature, addenda	§2.4
	Consultation par les patients (avec restrictions)	Portée patient, règles de mise à disposition, caviardage	§2.4
	Intégrité et conformité	Chaînes de hachage, ancrages, audit, consentement, conservation	§2.4
⑤ Ordonnances	Créer, modifier, révoquer	Versions signées, contrôles de sécurité	§2.5
	Notifier les pharmacies	Événements → interface pharmacie, file critique pour les révocations	§2.5
	Consultation des ordonnances actives par les patients	API patient	§2.5
	Suivre la délivrance	Machine à états de la délivrance	§2.5
⑥ Interface pharmacie	Accuser réception, mettre à jour les statuts	Boîte de réception, délai d'accusé, mises à jour de statut idempotentes	§2.6

Composant	Fonctionnalité	Mécanisme	Où
	Échanges patient–pharmacie	Fils de discussion + notifications	§2.6
	Intégration des stocks	Adaptateurs + cache des disponibilités	§2.6
⑦ Notification	Alertes et rappels (SMS, e-mail, application)	Chaîne de traitement avec travailleurs par canal et files de priorité	§2.7
	Préférences (consentement, désinscription, fréquence)	Réplique locale, heures de silence, plafonds, résumés	§2.7
	Statut de distribution et de lecture	Machine à états + journal	§2.7
⑧ Facturation et paiement	Honoraires et paiements	Pré-autorisation + encaissement	§2.8
	Factures (consultations, médicaments)	Numérotation continue, PDF en WORM, avoirs	§2.8
	Remboursements	Processus de remboursement	§2.8
	Transactions sécurisées	Champs hébergés par le PSP, 3-D Secure, webhooks signés	§2.8

7.3 Livrables

#	Livrable	Artefacts
1	Diagramme d'architecture de haut niveau	Architecture de haut niveau · PNG / SVG · contexte du système · vue de déploiement
2	Conception détaillée des composants	Conception des composants (8 services + composants de plateforme)
3	Modèle de données et stratégie de stockage	Modèle de données et stockage
4	Scalabilité et performances	Scalabilité et performances
5	Mesures de sécurité et de conformité	Sécurité et conformité · diagramme du chiffrement
6	Présentation	Diapositives et notes de l'orateur

7.4 Critères d'évaluation

Critère (pondération)	Où il est traité
Clarté de la communication (20 %)	Synthèse d'une page en tête de chaque document, numérotation cohérente ①–⑧, badges H/M/B, diagramme pour chaque flux clé, présentation avec notes de l'orateur
Solidité de l'architecture (20 %)	§1 justification du style, zones, règles de communication, dépendances synchrones acycliques (index des composants), ADR
Scalabilité et performances (20 %)	§4 : calculs de capacité, budgets de latence, mise à l'échelle par service, trajectoire des bases de données, vidéo à grande échelle, reprise après sinistre, dégradation, cellules
Alignement sur les priorités (20 %)	§0.4, §6 décisions et compromis, §8 feuille de route
Stratégie de gestion des données (10 %)	§3 et §5.6-5.7
Exhaustivité (10 %)	Cette matrice : 16/16 exigences de priorité et 30/30 fonctionnalités de l'Annexe 1 couvertes

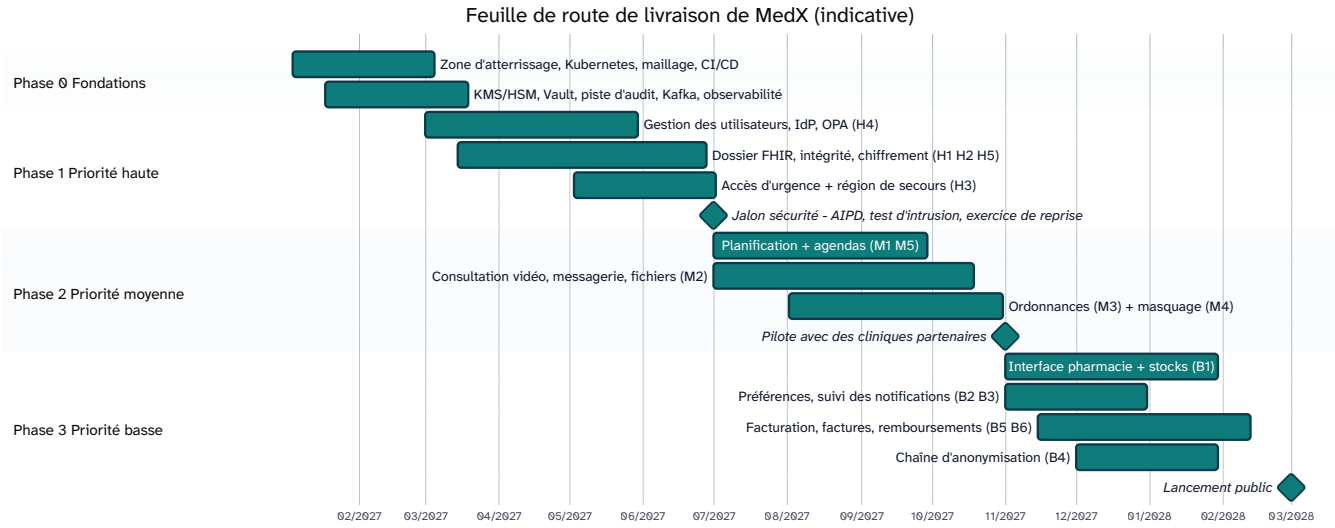
8. Feuille de route et risques

Comment la conception est livrée **dans l'ordre des priorités de MedX**, et ce qui pourrait mal tourner.

8.1 Principes de livraison

1. **Les capacités de priorité haute sont des fondations, pas des fonctionnalités**: chiffrement, identité, dossier patient, intégrité et accès d'urgence sont construits en premier et sont des **conditions de mise en production** pour tout le reste.
2. Les parcours de soin de priorité moyenne sont construits sur ces fondations.
3. Les capacités de priorité basse arrivent en dernier et s'appuient sur des partenaires (prestataire de paiement, fournisseurs de messagerie). Des tranches minimales, achetées, arrivent plus tôt **uniquement** quand une fonctionnalité de priorité moyenne en a besoin (par exemple un e-mail transactionnel de confirmation de réservation).
4. Chaque phase se termine par des critères de sortie **mesurés**, pas déclarés.

8.2 Plan par phases (indicatif, démarrage en janvier 2027)



Phase	Périmètre	Priorités	Critères de sortie
0 — Fondations (≈ 2 mois)	Comptes et garde-fous, Kubernetes + maillage (mTLS STRICT), CI/CD avec signature et analyses, KMS/HSM + Vault, bus d'événements + relais d'outbox, piste d'audit (WORM), stockage de documents, observabilité, générateur de données synthétiques	H1, H5 (prérequis)	Chaque environnement construit à partir du code; 100 % des stockages chiffrés; événements d'audit immuables de bout en bout
1 — Socle clinique sécurisé (≈ 4 mois)	Gestion des utilisateurs + Keycloak + OPA; dossier patient (FHIR, versionnage, chaînes de hachage, clés par patient, consentement, autorisations de soin); accès d'urgence actif dans deux régions; région de secours; AIPD	**H1–H5**	Suite de tests d'autorisation au vert; vérification des chaînes de hachage au vert; bris de glace p95 < 300 ms dans les deux régions; exercice de reprise réussi; test d'intrusion externe sans constat critique ou élevé ouvert

Phase	Périmètre	Priorités	Critères de sortie
2 — Parcours de soin (≈ 4 mois)	Planification (blocages, saga, liste d'attente, file urgente) + connecteurs d'agenda ; consultation (SFU, TURN, messagerie, partage de fichiers, chiffrement de bout en bout) ; ordonnances (signature, contrôles, révocation) ; masquage et caviardage ; notifications transactionnelles minimales	**M1–M5**	Test de charge à 2× la pointe de l'année 1 réussi ; indicateurs de qualité vidéo atteints sur réseaux dégradés ; une révocation atteint le portail pharmacie en < 5 s ; **pilote avec des cliniques partenaires**
3 — Écosystème et activité (≈ 4 mois)	Portail pharmacie + API partenaire + adaptateurs d'inventaire ; interface des préférences ; suivi des notifications ; facturation, factures, remboursements, grand livre ; chaîne d'anonymisation	**B1–B6**	Attestation PCI SAQ A ; rapprochement au centime près sur 30 jours ; premier éditeur de LGO intégré ; **lancement public**
4 — Croissance et expansion (continu)	Services nationaux (e-prescription, INS, dossier partagé), ISO 27001, sharding lorsqu'il est déclenché, cellules régionales, cellule américaine prête pour HIPAA	—	Déclenchée par la croissance et les décisions de marché

Organisation des équipes — une équipe plateforme (infrastructure, briques de sécurité, observabilité) et cinq équipes alignées sur des flux de valeur (identité et accès · dossier clinique et urgence · planification et consultation · ordonnances et pharmacie · communication et facturation), plus une capacité partagée pour les interfaces web et mobiles ; un référent sécurité dans chaque équipe.

8.3 Registre des risques

#	Risque	Probabilité	Impact	Atténuation	Responsable
R1	Évolution du périmètre réglementaire (périmètre HDS des activités propres de MedX, qualification du triage ou des contrôles comme dispositif médical)	Moyenne	Élevé	Revue juridique et DPO précoce ; AIPD ; triage à base de règles et validé médicalement ; plan de certification	DPO / juridique
R2	Une mauvaise expérience vidéo sur les réseaux faibles freine l'adoption	Moyenne	Élevé	Conception « audio d'abord », TURN sur 443, tests avant appel, télémétrie de qualité par région, repli téléphonique	Équipe consultation
R3	Charge d'exploitation des composants opérés par MedX (Keycloak, LiveKit, Kafka)	Moyenne	Moyen	Services managés lorsqu'ils sont dans le périmètre HDS, modèles de service standardisés, procédures d'exploitation, astreinte de l'équipe plateforme	Plateforme
R4	Abus du bris de glace	Faible	Élevé	Droits dédiés, alertes, information du patient, revues obligatoires, sanctions, UEBA	Responsable de la protection des données
R5	Erreur de gestion des clés rendant des données irrécupérables	Faible	Très élevé	Clés multi-régions adossées à des HSM, aucune suppression manuelle de clé en dehors du processus de crypto-effacement, double contrôle, exercices de récupération	Sécurité
R6	Performances de l'entrepôt FHIR à grande échelle	Moyenne	Moyen	Projections, partitionnement dès le premier jour, trajectoire de sharding, tests de charge à 2×	Équipe dossier patient
R7	Adoption lente par les pharmacies (intégrations)	Élevée	Moyen	Portail pour chaque pharmacie dès le premier jour, adaptateurs par éditeur de LGO, partenariats	Produit
R8	Panne d'un fournisseur tiers (PSP, SMS, agendas)	Moyenne	Moyen	Deux fournisseurs par canal de messagerie, dégradation maîtrisée, disjoncteurs	Équipe communication

#	Risque	Probabilité	Impact	Atténuation	Responsable
R9	Dépendance à un fournisseur	Moyenne	Moyen	Standards ouverts (FHIR, OIDC, WebRTC), composants open source, Kubernetes, infrastructure sous forme de code	Architecture
R10	Compétences rares (FHIR, sécurité, WebRTC)	Moyenne	Moyen	Technologies standard, formation, binômage, référents sécurité	Direction technique
R11	Attaque de la chaîne d'approvisionnement via les dépendances	Moyenne	Élevé	SBOM, images signées, contrôle à l'admission, épinglage et analyse des dépendances	Sécurité

8.4 Questions ouvertes pour MedX

1. Rôles juridiques entre MedX et les praticiens (responsable de traitement / sous-traitant) et périmètre de certification HDS qui en découle.
2. Calendrier et périmètre obligatoire des intégrations nationales (e-prescription, identifiant national de santé, dossier partagé).
3. Modèle de tarification et de remboursement (paiement par le patient, assureurs, tiers payant) — impact sur la facturation.
4. Marchés cibles après la France et ordre d'ouverture des cellules régionales.
5. Appétit pour des fonctionnalités assistées par l'IA (triage, prise de notes) : elles entraîneraient des obligations au titre du règlement européen sur l'IA et du MDR, et contraindraient les choix de chiffrement de bout en bout.